网络安全技术
课程回顾

题型

- 单选
- 判断
- 简答
- 综合

复习内容(1)

- **密码学**

1. 信息安全要素： 机密性 完整性 可靠性 非否认行 等等
2. 密码学基本概念： 加密 解密 明文 密文 柯克霍夫原则等等
3. 对称密码体制，非对称密码体制： 特点 区别 常见算法
4. 哈希函数：特点、常见算法，MD5的不安全性
5. 数字信封、Lamport(S/Key)、门限秘密共享

- **身份认证**

1. 身份认证方式Know sth./have sth./be sth.
2. SSL协议
3. 双因子认证，多因子认证

- **PKI**

1. 基本组成要素
2. X.509 数字证书格式
3. LDAP协议
4. CRL和OCSP
5. CA信任关系模型

复习内容(2)

- **TCP-IP安全**

1. 网络攻击：主动攻击和被动攻击，篡改，重放，窃听，拒绝服务，社会工程学
2. TCP/IP协议栈层次，每层常见协议。
3. TCP连接建立过程（三次握手），针对TCP连接过程的攻击
4. ICMP、ARP、IP、DNS协议（所属OSI层次和功能），以及针对他们的攻击

- **防火墙**

1. 两种分类方式：按工作层次分类，按位置/工作模式分类
2. 包过滤防火墙和应用层防火墙比较
3. 路由模式和透明模式比较

- **网络攻击与防范**

1. SQL注入、XSS、文件上传漏洞、CSRF，这些是什么攻击
2. IDS和IPS特点比较
3. WAF功能

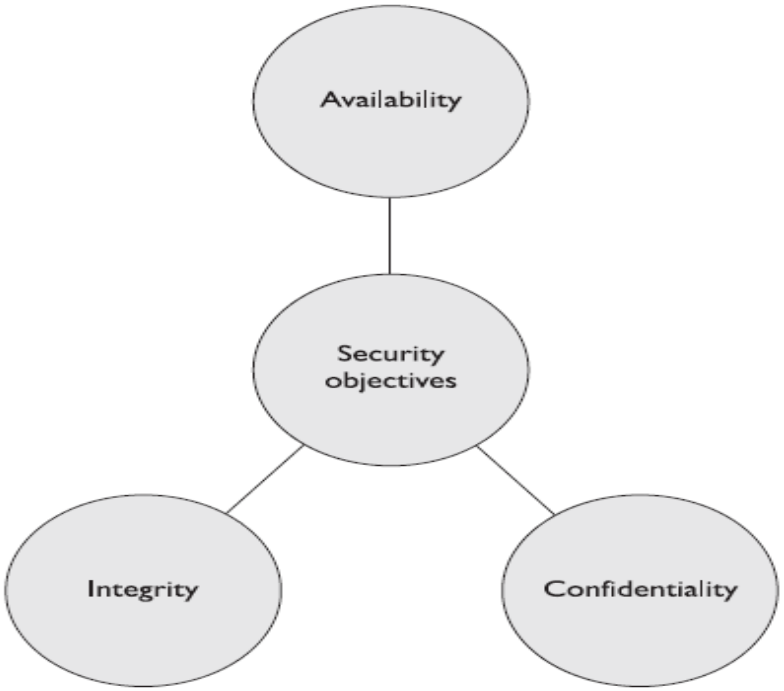
- **VPN**

1. PPTP协议 工作流程
2. IPSec协议 工作流程（2种工作模式和报文）

- 考试时间：7月3日(第17周周五)56节
- 考试地点：综合体南楼228/227

1.1 密码学简介

- 密码学是信息安全的重要组成部分
- 信息安全三要素
  - 机密性
  - 完整性
  - 可用性



机密性

- 确保信息不被非法获取
- 常见威胁
  - 窃听
  - 盗窃文件
  - 社会工程学

    ……

完整性

- 确保系统或数据被恶意篡改后，我们能够发现
- 导致破坏完整性的原因
  - 合法用户的失误
  - 非法用户的篡改

可用性

- 确保系统以足够的能力、预期的方式、可接受的性能提供服务
- 导致破坏可用性的原因
  - 设备故障
  - 软件错误
  - 环境因素
  - 人为攻击
  - 典型代表：DoS攻击(拒绝服务攻击)

密码学的基本术语

- 明文：需要保护的信息
- 加密：隐藏信息的过程
- 密文：加密后的明文
- 解密：从密文恢复出明文的过程
- 密码分析：对密码进行破译的过程

密码学的基本原则——柯克霍夫斯原则

- 柯克霍夫斯原则

  即使密码算法的任何细节已为人所知，只要密钥没有泄漏，它也应是安全的。

- 另一种表述

  密码算法的安全性是基于密钥的安全性，而不是基于保密算法细节。



Auguste Kerckhoffs
1835 –1903
荷兰语言学家、密码学家

柯克霍夫斯原则的意义何在？

- 意义在于，密码算法很难做到保密
  ① 知道算法的人可能会叛变——历史上这种事屡见不鲜
  ② 设计者有个人喜好
  ③ 频繁更换密钥是可能的，但无法频繁更换密码算法 (因为设计安全的密码算法相当困难)

4.1.1 Hash函数概述

- 定义
  - 又称哈希函数、杂凑函数、散列函数
  - 是一个将任意长度的消息映射成固定长度输出的函数

$$H:\{0,1\}^{*}\rightarrow\{0,1\}^{n}$$

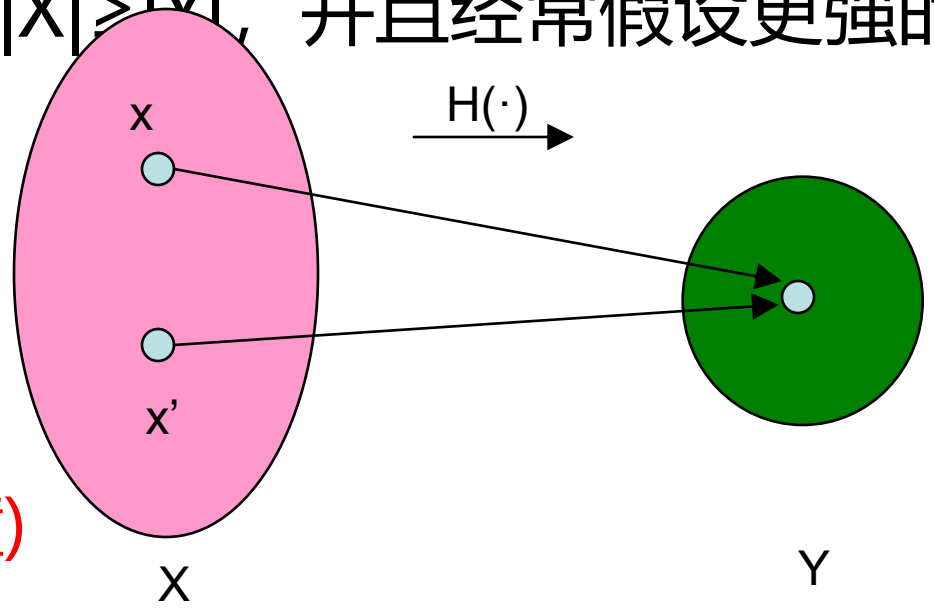
  - 其输入称为“消息”
  - 其输出称为“散列值” (Hash值、消息摘要)
  - n是散列值的长度

- 通过定义可以知道，散列值是消息所有比特的函数
- Hash函数应该实现这样的功能：
  - 改变消息的一个比特或几个比特都会使散列值发生改变

- 通常，Hash函数是一个具有压缩功能的函数
  - 设X是消息的集合，Y是散列值的集合
  - 我们总是假设|X|≥|Y|，并且经常假设更强的条件|X|≥2|Y|。

根据鸽巢原理：两个甚至多个消息会映射为同一个散列值

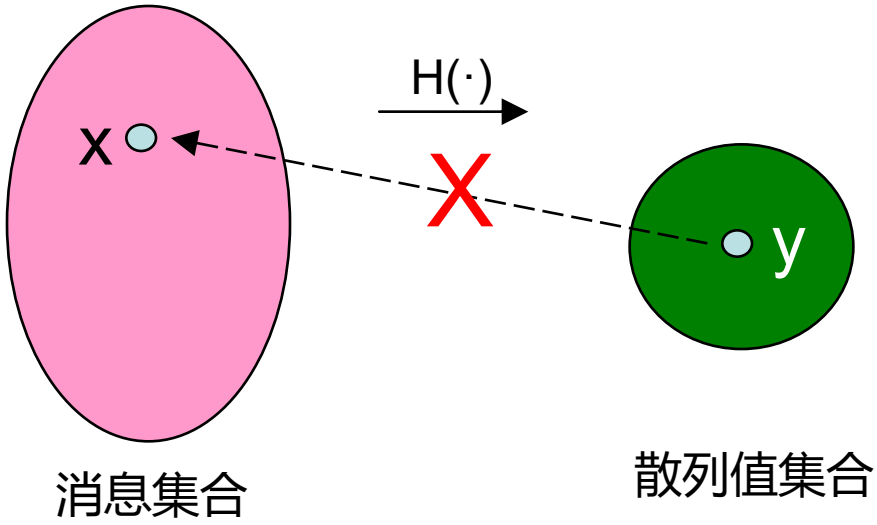
(称x和x’是一对碰撞)



4.1.2 Hash函数的安全性

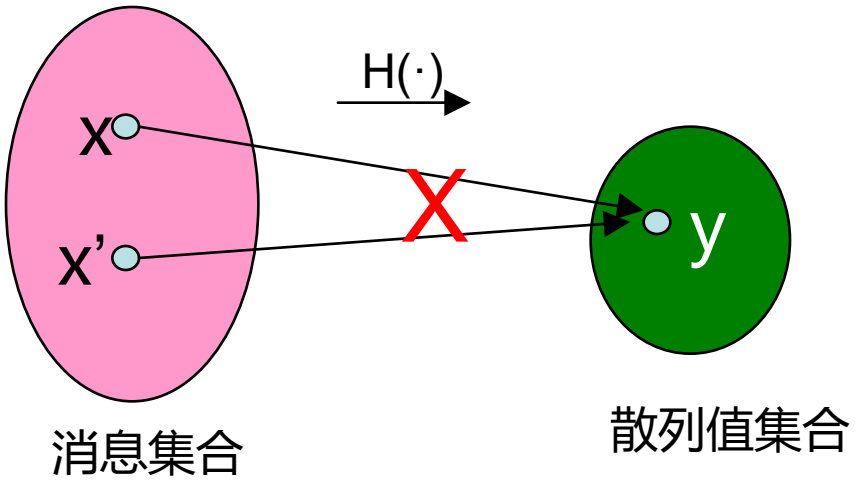
- Hash函数的分类
  ① 单向Hash函数
  ② 弱抗碰撞Hash函数
  ③ 强抗碰撞Hash函数

- 原象稳固
  - 给定散列值y，要找到其原象x，使得H(x)=y是困难的



满足该性质的Hash函数称为“单向Hash函数”

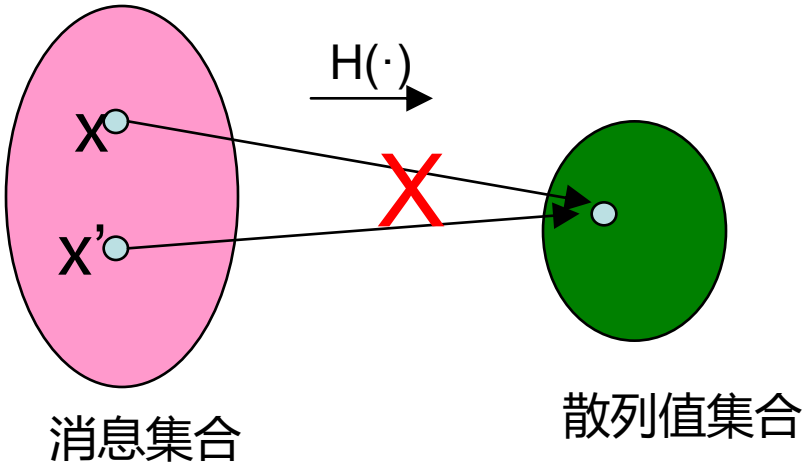
- 第二原象稳固
  - 已知H(x)=y，找到另一个x’，使得H(x’)=y是困难的



满足该性质的Hash函数称为“弱抗碰撞Hash函数”

- 碰撞稳固

  找到任意一对x、x’(两个不同的消息)，使得H(x)=H(x’)是困难的。



满足该性质的Hash函数称为“强抗碰撞Hash函数”

几个著名的Hash函数

1. MD5
   - 时间：1992年
   - 发明者：R.Rivest
   - 相关文档：RFC 1321
   - 输入：将消息分成512比特一组处理
   - 散列值长度：128比特
   - 应用领域：商业
   - 特性
     - 直接构造法: 不依赖任何密码模块和假设条件
     - 算法简洁，计算速度快
     - 特别适合32位计算机软件实现

2. SHA系列 (SHA-0、SHA-1、SHA-2)
   - 时间：1993年，1995年的修改版称为SHA-1
   - 开发者：NIST、NSA
   - 相关文档：FIPS 180，联邦信息处理标准
   - 应用领域：美国政府
   - 运行速度比MD5慢
   - SHA–1输入：将消息分成512比特一组处理(与MD5相同)，整个消息长度小于2^{64}
   - SHA–1散列值长度：160比特

- MD5是金融业、数据库系统等首选的Hash函数
- 很多学者和爱好者投入到对它破译的工作中(寻找碰撞)，甚至出现很多相关的网站
- 在诸多攻击中，我国学者王小云的方法最具威胁
- 在CRYPTO’04学术会议上，王小云做了破译MD5的学术报告，令国际顶尖密码专家为之震惊
- 这次会议的总结报告是这样写的
  - 我们该怎么办？MD5被重创了，它即将从应用中淘汰。SHA-1仍然活着，但也见到了它的末日。现在就得开始更换SHA-1了。

- 既MD5被破译之后，密码学界仍认为SHA-1是安全的
- 2005年，NIST宣布
  - SHA-1还没有被攻破，也没有理由怀疑它的安全性
- 但仅在一周之后，王小云又令密码学界大跌眼镜
  - SHA-1也被她破译了

- 因为SHA-1应用比MD5广泛，美国政府早在1994年就开始使用SHA-1
- 因此SHA-1崩溃的影响甚至超过半年前MD5的坍塌
- 美国政府宣布5年内不再使用SHA-1，并对SHA-1进行改进
- 目前，美国政府已逐渐减少使用SHA-1，而改用SHA-2系列

- SHA-2系列
  ① SHA-224
    - 散列值224比特
    - 安全性增加到112位
  ② SHA-256
    - 散列值256比特
    - 安全性增加到128位
  ③ SHA-384
    - 散列值384比特
    - 安全性增加到192位
  ④ SHA-512
    - 散列值512比特
    - 安全性增加到256位

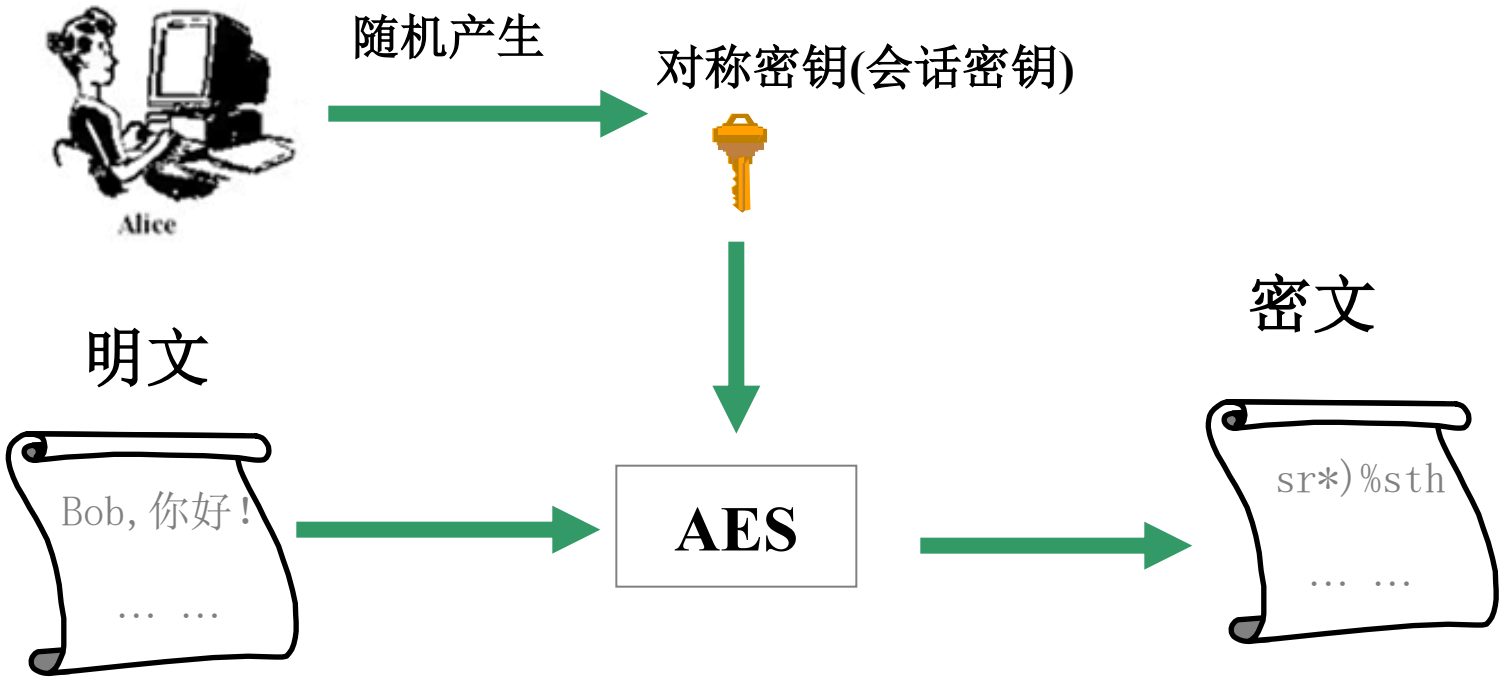
- 尽管王小云的成果真正应用到实际中还有一段路程要走，但至少证明了MD5和SHA-1存在很大的安全问题。
- 在密码学的学术理论中，任何攻击方法的计算复杂度若少于穷举攻击，就被视为成功的攻击，但这并不表示该方法已经可以进入实际应用的阶段。
- 不过，就应用层面而言，一种新破译方法的出现，暗示着将来可能会出现效率更高、更实用的改良版攻击法。
- 虽然这些实用的破译改良版根本还没诞生，但确有必要发展更强的算法来取代旧的算法。
- 因此，美国政府以及密码学界对王小云的成果感到震惊，甚至兴师动众并非小题大做。

对称密码	公钥密码
●一般要求： 1、加密解密用相同的密钥 2、收发双方必须共享密钥 **●安全性要求：** 1、密钥必须保密 2、没有密钥，解密不可行 3、知道算法和若干密文不足以确定密钥	**●一般要求：** 1、加密解密使用不同的密钥 2、发送方拥有加密或解密密钥，而接收方拥有另一个密钥 **●安全性要求：** 1、私钥必须保密，公钥可以公开 2、没有私钥，解密不可行 3、知道算法和公钥，以及若干密文不能确定私钥

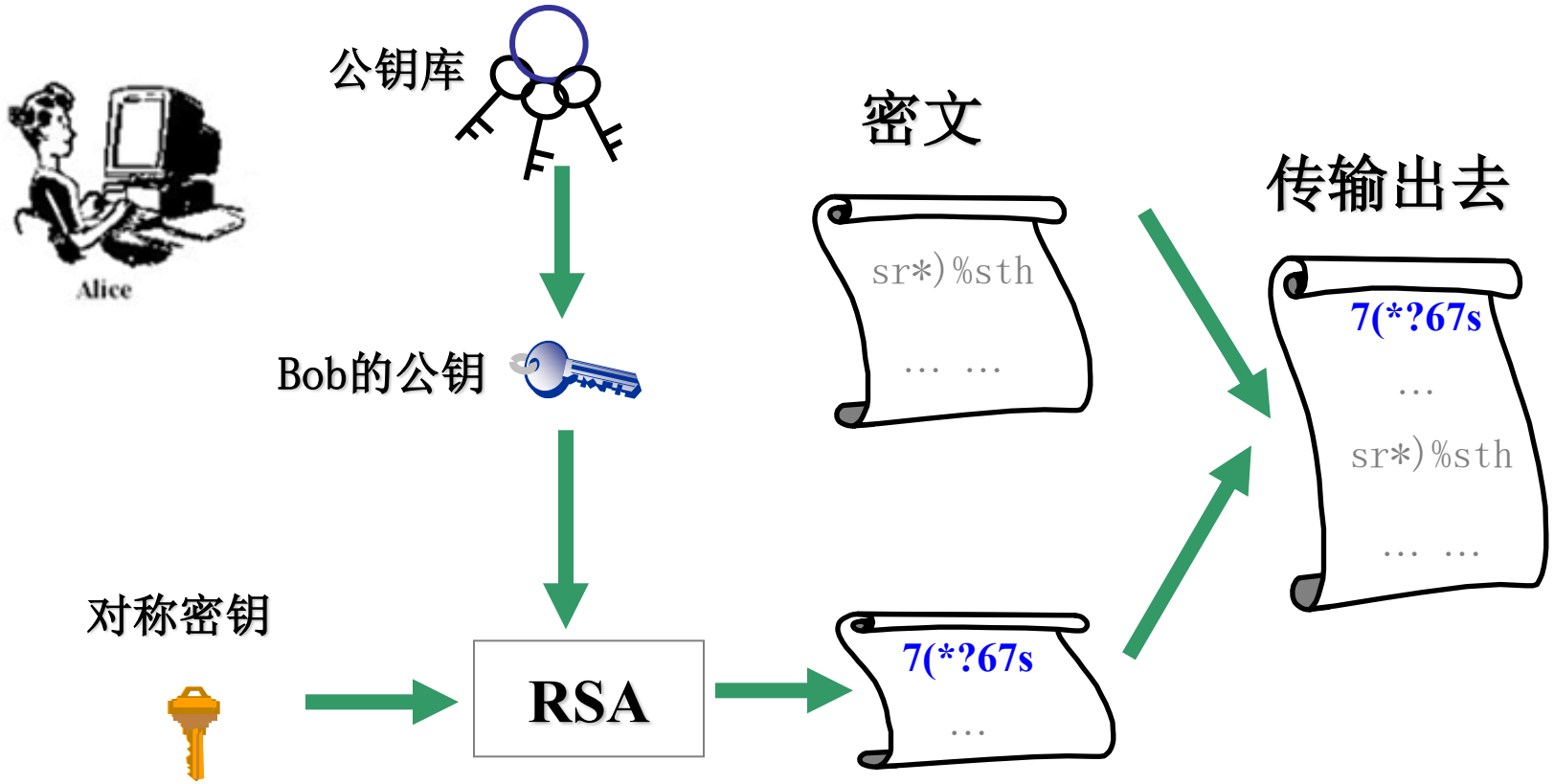
6.6 数字信封

- 对称密码、公钥密码各有长短
  - 对称密码体制：高效，适用于加密大量数据，但密钥分发困难
  - 公钥密码体制：效率低，不适于加密大量数据，但灵活
- 数字信封(Digital Envelope)
  - 目的：取长补短，利用对称密钥加密数据，用接收者公钥保护该对称密钥

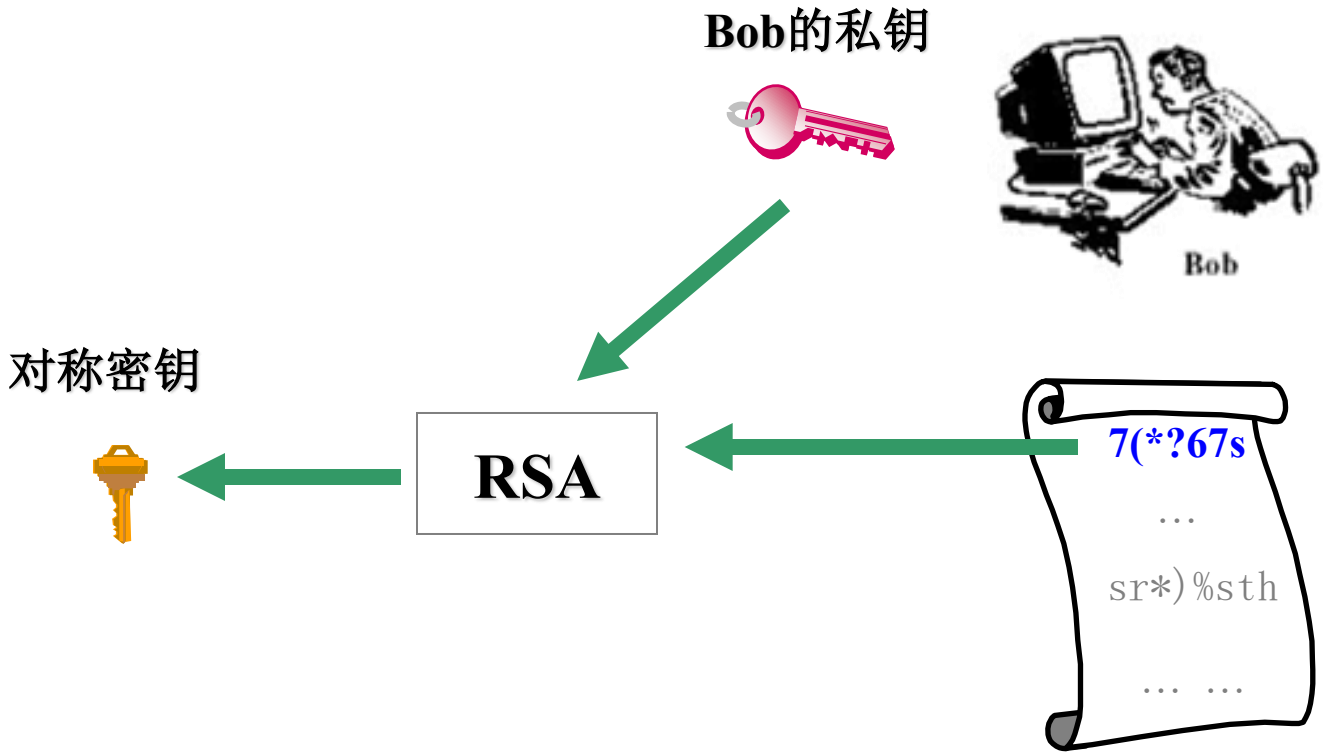
- Alice的加密过程：
  - 用对称密码体制加密数据



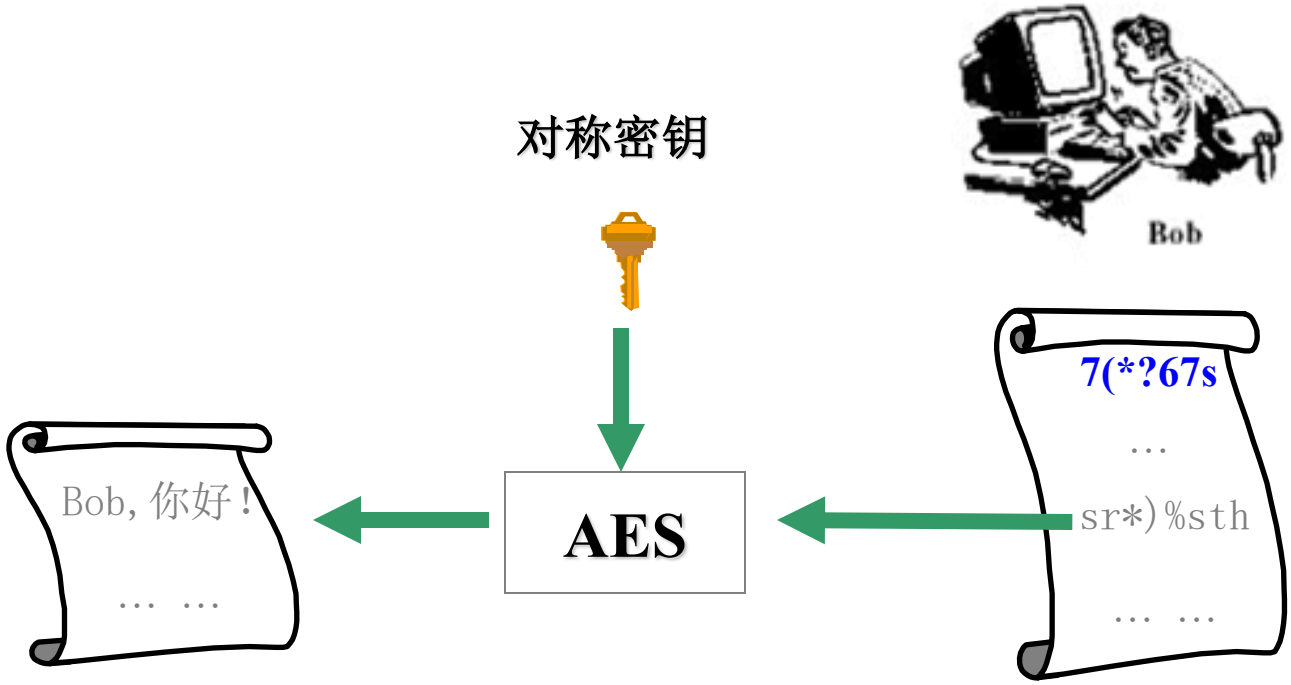
– 用公钥密码体制保护对称密钥



- Bob在接收端的解密过程：
  - 用私钥恢复对称密钥



– 用对称密钥恢复明文



数字信封总结

- 发送方
  ① 随机生成对称密钥, 用该密钥加密明文
  ② 用接收方的公钥加密该对称密钥
  ③ 将①、②的结果发送给接收方
- 接收方
  ① 用自己的私钥恢复对称密钥
  ② 用该对称密钥解密密文
- 考虑数据完整性的话，还应加入完整性技术

公钥基础设施(PKI)

- 公钥的分发仍是个严重的问题
  - 当你要与Alice通信时，首先你必须获得她的公钥
  - 但是，你从网络上接收到的公钥只是一个杂乱无章的比特串，你能确定它就是Alice的公钥吗?
- 解决方案
  - 以公钥和用户身份作为消息，产生数字签名，将两者捆绑在一起

- 现在的问题是，该签名由谁产生?
  - 其他用户？—— 缺乏公信力
  - 应该由可信第三方承担，称之认证机构(CA)

“证书”与“身份证”的类比

数字世界

现实世界

CA

签发



证书

证明公钥所有者的真实性

证明持有者的真实性

公安局

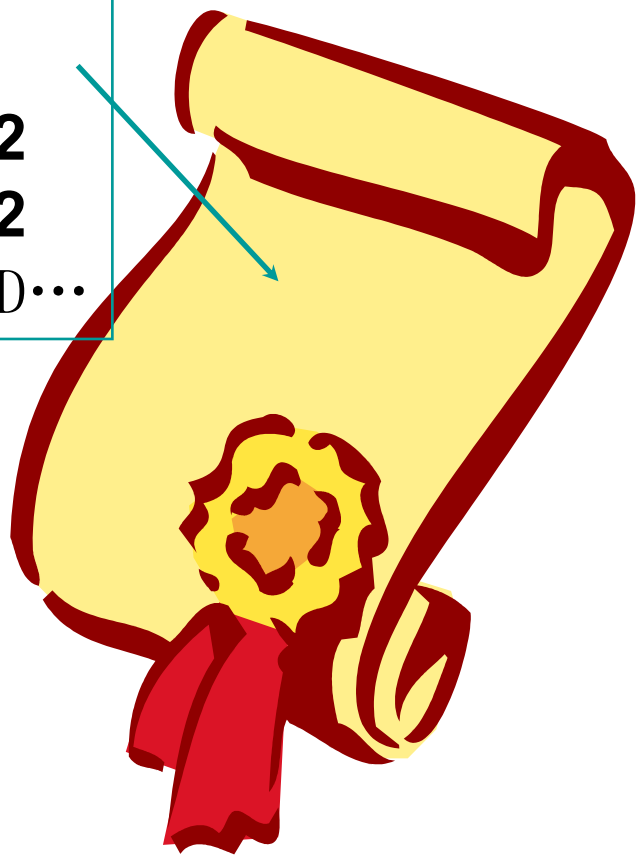
签发



身份证

证书的逻辑形式

Name:	**Tom**
Serial number:	**484865**
Issued by:	**GA-CA**
Issue date:	**1997 01 02**
Expiration date:	**2003 01 02**
Public key:	P4QRG63YJD…



证书是用户身份和用户公钥的结合体；

证书由CA在审核用户的身份后签发

- 为配合公钥证书的签发，需要十分复杂的管理机构，CA只是其中一个组成部分而已
- 由此，引出PKI的概念

PKI概述

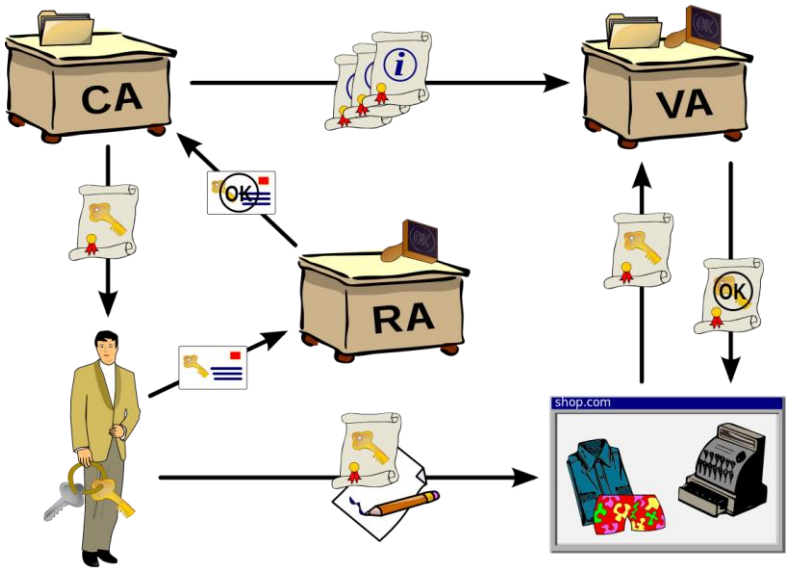
- 通过网络进行交流和商业活动，面临的最大问题是
  - 如何建立相互间的信任关系
  - 如何确保信息的真实性、完整性、机密性和非否认。
- PKI则是解决这一系列问题的技术基础，它是电子商务、电子政务的关键和基础技术。
- PKI的目的
  - 为了提供可信任的高效密钥和证书管理，以支持众多依赖于公钥的安全技术

- PKI的定义
  - 是一个使用公钥概念和密码技术实施和提供安全服务的具有普适性的安全基础设施的总称。
- PKI不是特指某一个密码设备和管理设施，它是
  - 生成、管理、存储、颁发和撤销公钥证书所需要的软硬件、人员、策略和规程的总和
  - 提供密钥管理和数字签名服务的平台

PKI提供的基本服务

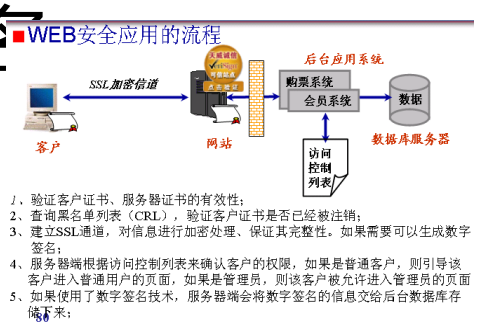
- 基本服务
  ① 机密性（包括公钥加密和对称加密）
  ② 数据完整性
  ③ 非否认
- 比如
  - 加密
  - 数字签名
  - 数字信封
  - 时间戳

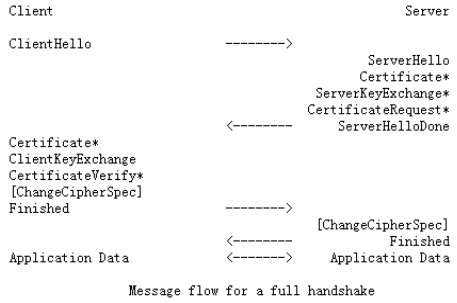
……

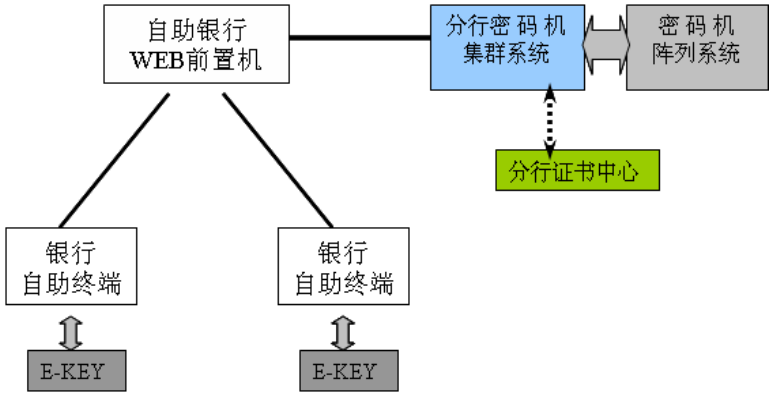


PKI的应用

- 通用应用
  - 电子邮件的加密与签名
  - SSL/TLS
  - IPSec
  - VPN
- 特殊应用
  - 金融HSM设备证书
  - ATM证书

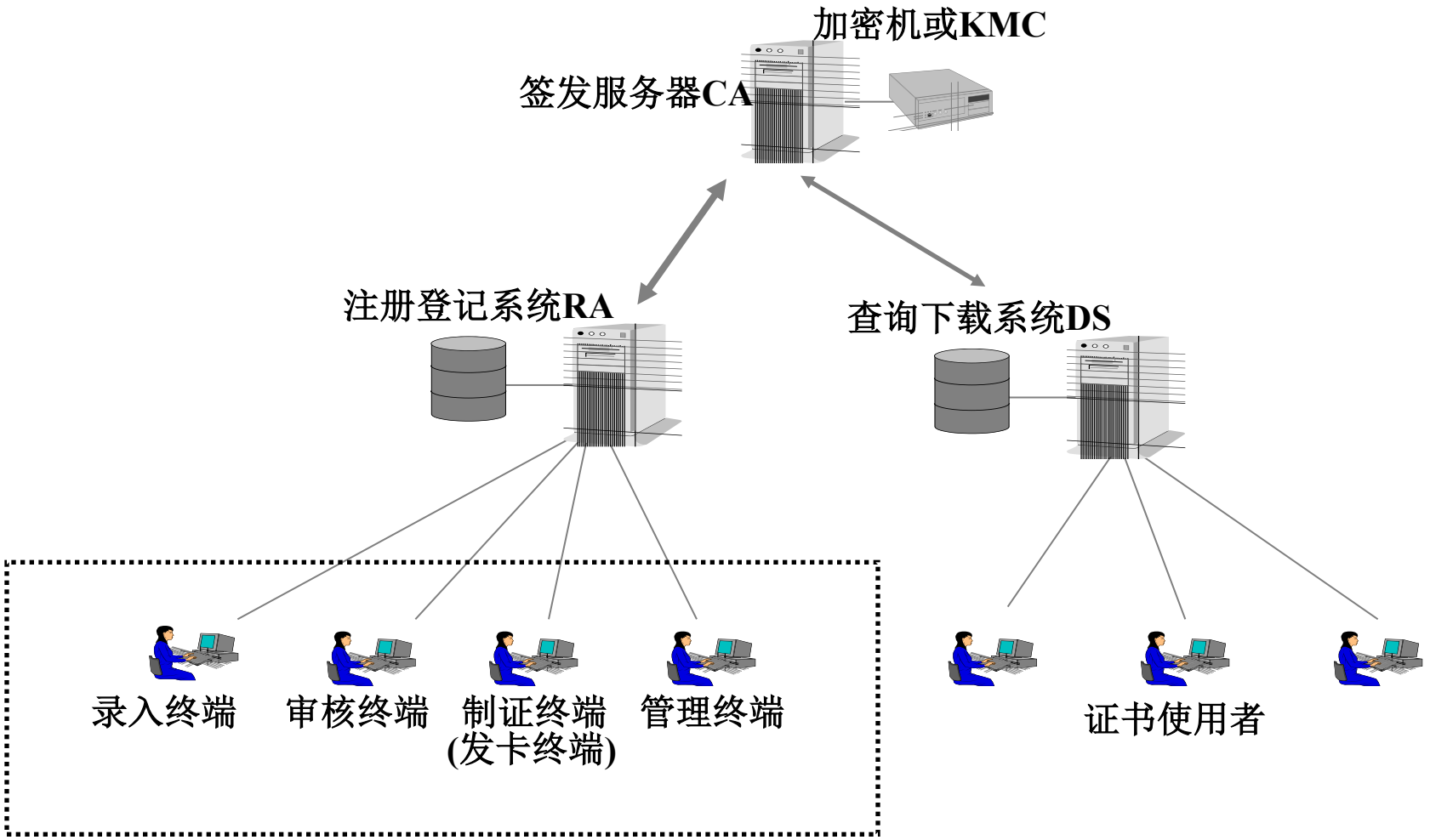






PKI的主要组成部分

① 认证机构(CA)
② 证书库
③ 密钥备份及恢复系统
④ 证书作废处理系统
⑤ PKI应用接口系统


加密机或KMC
签发服务器CA
注册登记系统RA
查询下载系统DS
录入终端
审核终端
制证终端
(发卡终端)
管理终端
证书使用者

① 认证机构(CA)

- 任务是签发和管理证书，是PKI的核心
- 签名所用的密钥是CA自己的私钥

- 用户公钥的产生方式
  ① 用户自己产生
  ② 或CA替他产生
- 用户Alice获得Bob的证书的方式
  ① Bob将证书附在消息的后面，一起传给Alice
  ② 或Alice从证书库中获得

- CA产生证书所用的签名算法有很多，主要有：
  - Hash签名
  - DSS签名 (DSS：数字签名标准)
  - RSA签名

- 引入数字签名带来的新问题：
  ① 法律应承认和重视数字签名具有的特殊作用
  ② 接收者必须具有数字签名软件，这要求该软件的普及率
  ③ 发送者已脱离组织，被取消签名的权限。要验证过去发送的签名，必须结合时间进行
  ④ PKI的费用，公共资金？用户收费？

- 证书注册审批机构(RA)
  - 辅助CA完成一些工作(该机构是可选的)
  - 职责

    ①录入、审核证书申请者的身份信息

    ②证书发放

    ③管理已发放的证书等

② 证书库

- 任务
  - 集中存放证书，是一个公开的信息库
- 系统的职责
  - 保证库的完整性，防止伪造、篡改证书
- 构建证书库的最佳方法
  - 支持LDAP协议的目录系统，用户或相应的软件通过LDAP协议访问证书库

③ 密钥备份及恢复系统

- 为防备用户忘记或丢失解密私钥，PKI应提供备份与恢复解密私钥的机制
- 注意：只备份解密私钥，不备份签名私钥(保证只有该私钥持有者可以签名)
- 可由CA来完成这个工作

④ 证书作废处理系统——PKI的重要部分

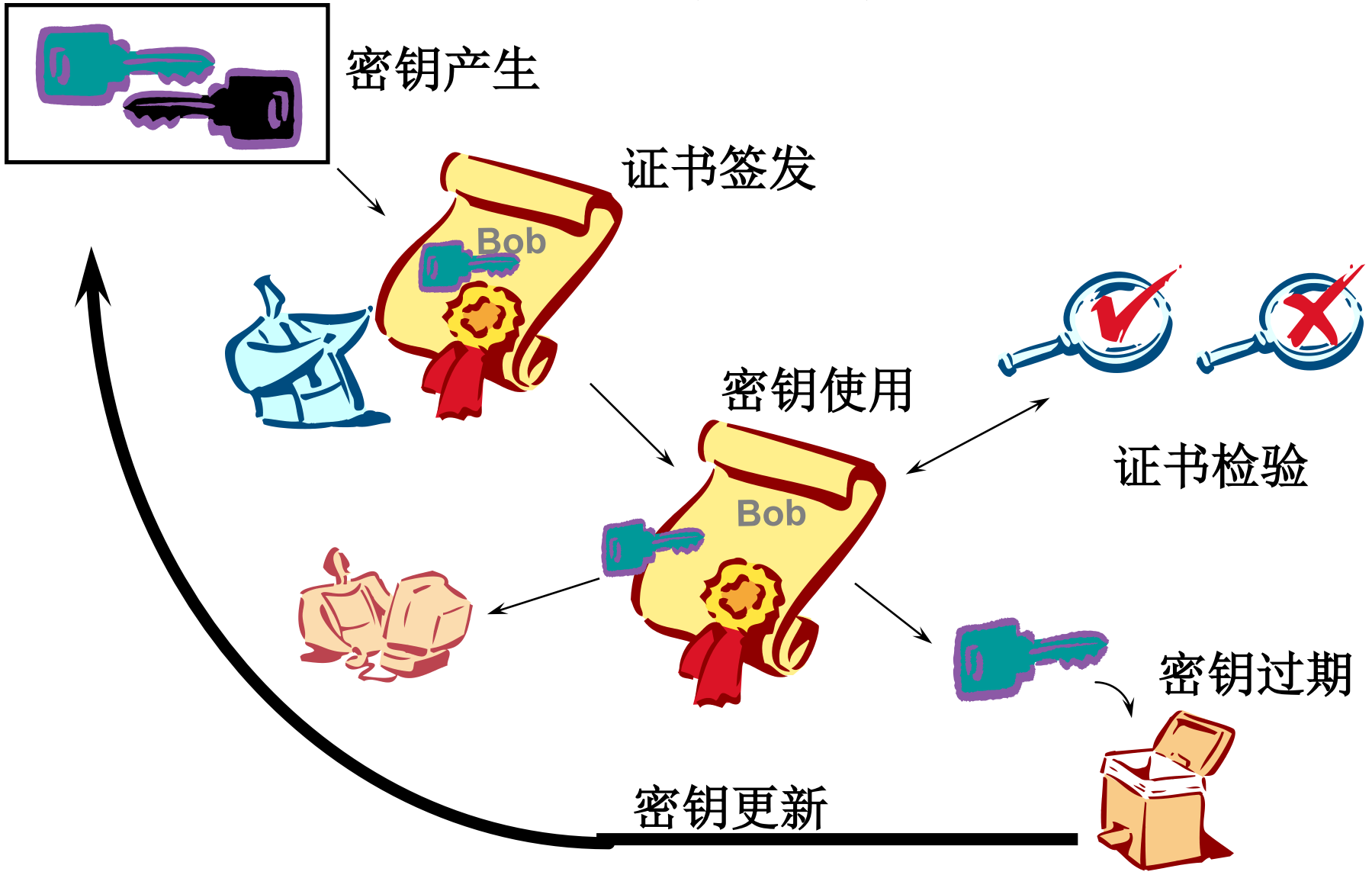
- 证书在有效期内作废
- PKI应提供的证书作废的三种策略

  ①作废一个或多个实体的证书

  ②作废由某对密钥签发的所有证书

  ③作废由某CA签发的所有证书
- 一般方法是将作废证书放入CRL(证书撤销列表)中存放

密钥生命周期



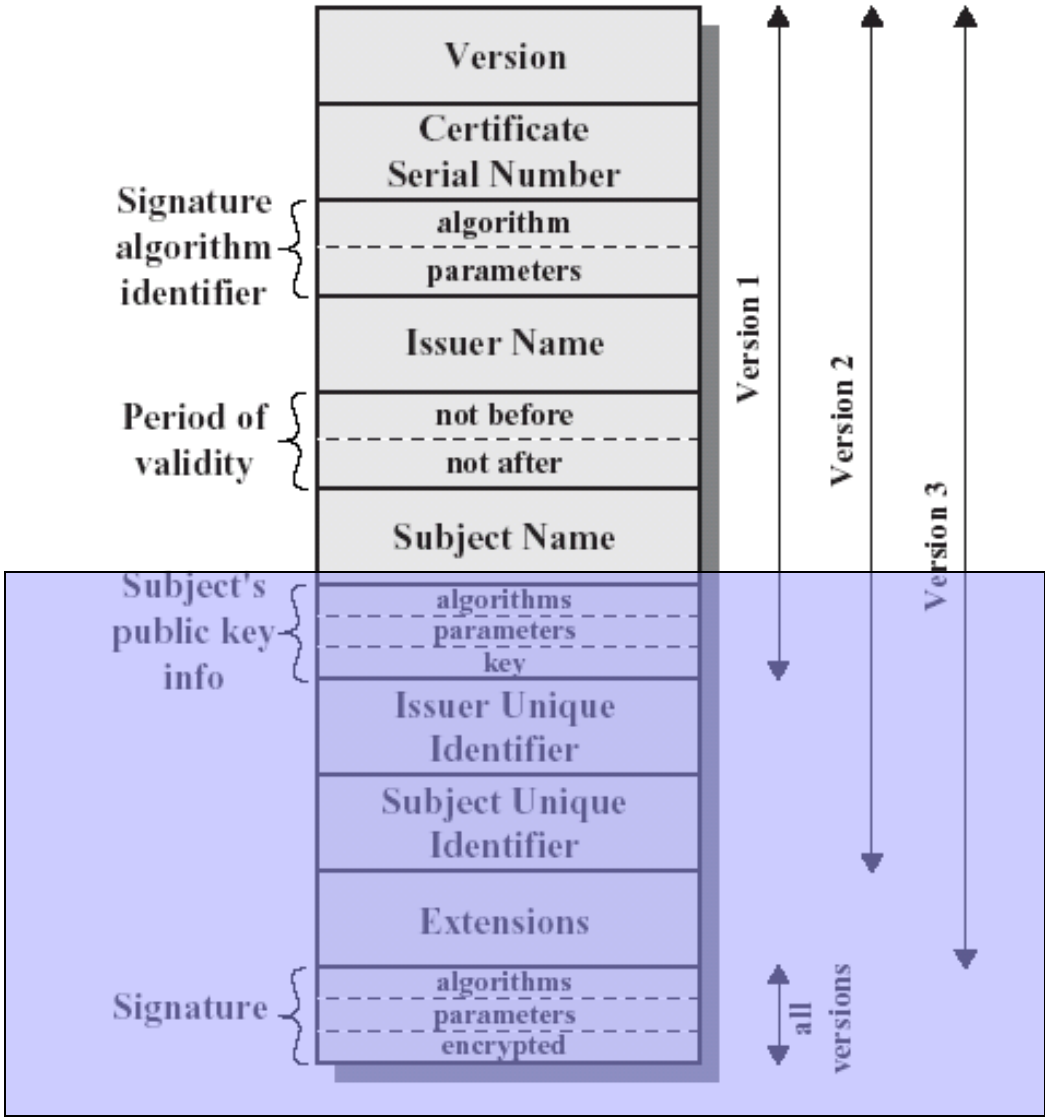
PKI相关标准

- 证书格式：X.509 v3标准
- 目录服务：LDAP
- PKCS系列标准
- 交叉认证：PKIX group in IETF(RFC 2459)

……

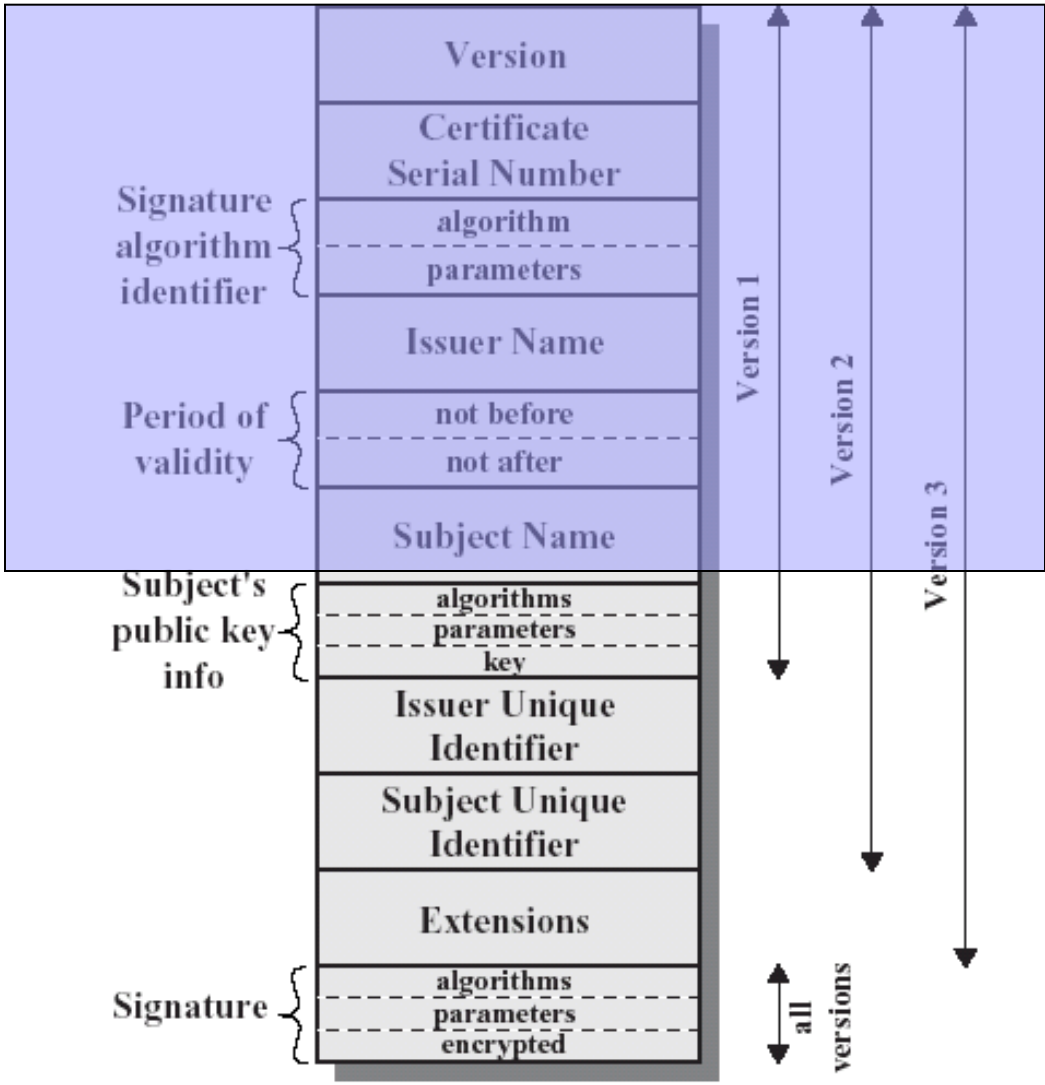
X.509证书格式

- 版本1、2、3
- 序列号
  - 在CA内部唯一
- 签名算法标识符
  - 指该证书中的签名算法
- 签发人名字
  - CA的名字
- 有效时间
  - 起始和终止时间
- 实体名字

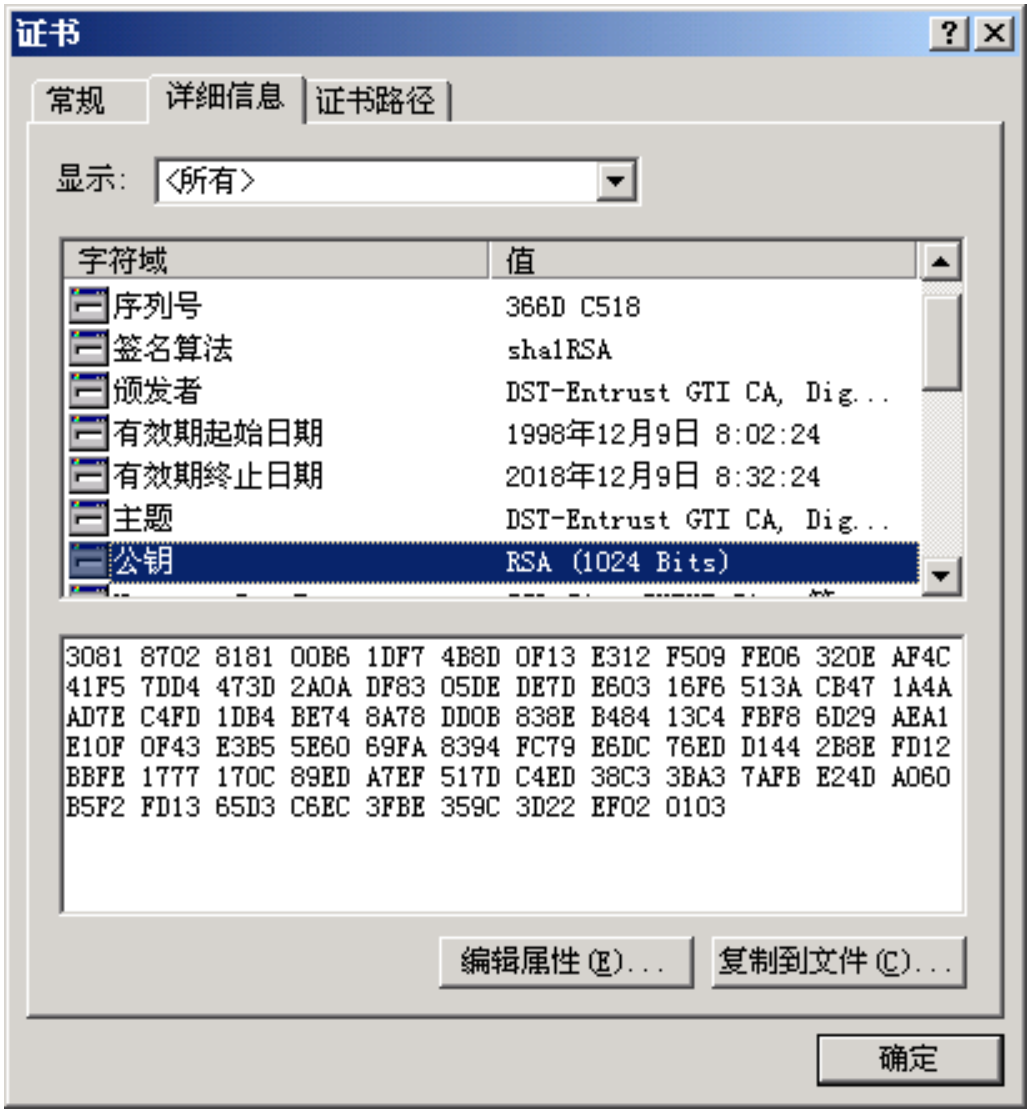


X.509证书格式(续)

- 实体的公钥信息
  - 算法
  - 参数
  - 密钥
- 签发者唯一标识符
- 实体唯一标识符
- 扩展域
- 签名



X.509证书示意图


证书
常规
详细信息
证书路径
显示:
<所有>
字符域
值
序列号
366D C518
签名算法
sha1RSA
颁发者
DST-Entrust GTI CA, Dig...
有效期起始日期
1998年12月9日 8:02:24
有效期终止日期
2018年12月9日 8:32:24
主题
DST-Entrust GTI CA, Dig...
公钥
RSA (1024 Bits)
3081 8702 8181 00B6 1DF7 4B8D 0F13 E312 F509 FE06 320E AF4C
41F5 7DD4 473D 2A0A DF83 05DE DE7D E603 16F6 513A CB47 1A4A
AD7E C4FD 1DB4 BE74 8A78 DD0B 838E B484 13C4 FBF8 6D29 AEA1
E10F 0F43 E3B5 5E60 69FA 8394 FC79 E6DC 76ED D144 2B8E FD12
BBFE 1777 170C 89ED A7EF 517D C4ED 38C3 3BA3 7AFB E24D A060
B5F2 FD13 65D3 C6EC 3FBE 359C 3D22 EF02 0103
编辑属性(E)...
复制到文件(C)...
确定

证书存放及查询方法

- 一般开发信息查询的方法——数据库方式
  Windows：IIS + Oracle(SQLServer)
  Linux：Apache + mysql
  - 缺点
    ①关系型数据库需要进行完整性处理，性能相对较低
    ②用户权限一般只设置在表一级，而不是记录一级

- 目录服务——解决了数据库存在的问题
  ① 功能和数据库类似，但其数据主要是字符
  ② 主要面向数据的查询服务，不提供事务回滚机制
  ③ 目标与数据库不同：提供快速响应、大容量查询，提供多目录服务器的信息复制

PKI的相关标准：X.500目录服务

- X.500目录服务——目录服务的国际标准
  - CCITT针对目录服务系统提出的建议
  - 用于开发一个单位内部人员目录的方法
  - 它定义了一个机构如何在企业的全局范围内共享名字和其相关的对象

- X.500目录是一个“数据库”，存放的实体叫对象
  - 对象被组织成树型结构
  - 目录的每个分支代表一个分支部门(可能在不同的地点)
  - “数据库”被分解成多个分区，存放在不同的地点
  - 用户查询时，先查本地分区，查不到再通过互联网查其他分区
- 优点：提高了查询效率

PKI的相关标准：LDAP协议

- LDAP(轻量级目录访问协议)
  - LDAP目录是树型结构，基于X.500标准，但较简单，可以自行定制
    - 类似Windows、UNIX下的目录结构
  - LDAP目录可以存放各种数据：邮件地址、人力资源数据、公钥证书等
  - 支持TCP/IP协议，已成为Internet的标准

- LDAP目录的优势
  - 跨平台、标准协议
  - 客户端程序品种多
  - 应用程序添加LDAP支持很容易
  - 存放位置对用户透明
  - 安装简单，易于维护
  - 使用ACL(访问控制列表)控制对数据的读写，开发客户端时方便简单

3.5 轻型目录访问协议

- 2. LDAP

LDAP是一个新的目录访问协议，它是在继承了X.500标准的所有优点的基础上发展起来的一个基于TCP/IP体系的目录服务协议，也是目前在网络上应用最为广泛的目录服务协议。

X.500协议是最早的具有完备意义的目录服务协议，它由CCITT和ISO两大国际组织各自对目录服务的开发成果融合而产生，并于1988年被认可，1990年初由CCITT发布，以后曾数次更新，目前仍在发展中。由于X.500协议是基于OSI体系结构的，所以早期设计人员过多地考虑了其通用性和可扩展性，致使X.500协议内容庞杂，开发和部署都极其复杂，同时性能不高。

3.5 轻型目录访问协议

随着Internet的发展，TCP/IP成为事实上的网络标准。与X.500协议不同，LDAP直接运行在更简单和更通用的TCP/IP或其他可靠的传输协议层上，避免了在OSI体系会话层和表示层的开销，使连接的建立和数据的传输更加简单、快捷，适应了以Internet为主的互联网和企业内部网络（Intranet）的应用需要。具体来说，LDAP从以下几方面对X.500协议做了简化和发展：

（1）功能方面。缩减了X.500中冗余的和使用频率较小的功能，以较低的开销完成了原来X.500协议中90%的功能；

（2）数据表示方面。统一采用文本字符串形式，避免数据解释时可能导致的二义性；

（3）编码上。仅采用X.500协议的一个子集（简单的编码规则BER），节约了空间，而且大大简化了其实现过程；

（4）传输上。直接运行于TCP/IP体系的传输层，对系统的开销较小，在提高了性能的同时，使目录服务的部署更加简单易行。

3.5 轻型目录访问协议

1993年7月，第一个LDAP规范在RFC 1487文档中发布；同年，LDAP v2发布，其功能在RFC 1777文档中进行了描述；1997年，随着LDAP v3的发布（详见RFC 2251文档），LDAP进入一个更加成熟的阶段。与LDAP v2相比，LDAP v3提供了更多的功能，如使用UNICODE支持国际化，支持强度认证及使用TLS（SSL）进行完整性和安全保护等。目前，LDAP v3已成为Internet的标准。

- 3. LDAP的目录结构

与UNIX的文件系统类似，在LDAP中目录按照树型结构来组织，该树型结构称为DIT（Directory Information Tree，目录信息 ）树。LDAP 标准定义了目录中访问信息的协议，规定了信息的形式和特性、信息存放的索引和组织方式、分布式的操作模型，并且使LDAP协议本身和信息模型都是可以被扩展的。LDAP目录中可以存放如文本、图片、URL、二进制数据、证书等不同类型的数据。

LDAP树状信息中的基本数据单元称为条目（Entry），条目可以理解为关系数据库中表的记录；条目是具有标识名（Distinguished Name，DN）的属性（Attribute）集合，DN可以理解为关系数据库表中的关键字（Primary Key）；属性由类型（Type）和多个值（Values）组成。LDAP中的属性可以理解为关系数据库中的域（Field），域由域名和数据类型组成，在LDAP中为了便于检索类型（Type），一个类型（Type）可以同时拥有多个值（Value）。和关系数据一样，LDAP服务器也是用来处理查询和更新的，但LDAP与关系数据库具有较大的不同，LDAP不具有关系数据库完备的关系运算处理能力，也没有很强的数值计算能力。但是LDAP目录服务对读、浏览和搜索等操作进行了优化。

3.5 轻型目录访问协议

LDAP中条目的设计一般按照地理位置或组织关系进行组织，应用中非常直观。LDAP把数据存放在文件中，为提高效率可以使用基于索引的文件数据库，而不是关系数据库。LDAP还规定了DN的命名方法、访问控制方法、搜索格式、复制方法、URL格式、开发接口等功能。

LDAP是一个类似于DNS的关于目录服务的网络协议。如图3-13所示，在LDAP的DIT结构中，最顶部被称为根，即“基准DN”，代表一个国家、组织或学校；下一层是OU（Organization Unit，组织单元），可以代表该国家、组织或学校中的一个内部机构；更低一层的OU可用来对上一层的OU进行更细的归类，如对某一机构内部的人员按照职务进行细分等。其中，dc表示domain component。

3.5 轻型目录访问协议

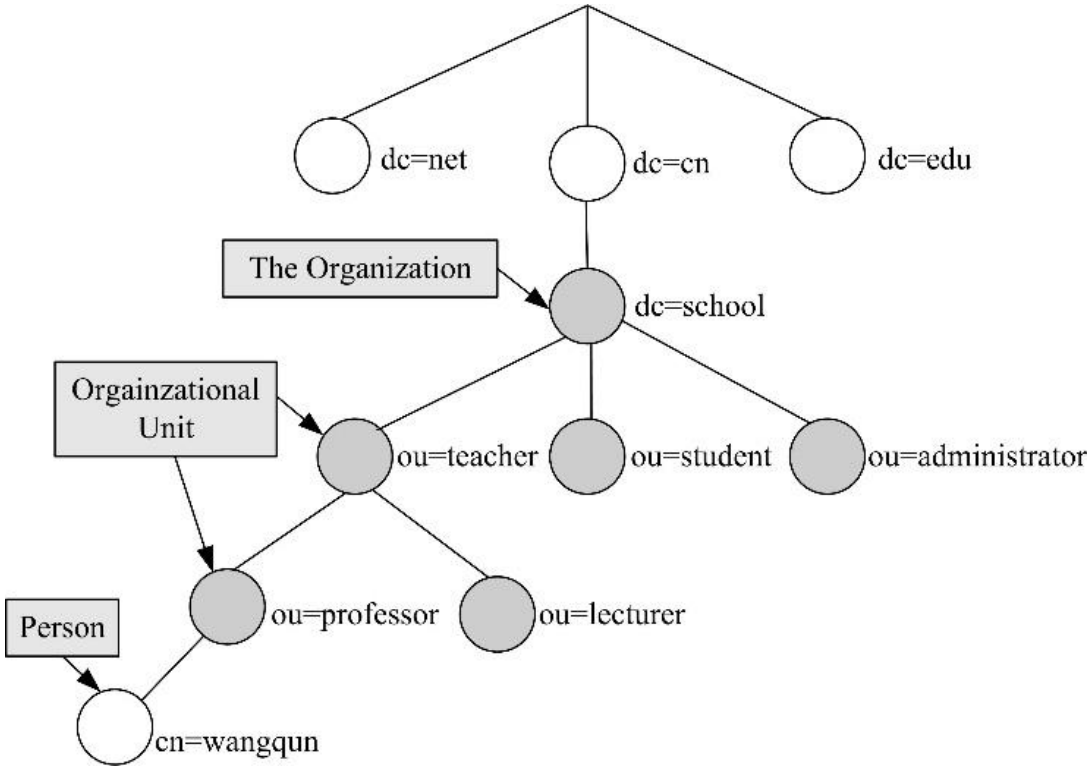


图3-13 LDAP目录的树形结构

3.5.2 LDAP的模型

LDAP通过定义4种基本模型来描述其工作机制，具体说明什么样的数据可以存放在LDAP目录中以及如何操作这些数据。下面分别介绍这4种模型的功能。

- 1.信息模型

LDAP的信息模型定义了目录中存储的数据的基本单位和数据的类型。其中，目录中数据的基本单位为条目（Entry），即关于对象的信息集合，每一个条目为一个属性集合，每一个属性含有一个属性类型和一个（或几个）值。条目相当于现实世界中的一个对象（如一个部门、一台计算机等），属性则从某一方面反映对象的特征（如部门的归属，计算机的型号等）。另外，目录模式（Directory Schema）规定了哪些属性是必须具有的，哪些只是允许存在的。

- 2.命名模型

LDAP的命名模型定义了目录的组织和查询方式。LDAP中的条目都有自己的DN和RDN（Relative Distinguished Name，相对标识名），其中DN为该条目在整个目录树中的唯一名称标识，而RDN是条目在父节点下的唯一名称标识。LDAP目录树的根（Root）是虚根，树的每一个节点都存储信息，每一个节点都有一个属性作为RDN。从其中一个节点回溯到根，经过的RDN依次连接后组成该节点的DN，DN在整个LDAP目录树中是唯一的。在LDAP目录中存储的记录内容都要有一个名字，这个名字通常存在于cn（Common Name，共同名）这个属性里，在LDAP中存储的对象都用其他的cn值作为RDN的基础。图3-14所示的是LDAP目录树中RDN和DN的组成。

3.5 轻型目录访问协议

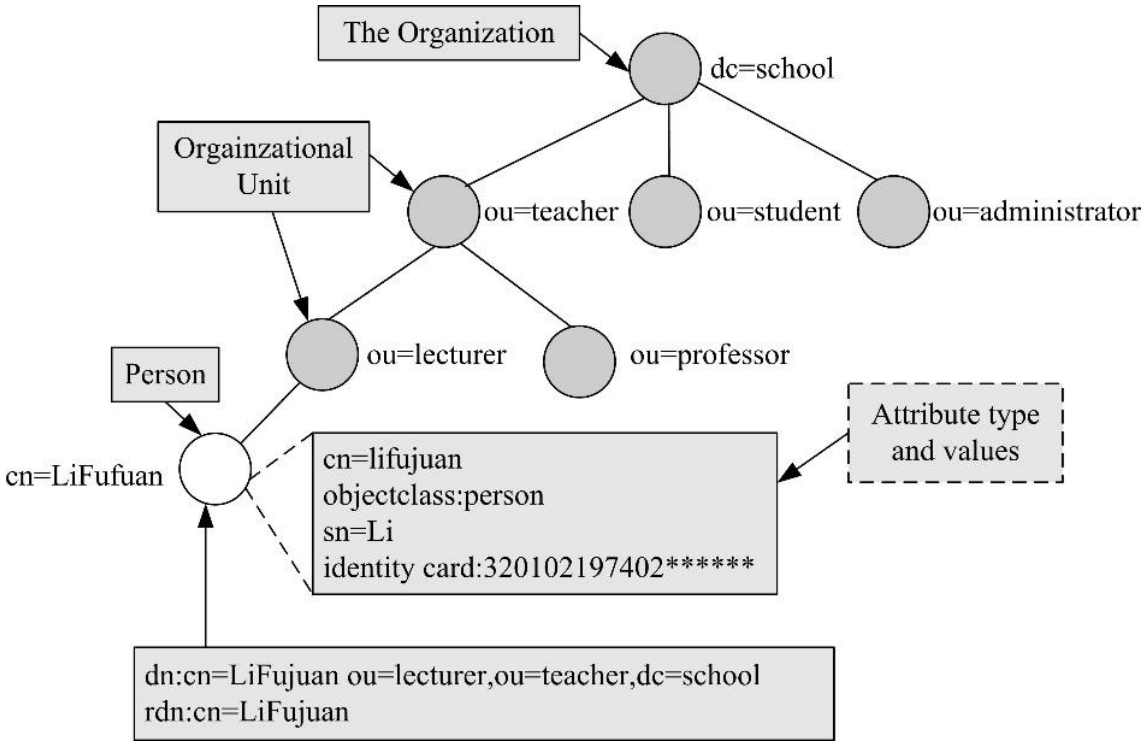
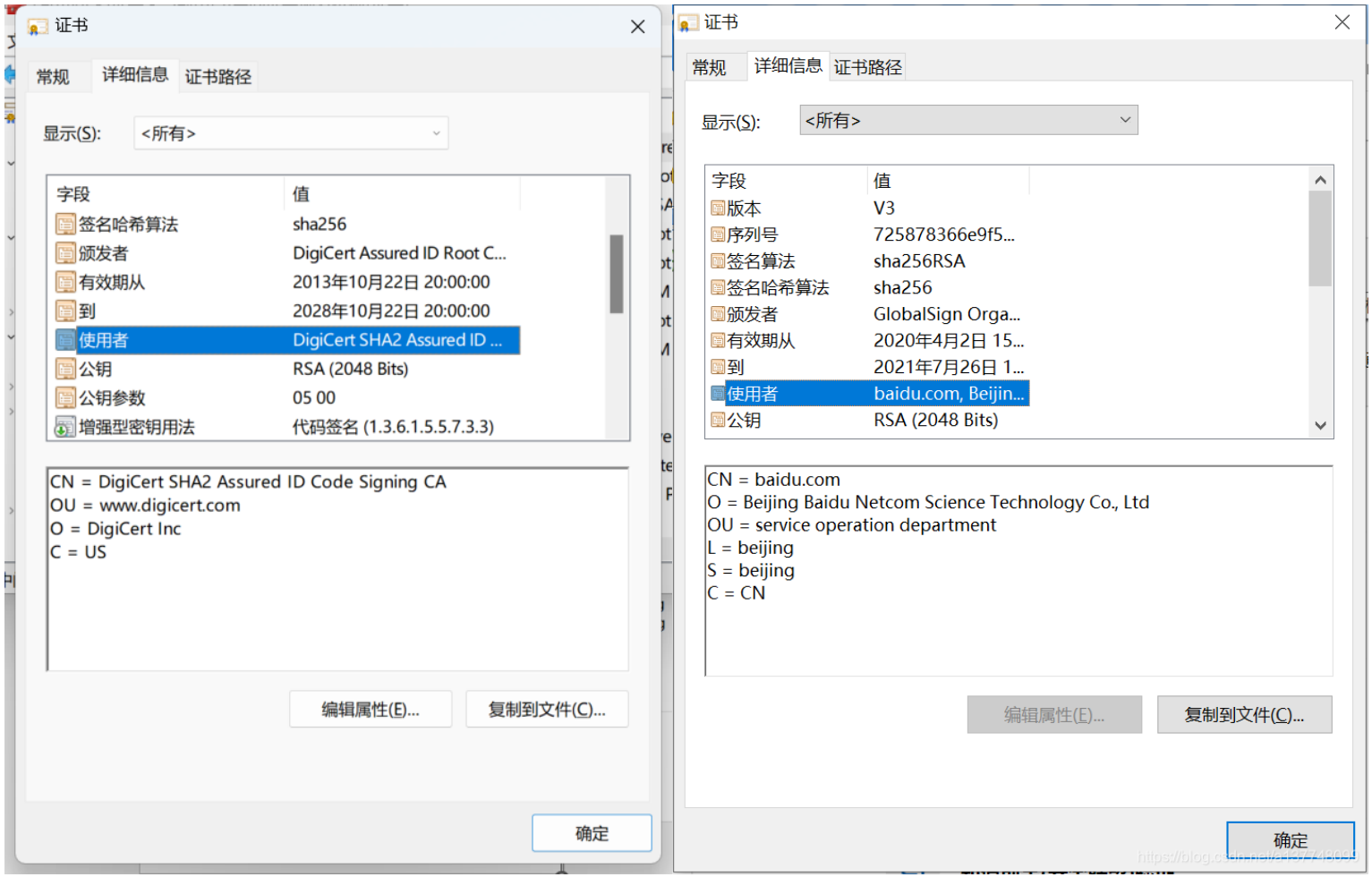


图3-14 LDAP目录中的DN和RDN

3.5 轻型目录访问协议


证书
常规
详细信息
证书路径
显示(S):
<所有>
字段
值
签名哈希算法
sha256
颁发者
DigiCert Assured ID Root C...
有效期从
2013年10月22日 20:00:00
到
2028年10月22日 20:00:00
使用者
DigiCert SHA2 Assured ID ...
公钥
RSA (2048 Bits)
公钥参数
05 00
增强型密钥用法
代码签名 (1.3.6.1.5.5.7.3.3)
CN = DigiCert SHA2 Assured ID Code Signing CA
OU = www.digicert.com
O = DigiCert Inc
C = US
编辑属性(E)...
复制到文件(C)...
确定
证书
常规
详细信息
证书路径
显示(S):
<所有>
字段
值
版本
V3
序列号
725878366e9f5...
签名算法
sha256RSA
签名哈希算法
sha256
颁发者
GlobalSign Orga...
有效期从
2020年4月2日 15...
到
2021年7月26日 1...
使用者
baidu.com, Beijin...
公钥
RSA (2048 Bits)
CN = baidu.com
O = Beijing Baidu Netcom Science Technology Co., Ltd
OU = service operation department
L = beijing
S = beijing
C = CN
编辑属性(E)...
复制到文件(C)...
确定

- 3. 功能模型

LDAP的功能模型也称为函数模型，具体定义了访问和更新目录的4类操作，具有包括：

- **（1）查询类操作。**查询某个条目并返回结果，LDAP同时支持根据DN的查询和根据某一属性的检索。如检索、比较等；
- **（2）更新类操作。**进行条目或其属性的增加、删除及重命名。如添加条目、删除条目、修改条目名等；
- **（3）认证类操作。**对客户端进行认证，控制某些交互行为。如绑定、解绑定等；
- **（4）其他类操作。**如放弃、扩展操作等。

- 4. 安全模型

LDAP安全模型定义了如何保护目录信息，防止未授权用户对目录信息的访问和修改。其中应用最为广泛的主要有绑定操作，而且绑定操作的不同使得安全机制有所不同，主要有以下3种：

（1）无认证。无认证是指LDAP客户端与服务器之间的通信不进行认证。这种方法只在没有数据安全问题且不涉及访问控制权限（如匿名访问）的时候才能使用。

（2）基本认证。当使用基本认证方式时，客户进程通过网络向服务进程发送一个用于进行身份标识的DN和口令，服务进程检查客户进程发送的DN和口令，如果与目录数据库中存储的匹配，则通过认证，并进行访问授权。否则，拒绝用户的访问。

（3）SASL认证。SASL（Simple Authentication and Security Layer，简单认证与安全层）是一种为基于连接的网络应用协议（如LDAP、IMAP、SMTP等）增加认证支持的标准，主要在RFC 2222文档中进行了描述。SASL支持多种认证机制，并且允许用户根据自己的需要进行扩充，目前已被多种网络协议所支持，具有十分广阔的应用前景。SASL认证的基本过程由服务器的请求和客户端的应答组成，根据认证机制的要求，这个过程可以重复，直到服务器发送成功或者失败消息为止。这个认证过程不仅可以执行必要的认证，而且还能传送安全层的标识信息和协商选项。如果协商成功了一个安全层，它将在认证过程完成后立即生效，为后继的协议通信提供一个安全的通道。目前常用的SASL认证机制主要有Kerberos v4、GSS-APIS、Key与OTP、CRAM-MD5和EXTERNAL等。

3.5.3 LDAP的功能模块和工作过程

LDAP认证过程的实现，由相应的认证功能模块组成。各功能模块之间协调操作，完成认证操作。

- 1. 功能模块

LDAP的目录服务是建立在TCP/IP基础之上的应用层协议，客户端与服务器之间以Client/Server模式工作，所有的目录数据存储在LDAP服务器上。如图3所示，出于安全和分布式访问的需要，同一网络中一般需要具有2台或2台以上的LDAP服务器来组成LDAP目录树，每一个LDAP服务器由目录服务模块、复制服务模块和管理模块3部分组成。

3.5 轻型目录访问协议

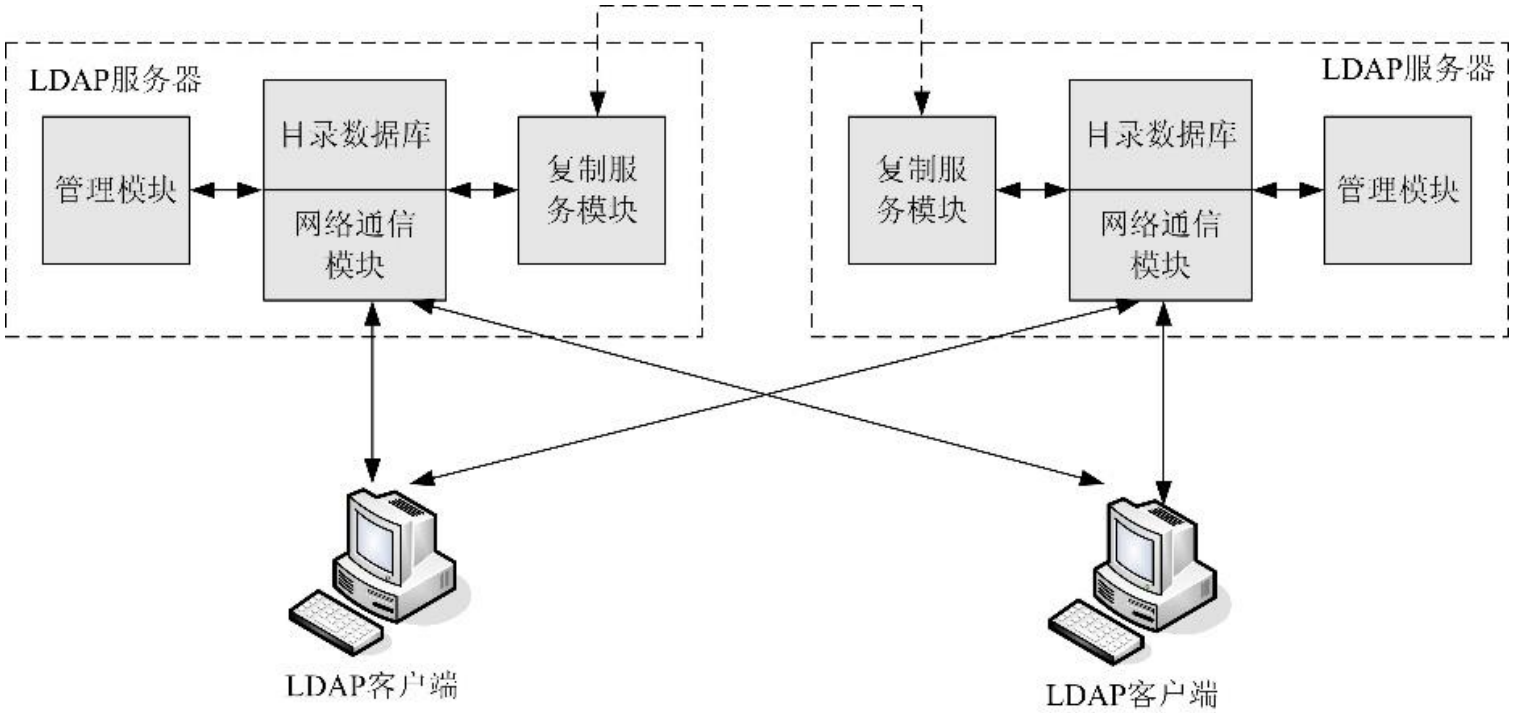


图3-15 LDAP目录服务功能模块组成示意图

3.5 轻型目录访问协议

（1）目录服务模块。目录服务模块主要由网络通信模块和目录数据库2部分组成，其中位于前端的网络通信模块主要负责LDAP服务器与LDAP客户端之间的通信；目录数据库负责LDAP目录数据的管理；

（2）复制服务模块。复制服务模块负责不同LDAP服务器之间的目录数据的复制，以保证目录服务的一致性；

（3）管理模块。管理模块负责目录信息的管理，为用户提供所期望的反应时间、通信的管理性、数据传输的完整性和服务的一致性。

- 2. 工作过程

LDAP是基于面向连接的TCP协议实现的，定义了LDAP客户端与LDAP服务器之间的通信过程和数据格式。LDAP服务器在服务端口（缺省TCP端口为389）进行监听，当收到客户端的请求后，建立连接，开始会话。LDAP的工作过程如下（如图3-16所示）：

（1）LDAP客户端根据访问需求向LDAP服务器发送操作请求；

（2）LDAP服务器负责对目录树中的条目进行必要的操作；

（3）LDAP服务器向LDAP客户端返回一个应答（响应）。这个应答可能包含查询结果，或包含操作出错信息，或者是一个引用。引用（Referral）是一种重定向机制，表明客户所需要的目录服务不在本地服务器，并向客户端返回一个能够提供服务（或能够提供更好服务）的服务器的URL；

（4）如果第（3）步在响应信息中包含的操作是引用，那么客户端则向该URL指定的LDAP服务器发送请求。

3.5 轻型目录访问协议

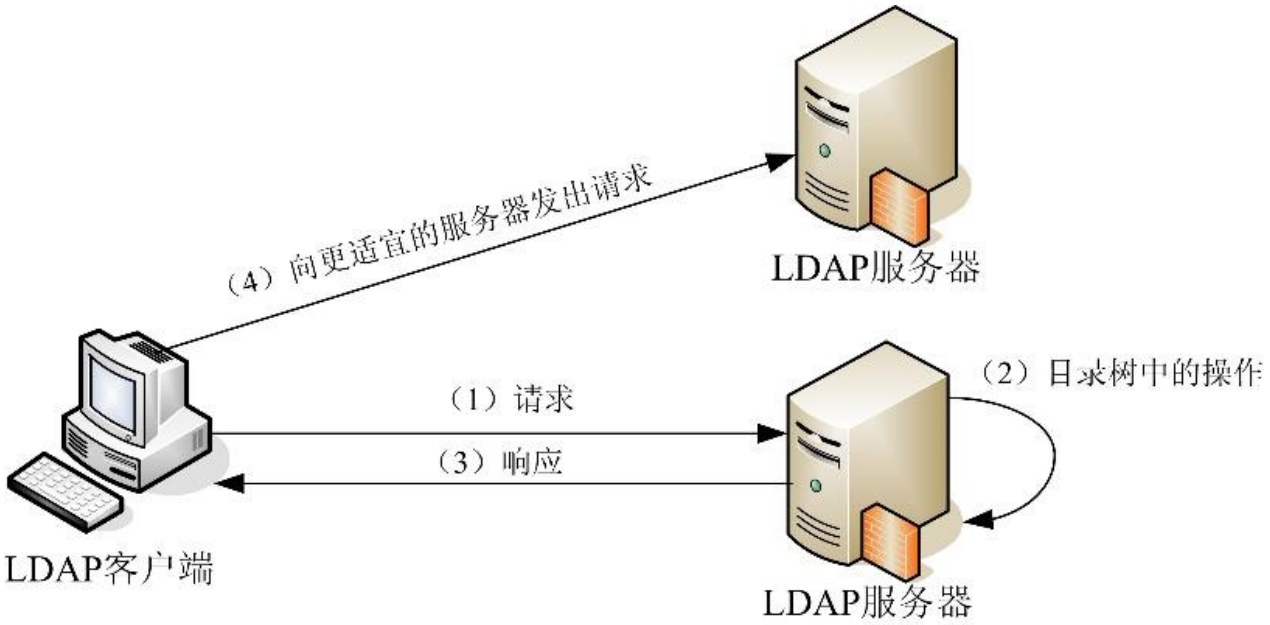


图3-16 LDAP的工作过程

PKI的相关标准： PKCS系列标准

- PKCS #1
  - RSA Encryption Standard
- PKCS #3
  - Diffie-Hellman Key-Agreement Standard
- PKCS # 5
  - Password-Based Encryption Standard
- PKCS #6
  - Extended-Certificate Syntax Standard
- PKCS #7
  - Cryptographic Message Syntax Standard
- PKCS #8
  - Private-Key Information Syntax Standard

PKI的相关标准： PKCS系列标准

- PKCS #9
  - Selected Attribute Types
- PKCS #10
  - Certification Request Syntax Standard
- PKCS #11
  - Cryptographic Token Interface Standard
- PKCS #12
  - Personal Information Exchange Standard
- PKCS #13
  - Elliptic Curve Cryptography Standard
- PKCS #15
  - Cryptographic Token Information Format Standard

PKI的产品： 主要厂商和产品

① VeriSign (www.verisign.com)
- 最大的公共CA，最早推广PKI的公司之一
- 最可信的公共CA之一，开发了一些使用工具

② Entrust 公司——世界一流
- 产品：Entrust/PKI 5.0
- 优点：
  ① 管理和安全做得都很出色
  ② 与其它产品兼容
  ③ 支持各种标准:X.509、CRL、OCSP等

信任模型

- 在Internet中，信任扮演着重要角色
  - 用户要信任可信第三方
  - 朋友推荐的人可以信任
- 所以，信任的实体间可以形成一条路径
- 直观上，路径上的节点越远，越不值得信任
- 在公钥世界里，当一个用户看到另一个用户出示的证书时，他是否信任此证书？
  - 信任难以度量，总是与风险联系在一起

- 信任的定义
  - X.509中定义：实体A假定实体B严格按照A所期望的那样行动，则A信任B。
  - PKI中定义：如果一个用户假定CA可以把任一公钥和其持有者的身份绑定在一起，则该用户信任CA。

- 信任模型主要阐述以下几个问题

① PKI用户信任的证书是怎样被确定的?

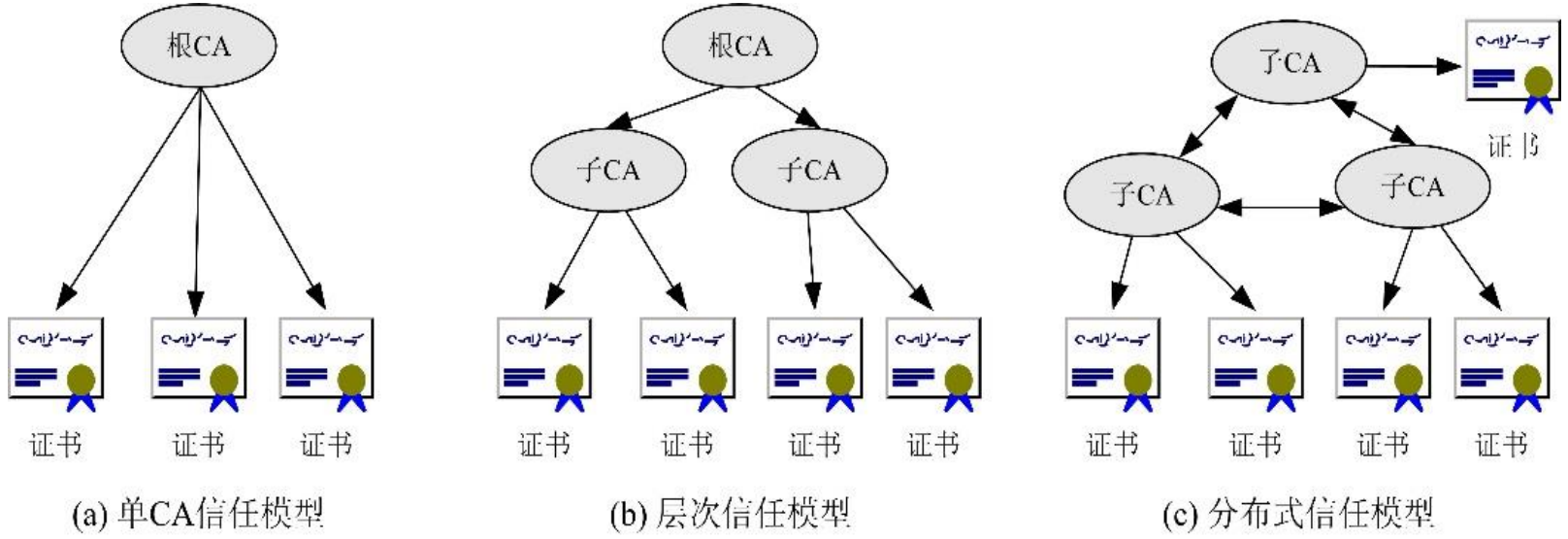
② 这种信任是怎样被建立的?

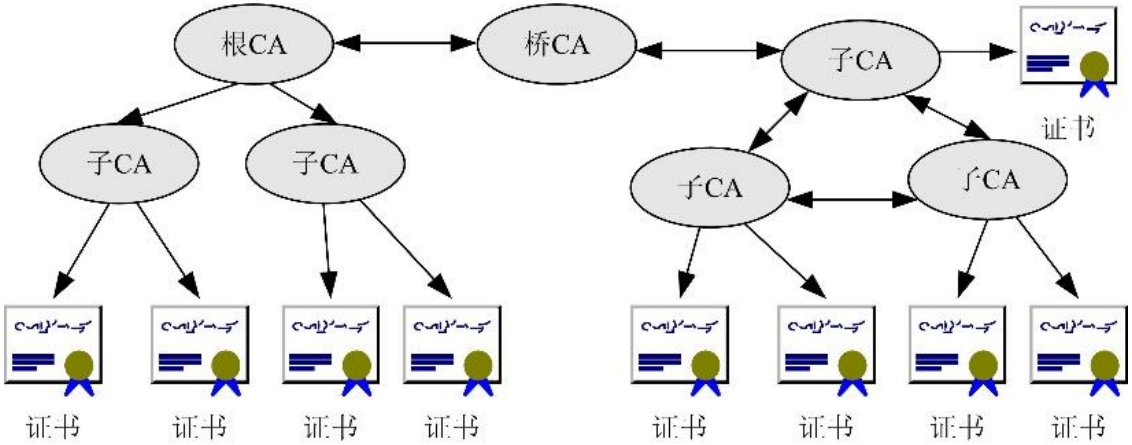
③ 这种信任在一定环境下如何被控制?

- 4种常用的信任模型
  ① CA的严格层次结构模型
  ② 分布式信任结构模型
  ③ Web模型
  ④ 以用户为中心的信任模型

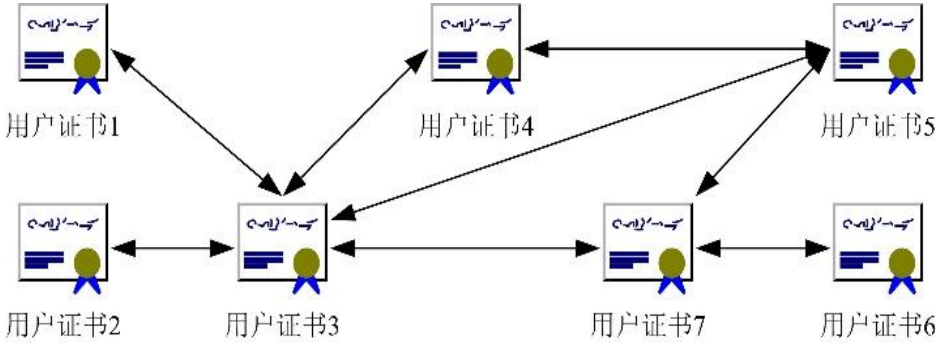
① CA的严格层次结构模型

- 是一棵树型结构
  - 根CA——认证的起点或终点
  - 根CA下有多层CA，即中间CA(子CA)
  - 叶子节点——用户
  - 所有实体都信任唯一的根CA

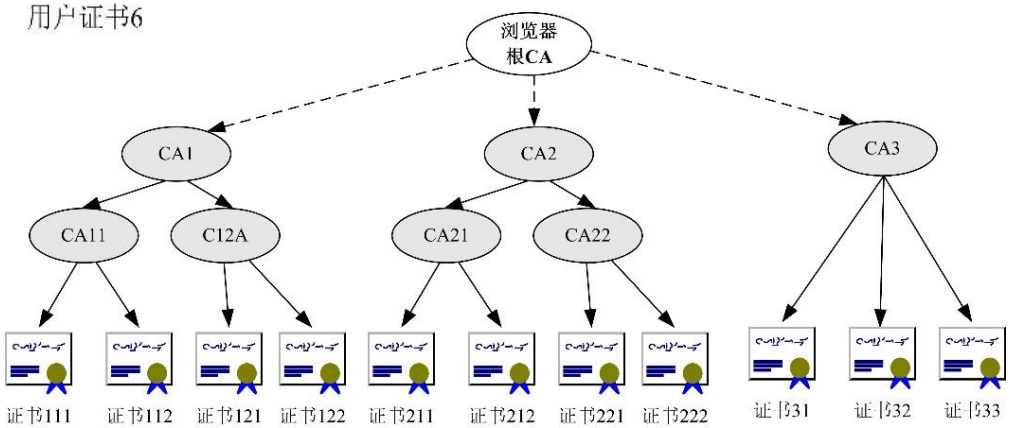




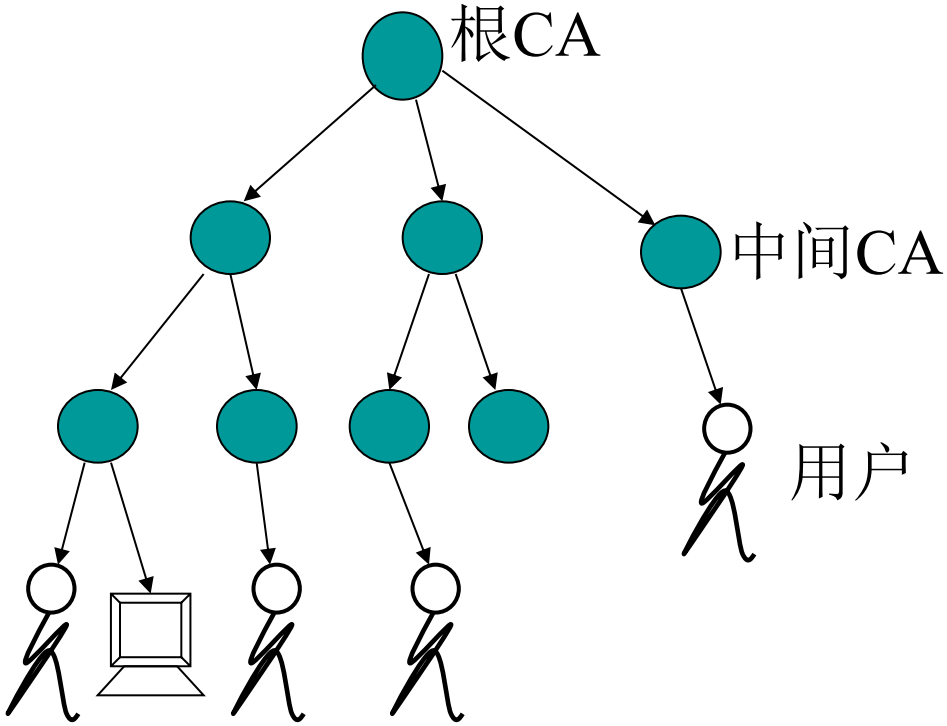
桥CA信任模型



以用户为中心的信任模型



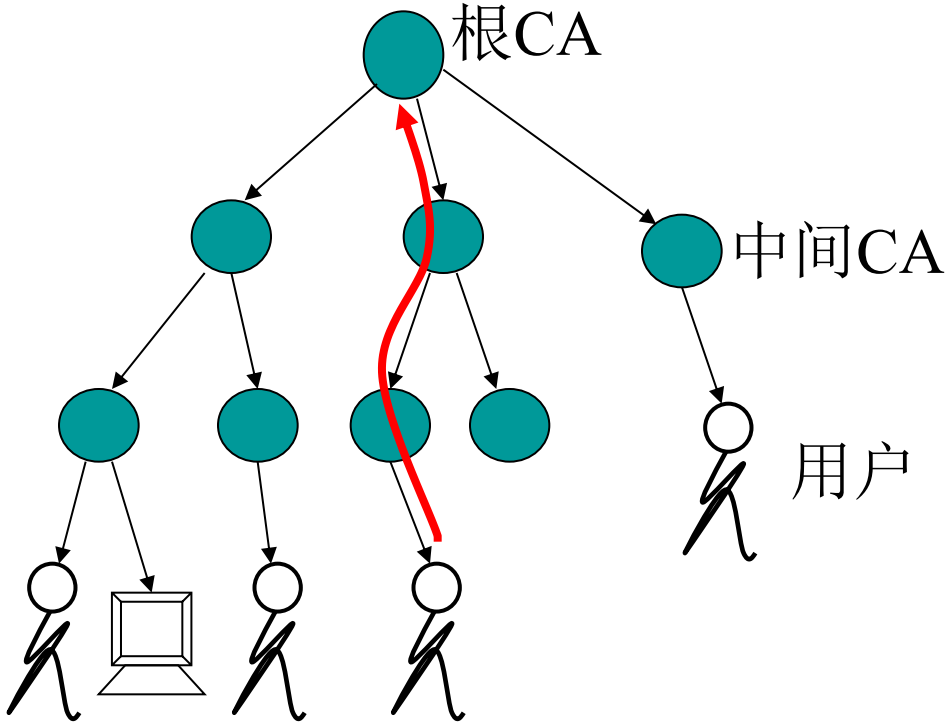
Web信任模型



- 建立规则如下
  - 根CA认证(颁发证书)它的下一级CA
  - 每个CA都认证它的下一级CA
  - 倒数第二层CA认证它下面的用户
- 每个实体都要有根CA的公钥

层次结构中如何验证证书

- 假设Bob得到Alice的证书，证书中必然包含签发证书的CA的信息。沿着层次树往上找，必可构成一条证书链，直到根CA的证书

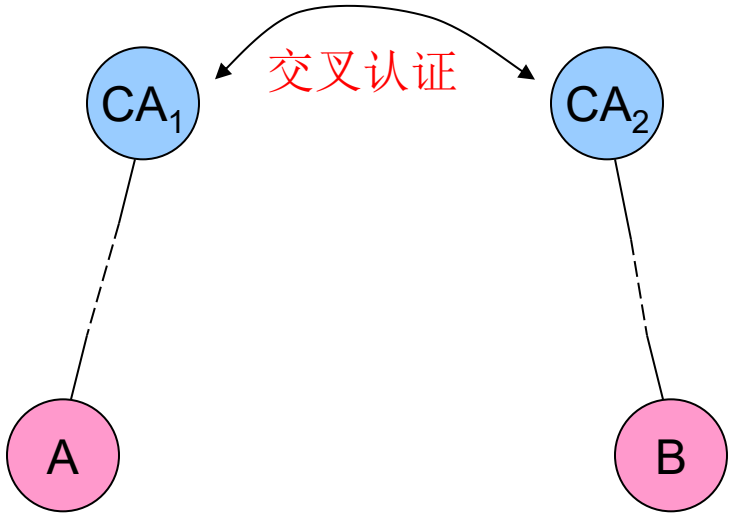


- 验证过程
  - 从根CA的证书开始，依次往下验证每一个实体证书中的签名,一直验证到Alice证书中的签名。其中，根CA的证书是自签名的，用它自己的公钥进行验证
  - 如果所有的签名都通过验证，则Bob可以确定所有的证书都是正确的。如果他信任根CA，则可以相信Alice的证书和公钥

② 分布式信任结构模型

- 信任分散在两个或多个CA上

例: 用户A在以CA_1为根的严格层次结构中
用户B在以CA_2为根的严格层次结构中



③ Web模型

- 许多CA的公钥被预装在IE、Navigator中， 确定了浏览器最信任的CA
- 浏览器制造商相当于根CA，安装在浏览器内的公钥则是它信任的CA的公钥
- 优点：简单、方便
- 缺点

① 用户自动信任预安装的公钥，如果有一个CA是“坏”的，易出问题

② 没有实用的机制撤销这些公钥(因为浏览器可能已发布到世界的每个角落，全部撤销基本不可能)

……

④ 以用户为中心的信任模型

- 用户自己决定信任哪些证书
- 典型代表软件
  - PGP：用户对公钥证书的信任是建立在该证书是否是朋友或朋友的朋友签署的
- 应用场合
  - 技术水平较高、利益高度一致的群体

各种CA信任模型的性能说明

信任模型	实用性	方便性	可扩展性	安全性	高效性	灵活性	互操作性	应用范围
单CA	低	高	高	高	高	低	低	窄
层次	中	高	高	高	高	低	高	窄
分布式	中	低	低	高	低	高	高	广
桥CA	高	低	高	高	低	高	高	广
Web	低	高	低	低	高	低	低	窄
以用户为中心	中	低	低	高	低	低	高	窄

证书及管理

证书撤销

在证书的有效期内，由于私钥丢失或证书持有者解除了与某一组织或单位的关系时，该用户所使用的数字证书需要撤销。证书的撤销操作由CA完成，当CA接收到用户撤销证书的申请时，立即执行证书撤销操作，同时通知用户证书的撤销情况。其实，出于安全考虑，在证书的正常使用中，当用户每次使用证书时系统都要检查用户的证书是否合法和有效。

证书的撤销一般可通过两种方式实现：一种是利用周期性发布机制，主要有证书撤销列表（Certificate Revocation Lists，CRL）；另一种是利用在线查询机制，如在线证书状态协议（Online Certificate Status Protocol，OCSP）。以下分别进行介绍。

- 1. 利用CRL撤销证书

证书撤销列表（CRL，又称证书黑名单）为应用程序和其他系统提供了一种检验证书有效性的方式。任何一个证书撤销以后，认证机构CA会通过发布CRL的方式来通知各个相关方。X.509中CRL所包含的主要内容格式如下（结构如图3-9所示）：



图3-9 证书撤销列表

（1）版本号。CRL的版本号，0表示X.509 v1标准，1表示X.509 v2标准，依此类推。目前最新的版本为X.509 v4。

（2）签名算法。包含算法标识和算法参数，用于指定证书签发机构用来对CRL内容进行签名的算法。

（3）证书签发机构名。签发机构的DN名，由国家、省市、地区、组织机构、单位部门和通用名等组成。

（4）本次签发时间。本次CRL签发时间，遵循ITU-T X.509 v2标准的CA在2049年之前把这个域编码为UTCTime类型，在2050或2050年之后把这个域编码为GeneralizedTime类型。

- 下次签发时间。下次CRL签发时间，遵循ITU-T X.509 v2标准的CA在2049年之前把这个域编码为UTCTime类型，在2050或2050年之后把这个域编码为GeneralizedTime类型。
- 用户公钥信息。其中包括撤销的证书序列号和证书撤销时间。撤销的证书序列号是指要撤销的由同一个CA签发的证书的一个唯一标识号，同一机构签发的证书不会有相同的序列号。
- 签名算法。对CRL内容进行签名的签名算法。
- 签名值。证书签发机构对CRL内容的签名值。

另外，CRL中还包含扩展域和条目扩展域。CRL扩展域用于提供与CRL有关的额外信息，允许团体和组织定义私有的CRL扩展域来传送他们独有的信息；CRL条目扩展域则提供与CRL条目有关的额外信息，允许团体和组织定义私有的CRL条目扩展域来传送他们独有的信息。

基于CRL的周期发布证书状态信息机制主要有以下优点：

（1）证书撤销列表的安全性是通过CA中心（或者CA授权的机构）签名来保证的，所以证书存储的地址并没有受到严格的控制，这样就可以根据需要在适当的地方存储需要的CRL。

（2）在CRL中，包含一个本列表的颁发日期，以及下一次CRL的颁发时间。这两个属性可以帮助管理CRL缓冲区。如果证书的撤销频率不是很高，CRL将会是一个有效的、有较好伸缩性的证书状态信息分发机制。

（3）使用增量CRL机制，仅发布那些自某个基本CRL颁发以来新撤销的证书，这样减少了单个签名的信息量，同时增加了CRL的实时性并且提高了证书状态响应器（服务器）的应答时间。

在PKI系统中，CRL是自动完成的，而且对用户是透明的。CRL中并不存放撤销证书的全部内容，只存放证书的序列号，以便提高检索速率。CRL产生的主要步骤如下：

（1）RA建立与CA的连接，提出撤销申请。该申请中包括撤销证书的序列号及撤销理由。

（2）CA将撤销证书的序列号签发到CRL中。

（3）系统通过数据库或LDAP目录等方式发放新的CRL，并且提供用户在线查询。

- 2. 利用OCSP撤销证书

尽管利用CRL撤销证书时具有许多优点，但该方式本身固有的CRL的存储位置分散、CRL的更新无法准确统计、客户端程序比较复杂等缺点，致使基于CRL的证书撤销机制在实际应用中存在不足。

在线证书状态协议（OCSP）是IETF工作组颁布的用于检查数字证书在当前时刻是否有效的标准协议。该协议提供给用户一条便捷的证书状态查询通道，使PKI体系能够更有效、更安全地应用于各个领域。OCSP可以作为周期性CRL的一种替代机制或者补充机制，它对于获得一个证书撤销状态的及时信息是必要的。与CRL相比，OCSP对获得证书撤销信息的及时性要强，所以OCSP一般用于网上银行、网上证券、电子政务中的某些关键部门。

OCSP协议是用于OCSP请求者（客户端）和OCSP 响应器（服务器）之间的一个请求/响应协议。客户端生成一个OCSP请求，它包含一个或者多个待查询证书的标识符，客户端可以选择性地对该请求进行数字签名。然后，客户端将请求发送给服务器。OCSP响应器对收到的请求返回一个响应（出错信息或是确定的回复）。OCSP响应器返回出错信息时，该响应不用签名。出错信息包括：请求编码格式不正确、内部错误、稍后再试、请求需要签名、未授权等内容。OCSP响应器返回确定的回复时，该响应必须进行数字签名。

OCSP是一种相对简单的请求/响应协议，它使得客户端应用程序可以测定所须验证的证书状态。协议对OCSP客户端和OCSP响应器之间需要交换的数据进行了描述。一个OCSP请求包含以下数据：协议版本、服务请求、目标证书标识和可选的扩展项等。一个确定的响应由以下信息组成：版本号、响应器名称、对每一张被请求证书的回复、可选扩展项、签名算法、对象标识和签名等组成。

OCSP机制的主要优点有：

（1）从OCSP响应器得到的信息总是能够反映该证书的真实状态。

（2）与CRL相比，每一次证书查询需要处理的信息量要小得多，因为用户只关心当前查询的证书状态，而且客户端应用程序需要处理的返回信息也要少一些。

尽管OCSP有许多优点，但基于证书响应状态协议的机制也存在一些问题与不确定性：

（1）证书状态响应器应该是一个可信的在线服务器，并为每一个请求提供及时的响应。而且，证书状态响应服务器不能完全替代CRL存储库，一定条件下仍然需要访问CRL存储库去查找证书。

（2）证书状态响应器难以实现镜像，也难以备份，从而可能成为通信中的瓶颈。而且，在线响应系统的访问流量可能非常不均匀，从而使得服务器系统经常处于一种不稳定的状态，这样很容易受到拒绝服务（DOS）等攻击。

（3）证书状态的响应服务器必须生成大量的签名，来保证每次响应的真实性和有效性，同时也可能需要验证大量的签名，这些过程将降低服务器的性能，甚至可能出现由于请求等待时间过长而丢失请求信息的现象。

证书更新

在PKI系统中，每一份数字证书被颁发以后都有其生命周期。当证书超出了其有效期就被作废而要求更新。进行证书更新的主要原因如下：一是与证书相关的密钥可能达到它有效的生命终点；二是证书即将到期；三是证书中的一些属性发生了改变，而且必须进行改变。在这些情况下，必须颁发一个新的证书，这被称为证书更新或重新证明。根据证书应用对象的不同，证书更新分为普通用户证书更新和机构证书更新两种类型。

- 1. 普通用户证书更新

普通用户证书一般是指由普通用户根据个人（包括组织或单位）需要所申请和使用的数字证书。普通用户证书更新一般有以下两种方式：

（1） **人工更新。**用户向注册机构（RA）提出更新证书的申请，RA根据用户申请信息更新用户的证书。

（2） **自动密钥更新。**PKI系统采用对管理员和用户透明的方式，对快要过期的证书进行自动更新，生成新的密钥对。

- 2. 机构证书更新

机构证书也是一种证书，只是这种证书专门用来证实机构（如CA、RA）的真实性、合法性、可靠性以及可信任性。机构证书与普通用户证书一样，如果在有效期快到期时，就要进行更新并将更新消息告知所有的相关用户及机构。因此，这就需要一套完整的机制来保证机构证书的顺利更新，从而保证整个系统的有效性和安全性。在一个PKI系统中，机构的类型分为各级CA机构及RA机构，因而机构证书的类型也相应地分为RA机构证书和CA机构证书。

当机构证书快到期时，就需要对它进行更新操作，以保证整个系统的安全性、稳定性和连续性。作为用户证书申请和签发的机构，其证书稳定性、连续性和安全性至关重要，它的更新操作与一般普通用户证书有很大的差别。普通用户证书在更新时，只需要向签发机构发出申请，由签发机构撤销旧的证书，并重新产生新的公私密钥对和颁发新的证书，用户证书就更新结束。相比之下，机构证书的更新就复杂得多，它分为根CA的更新和下级CA的更新。

为了保证系统的连续性，在机构证书更新期间，根CA就有多个证书存在。如下所示，根CA在更新期间，共有3类证书存在（其中old表示旧证书，new表示新证书）：

oldwithnew：表示用新证书签发的旧证书。

newwithold:表示用旧证书签发的新证书。

newwithnew：表示根CA自签发的新证书。

其中，oldwithnew和newwithold证书是为了在证书更新期间保持证书认证的连续性，它们在根CA证书更新结束时要被全部撤销。oldwithnew用于旧的用户证书的认证以及新旧用户证书的相互认证；newwithold用于新旧证书的相互认证；newwithnew用于新证书的认证和颁发新的下级证书。同时在根CA更新的同时，也需要用newwithnew对证书撤销列表进行操作，并生成新的证书链文件。

下级机构证书的撤销相对根CA而言就要简单些。下级机构证书快到期时，由下级机构向上级CA申请证书更新，上级CA通过为下级机构颁发新的证书并同时撤销旧的证书来达到下级机构证书的更新目的。但是，下级机构证书更新后，如果是CA机构，则要同时重签证书撤销列表并发布到证书目录服务器上，以供用户使用及认证使用。

需要说明的是，由于证书的不断更新，一段时间后同一个用户（或机构）可能存在多个“旧”证书，这一系列的“旧”证书形成了证书的历史档案，需要对其进行归档，并集中进行管理，以备需要时使用。

9.2.1 实体认证

- 实体认证，又称身份认证
- 目的
  - 向别人证明你是谁?
  - 弄清楚他是谁?
- 方法
  - 他有什么特征？他知道/拥有什么可用于识别他的东西

- 方法分类
  1. Know sth：声称者证明他知道某事或某物
     - 口令、密钥、暗号……
  2. Have sth：声称者证明他拥有某事或某物
     - 身份证、护照、IC卡、令牌……
  3. Be sth：声称者展示自身的某些不变特性
     - 指纹、虹膜、DNA……

将不同分类的认证方式组合使用，称谓双(多)因子/双(多)因素身份认证，简单地讲是指在身份认证过程中**至少提供两个类别的认证因素**，双因素认证与利用ATM（自动柜员机）取款很相似：用户必须利用持银行卡（认证设备 have sth），再输入密码(know sth)，才能提取其账户中的款项。双因素认证提供了身份认证的可靠性。

1. Know sth

- 口令是最常用的认证机制，但安全性较差
  - 易受到泄露、猜测、窃听、社会工程学等形式的攻击
- 什么是弱口令?
  - 短口令，常见单词，生日、电话号码……，系统预设口令

- 口令管理措施
  - 口令应具有一定的长度，包含多种字符类型
  - 口令不应使用易猜测的数字或字母组合
  - 口令应具有一定的生存期。。。
  - 口令不应使用一定时间内的历史口令
  - 用户登录不同系统应使用不同的口令
  - 系统应设定口令登录失败次数限制

口令空间

口令时间

口令保护

基于口令的认证机制

- 与“基于口令的加密(PBE)”的区别
  - PBE：利用口令推导出密钥
  - 基于口令的认证：利用口令进行实体认证
    - 例如：登录电子邮箱、进入网上银行…

- 需解决的关键问题：口令的存储
- 直接明文存储口令

  一旦得到存储口令的数据库，就可得到全体人员的口令。

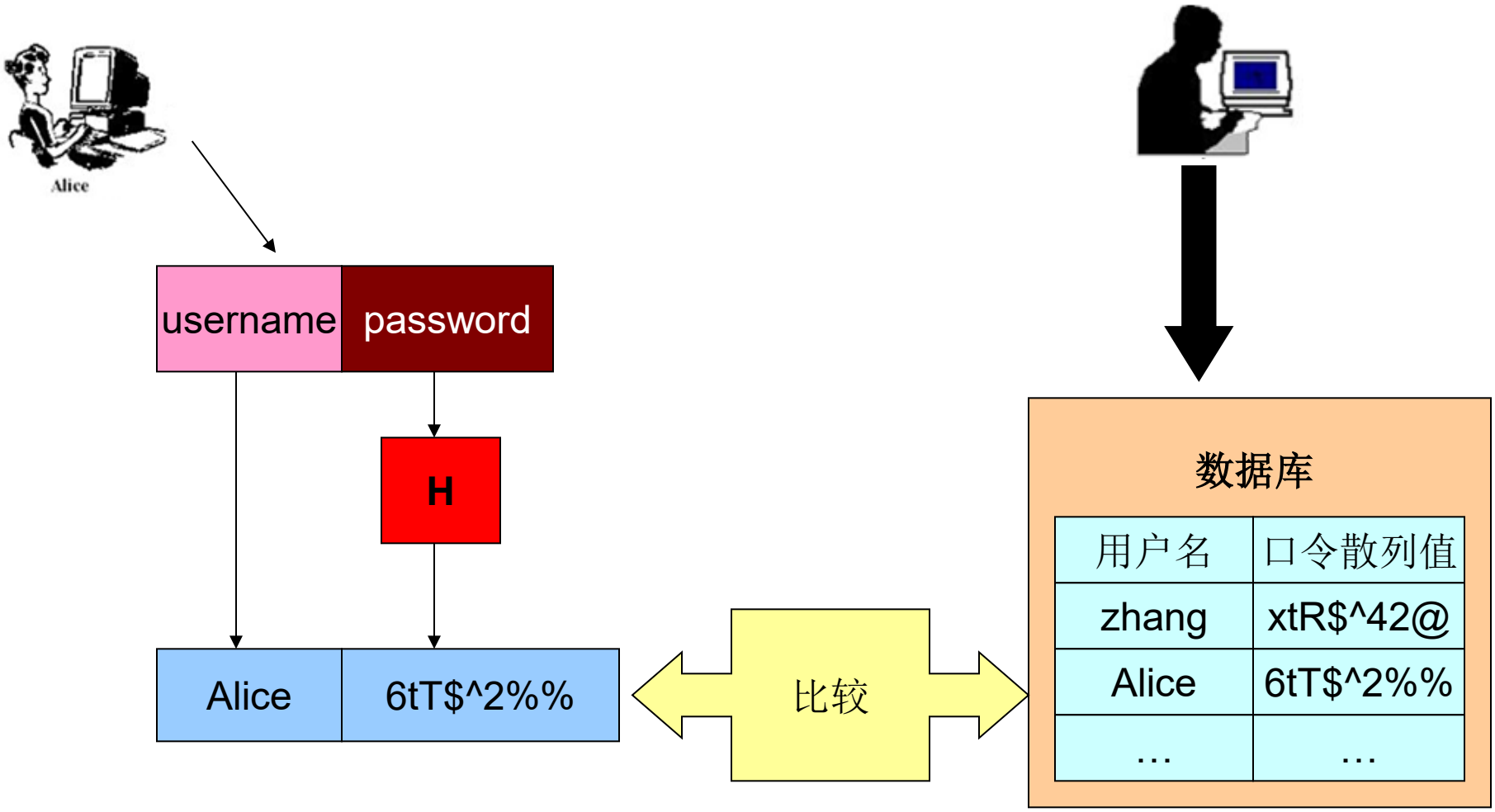
  风险很大！！！
- 常用解决方法
  - Needham口令认证协议(利用Hash函数存储口令)
  - 一次性口令机制

  ……

Needham口令认证协议

- 原理
  - 利用Hash函数存储口令，防范攻击者偷取数据库后得到口令
- 简单有效，广泛应用于各种系统中
  - UNIX：使用DES代替Hash函数
  - Discuz!

  ……



- 缺点
  - 无法防范攻击者在线窃听口令
  - 无法防范离线字典攻击

一次性口令机制

- 为防范在线窃听口令，可使用一次性口令机制
  - 每次认证使用不同的口令
- 要求用户和系统共享很多口令
- 但管理和保护大量的口令在技术上很困难
- 为克服这一缺点，Lamport提出利用多次Hash的方法实现一次性口令机制

Lamport的一次性口令机制

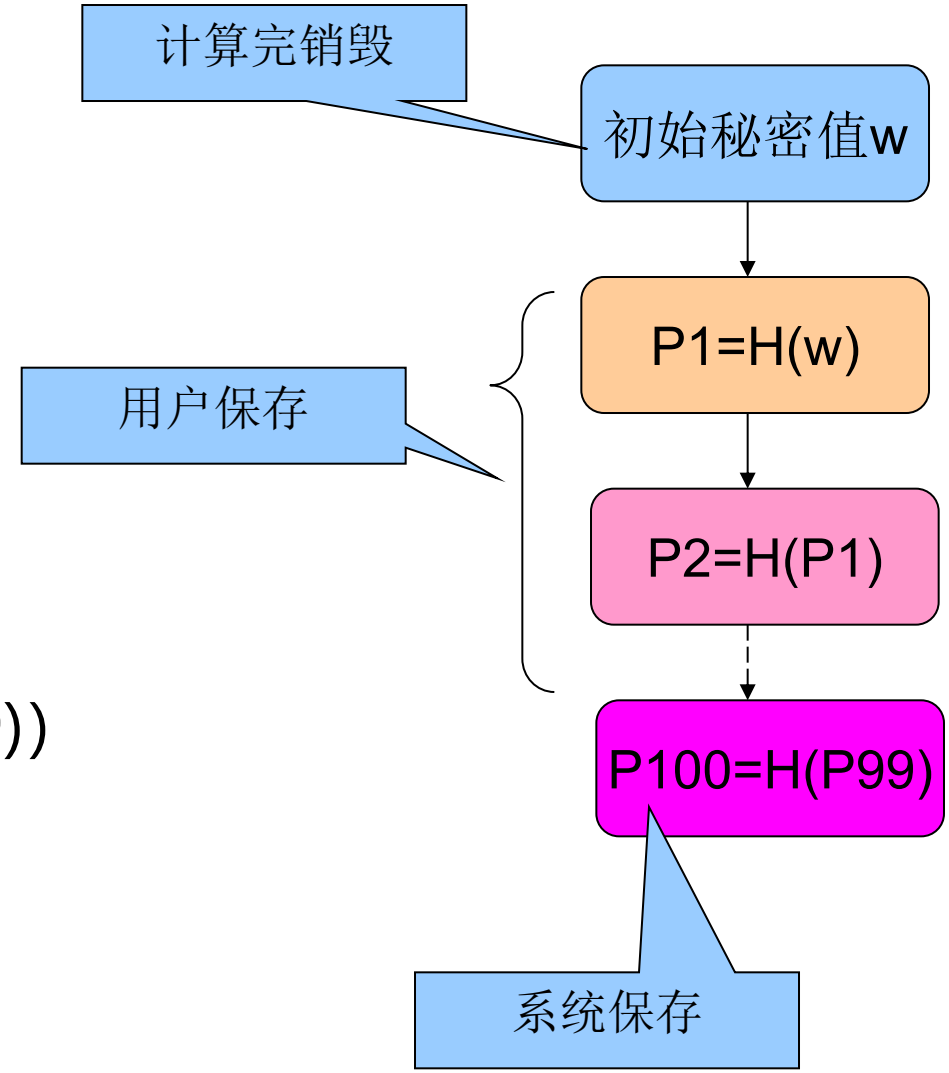
- 方法举例
  - 系统保存P100
  - 用户保存P99、P98、P97……
  - 认证过程

① 用户提交P99

② 系统计算

```
if (P100 == Hash(P99))
{ 验证通过;
  保存P99;
 }
```

③ 用户丢弃P99



- Lamport方案的缺点
  - 必须保持同步
  - 但可能因为不可靠信道或死机出现丢失同步的情况(有可能是攻击者的破坏所致)

安全传输口令：利用SSL建立安全信道

- 在WEB应用中，可以利用SSL建立安全信道，再进行基于口令的认证
- 方法
  - 先使用HTTPS协议，与服务器建立安全连接(服务器必须支持HTTPS)
  - 再将用户名和口令传送到服务器进行认证
- 应用方便，安全保护对用户透明
  - 比如：用浏览器登录电子邮件服务器



- 点击“登录”，浏览器地址栏会闪过一个以“https”开头的地址，这说明正用SSL安全连接传送用户名和口令

EKE协议

- 加密的密钥交换(EKE)协议
  - Bellovin和Merritt提出的极具吸引力的协议
  - 可以抵抗在线口令窃听、离线字典攻击





Alice, $E_{PWD}(pk)$

$E_{PWD}(E_{pk}(K))$

E：对称加密
E：公钥加密

挑

EKE的独创性在于前两轮：

- 第①轮中，pk是随机选择的，是一次性随机串。
- 第②轮中，利用双重加密包含另一个一次性随机串：会话密钥K
- K和pk实际起到salt的作用，通过加密将PWD隐藏起来
- 挑战-应答机制中使用的随机数，同样很好的隐藏了K
- 注意：如果pk不是一次性的，存在安全问题

- 对EKE可能的攻击有以下几种
  - 分析窃听到的消息，意图获得PWD
    - PWD和协议中传输的消息是统计独立的
    - 意味着PWD对窃听者的安全是一种信息论意义上的，故而攻击者无法进行离线的口令攻击
  - 直接猜测PWD
    - 这种攻击无法防止，但通常是无效的
  - 主动攻击
    - 攻击者将会以很大概率被参与者识破

2. Have sth

- 存储卡：在磁卡上保存用户信息；与PIN配合使用
- 智能卡：由一个或多个集成电路芯片组成，包含CPU和存储器，具有数据存储能力和逻辑处理功能

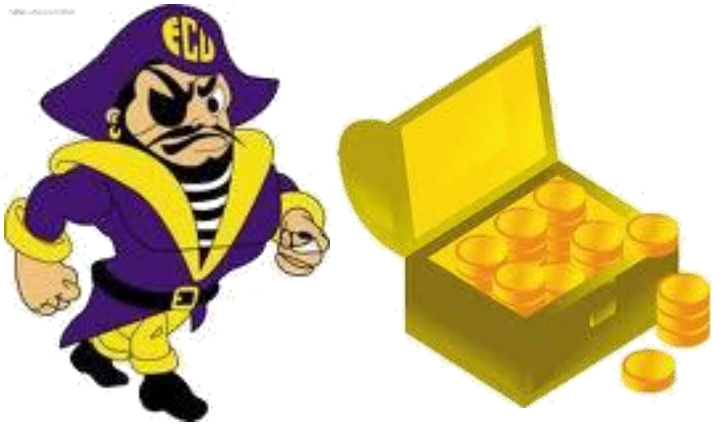
3. Be sth

- 生物特征
  - 指纹、掌纹、虹膜、视网膜、手形、面部特征、声音特征
- 动态特征
  - 签名特征
  - 键盘特征

秘密共享

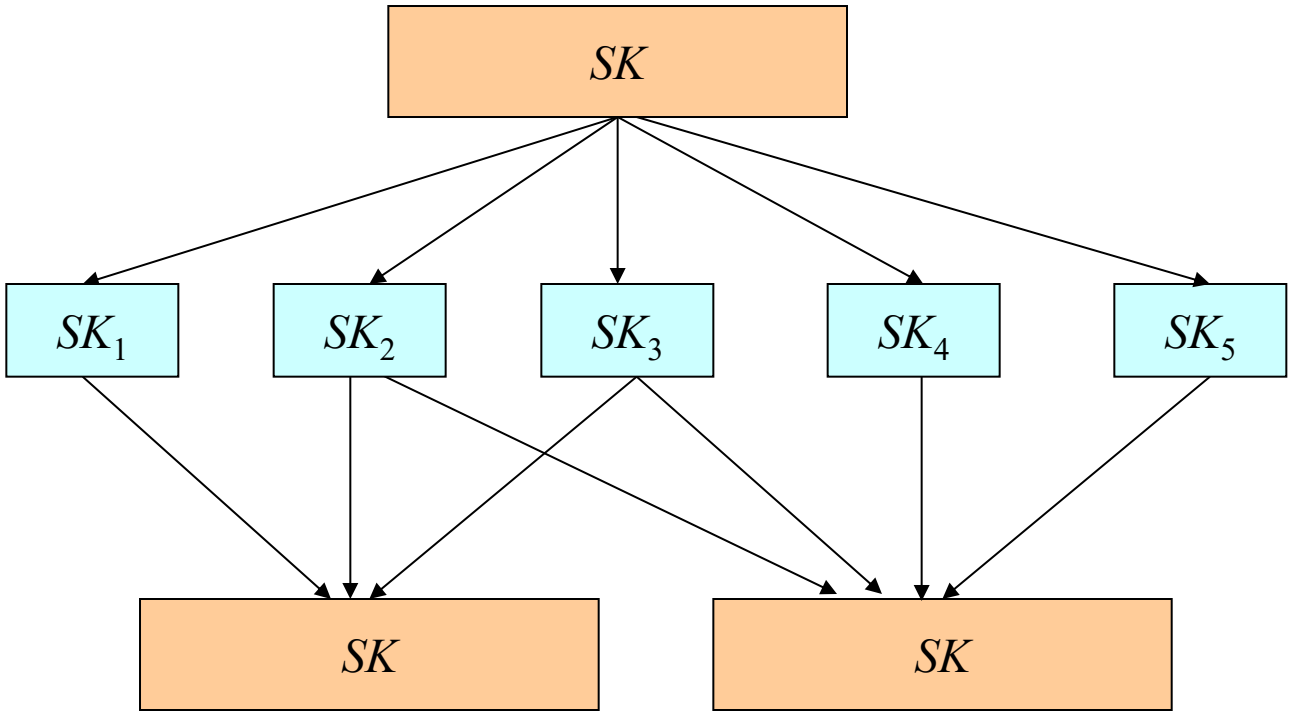
- 宝藏问题
  - 海盗们把宝藏藏在一个安全的地方，只有用地图才能找到。但地图如何分配呢?
    - 各拿一份地图肯定不行，因为他们彼此不信任
    - 各拿地图的一部分也不行，因为有人丢失他那份的话，就无法复原地图
- 如何解决?

  —— 秘密共享技术



- 秘密共享是什么
  - 将秘密分割存储的密码技术
- 秘密共享的目的
  - 防止秘密过于集中，以达到分散风险和容忍入侵的目的

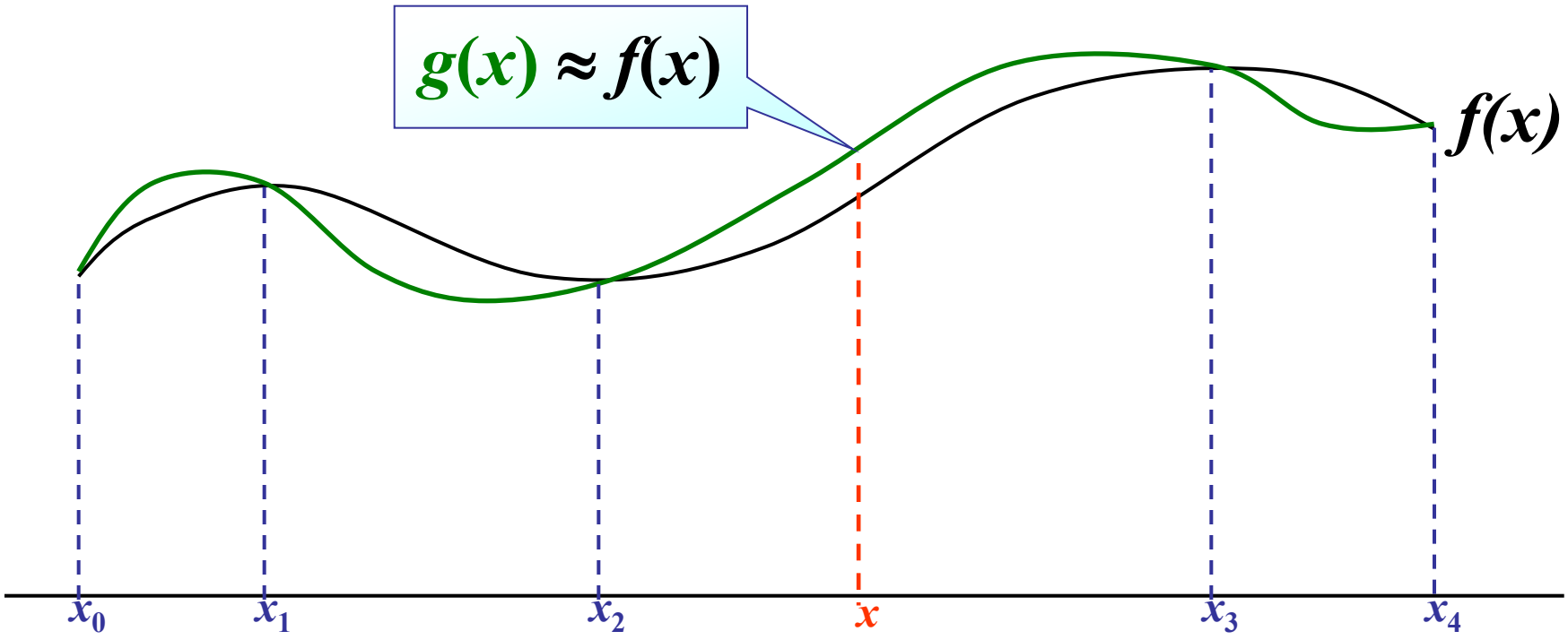
- 最常用的秘密共享方案——门限方案
  - 1979年，由Shamir提出
- (m,n)门限方案
  - 将秘密SK拆成n份，任意m(m≤n)份或更多份都可以恢复SK，任何少于m份都不能得到关于SK的任何有用信息
  - 其中，每一份都称为一个shadow



(3,5)门限方案

Shamir的门限方案

- Shamir提出了一个基于拉格朗日插值多项式的门限方案
- 插值的概念
  - 由于函数f(x)的多样性和复杂性，我们可能只知道函数曲线上的一些离散点；或者f(x)过于复杂而难以运算。
  - 这时，需要利用函数g(x)来近似逼近f(x)。自然地，希望g(x)通过所有的给定的离散点



$g(x)$通过所有给定离散点,逼近$f(x)$,是对$f(x)$的近似表示

拉格朗日插值多项式

- 给定有限域F_p中互不相同的整数$x_1,\ldots,x_{n+1}$,和任意不全为零的整数$k_1,\ldots,k_{n+1}$，公式

$$f(x)=\sum_{i=1}^{n+1}\frac{k_i(x-x_1)\cdots(x-x_{i-1})(x-x_{i+1})\cdots(x-x_{n+1})}{(x_i-x_1)\cdots(x_i-x_{i-1})(x_i-x_{i+1})\cdots(x_i-x_{n+1})}\bmod p$$

满足$f(x_i)=k_i$，$i=1,\ldots,n+1$

f(x)是一个n次多项式，称为拉格朗日插值多项式

- Shamir的门限方案

①分割秘密

  - 设待共享秘密为K,令$a_0 = K$
  - 随机产生m-1次多项式

    $$f(x) = (a_{m-1}x^{m-1} + \ldots + a_1x + a_0) \bmod p$$

  - 依次计算 $k_i = f(x_i)$，$i = 1, \ldots, n$
    - 易知K=f(0),且每一对(x_i,k_i)都是f(x)函数曲线上的一个点
  - k_i是每个参与者的shadow,必须保密(x_i无需保密)

② 重构f(x)

给定$k_1,k_2,\ldots,k_m$共m个shadow，对应的分别是$x_1,x_2,\ldots,x_m$。f(x)可由拉格朗日插值多项式给出：

$$f(x)=\sum_{i=1}^{m}\frac{k_i(x-x_1)\cdots(x-x_{i-1})(x-x_{i+1})\cdots(x-x_m)}{(x_i-x_1)\cdots(x_i-x_{i-1})(x_i-x_{i+1})\cdots(x_i-x_m)}\bmod p$$

③ 恢复秘密K=f(0)

- 安全性原理
  - 对于m-1次多项式，只需给出m个点就可以唯一地重构，少于m个shadow则不能。由此保证K可从m个shadow中获得，而少于m个办不到

- **举例：**(3,5)的门限方案
  - 设 m = 3，n = 5，p = 17，K = 13，

① 分割秘密

  - 构造随机多项式 $f(x) = (2x^2 + 10x + 13) \bmod 17$
  - $k_1 = f(1) = (2+10+13) \bmod 17 = 8$
  - $k_2 = f(2) = (8+20+13) \bmod 17 = 7$
  - $k_3 = f(3) = (18+30+13) \bmod 17 = 10$
  - $k_4 = f(4) = (32+40+13) \bmod 17 = 0$
  - $k_5 = f(5) = (50+50+13) \bmod 17 = 11$
  - $k_1,\ldots,k_5$便是shadow, 每个用户一人一个

② 重构f(x)。给定$k_1=8, k_3=10, k_5=11$,
重构如下:

$$
\begin{aligned}
f(x) &= 8\frac{(x-3)(x-5)}{(1-3)(1-5)} + 10\frac{(x-1)(x-5)}{(3-1)(3-5)} + 11\frac{(x-1)(x-3)}{(5-1)(5-3)} \\
&= 8\frac{(x-3)(x-5)}{8} + 10\frac{(x-1)(x-5)}{-4} + 11\frac{(x-1)(x-3)}{8} \\
&= (x-3)(x-5) + 10\times 4(x-1)(x-5) + 11\times 15(x-1)(x-3) \\
&= (x-3)(x-5) + 6(x-1)(x-5) + 12(x-1)(x-3) \\
&= 19x^2 - 92x + 81 \\
&= 2x^2 - 7x + 13 \\
&= 2x^2 + 10x + 13 (\mathrm{mod} 17)
\end{aligned}
$$

③ 恢复K=f(0)=13

门限方案的图形化——视觉密码

- 由Shamir等提出
  - 将写有秘密信息的图片拆分成n张,至少m张(m≤n)才能恢复原来的图片
- 优点
  - 安全性高：相当于“一次一密”
  - 计算开销低：恢复原图片时，用幻灯机即可，无需计算机参与







写有秘密信息的原图片

天王盖地虎
宝塔镇河妖

(2,3)的视觉密码方案效果

4.7 SSL协议

4.7 SSL协议



SSL（Secure Socket Layer，安全套接字层）协议最初是由Netscape Communication公司设计开发的安全认证协议，也是国际上最早应用于电子商务的一种网络安全协议。SSL刚开始制定时是面向Web应用的安全解决方案，目前SSL已经成为Web上最为广泛的信息安全协议之一，大部分Web服务器和浏览器都内置了该协议，比较容易应用。

4.7.1 SSL概述

在Internet体系结构中，套接字层（Socket Layer）位于应用层和传输层之间。而套接字（Socket）的概念起源于20世纪80年代的Unix操作系统，它定义了客户机与服务器进行之间的通信方式。这种通信方式既可以是面向连接的（如使用TCP协议），也可以是面向非连接的（如使用UDP协议）。Socket可以看成是通信中的一个端点，其中客户机上的应用程序利用一个Socket地址来呼叫服务器上的Socket，一旦服务器上的Socket与客户机上的Socket建立了连接，这两台计算机之间就可以交换数据。

SSL是一种点对点之间构造的安全通道中传输数据的协议，它运行在传输层之上、应用层之下，是一种综合利用对称密钥和公开密钥技术进行安全通信的工业标准。在通信过程中，允许一个支持SSL协议的服务器在支持SSL协议的客户端使协议本身获得信任，使客户端得到服务器的信任，从而在两台机器间建立一个可靠的传输连接。SSL协议主要提供了3个方面的安全服务。

4.7 SSL协议

（1）认证。利用数字证书技术和可信任的第三方认证机构，为客户机和服务器之间的通信提供身份认证功能，以便于彼此之间进行身份识别。为了验证证书持有者的合法性，防止出现用户名欺骗，SSL要求证书持有者在进行握手时相互交换数字证书，通过验证证书来保证对方的合法性。

（2）机密性。在SSL客户机和服务器之间传输的所有数据都经过了加密处理，以防止非法用户进行窃取、篡改和冒充。

（3）完整性。SSL利用加密算法和Hash函数来保证客户机和服务器之间传输的数据的完整性。

如图4-10所示，SSL协议分为上下两部分：上层为SSL握手协议，下层为SSL记录协议。其中SSL握手协议主要用来建立客户机与服务器之间的连接，并协商密钥；而SSL记录协议则定义了数据的传输格式。由此可以看出，SSL协议是建立在可靠的传输层协议（如TCP）之上的，与应用层协议无关，它在应用层协议通信之前就已经完成加密算法、通信密钥的协商以及服务器认证工作，高层的应用层协议（如HTTP、FTP、Telnet等）可以透明地建立在SSL协议之上，应用层协议所传送的数据都会被加密，从而保证通信的机密性。

4.7 SSL协议

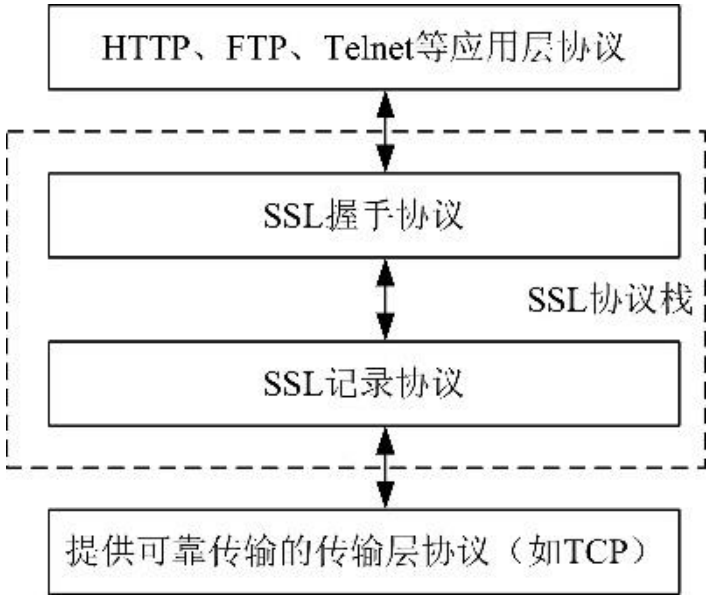


图4-10 SSL协议栈的组成

4.7.2 SSL握手协议

SSL握手协议提供了客户机与服务器之间的相互认证，协商加密算法，用于保护在SSL记录中发送的加密密钥。握手协议在任何应用程序的数据传输之前进行。如图4-11所示，SSL握手协议的一次握手操作包含了以下几个过程：

（1）通信的初始化阶段。客户机向服务器发送一个会话消息（Client Hello），服务器对该会话消息给予应答（Server Hello）。这一过程主要用于协商以下的信息：协议版本、加密算法、会话的ID、压缩方法和一个初始随机数。其中，初始随机数是客户机与服务器之间对每个连接选择的字节序列。

（2）如果客户机需要服务器的认证，则服务器开始发送它的数字认证证书，以证明其身份，包括：证书消息（Certificate）、服务器密钥交换消息（Sever Key Exchange）和证书请求消息（Certificate Request）。

（3）服务器发送一个服务器完成消息（Sever Hello Done），向客户机表明服务器的应答以及提供的证书等消息已结束。

（4）客户机在接收到服务器的服务器完成消息（Sever Hello Done）后，如果收到了服务器发送的证书请求消息（Certificate Request），即服务器需要对客户机进行认证，则客户机将向服务器发送证书消息（Certificate）。也可以不发送证书消息；客户机发送自己的密钥交换消息（Client Key Exchange）给服务器，发送之前需要用服务器公开密钥进行加密；如果服务器需要对客户机进行认证同时客户机也接受了此请求，即客户机已经向服务器发送了证书消息（Certificate），则客户机首先利用自己的私钥对已发送的证书消息（Certificate）进行数字签名，然后再发送给服务器，该签名后的消息为证书验证消息（Certificate Verify），以证明自己是证书的真正持有者。

（5） 客户机和服务器分别发送修改密码格式消息（ChangeCipherSpec），完成密钥交换；客户端和服务器相互发送完成消息（finished），完成认证过程。

4.7 SSL协议

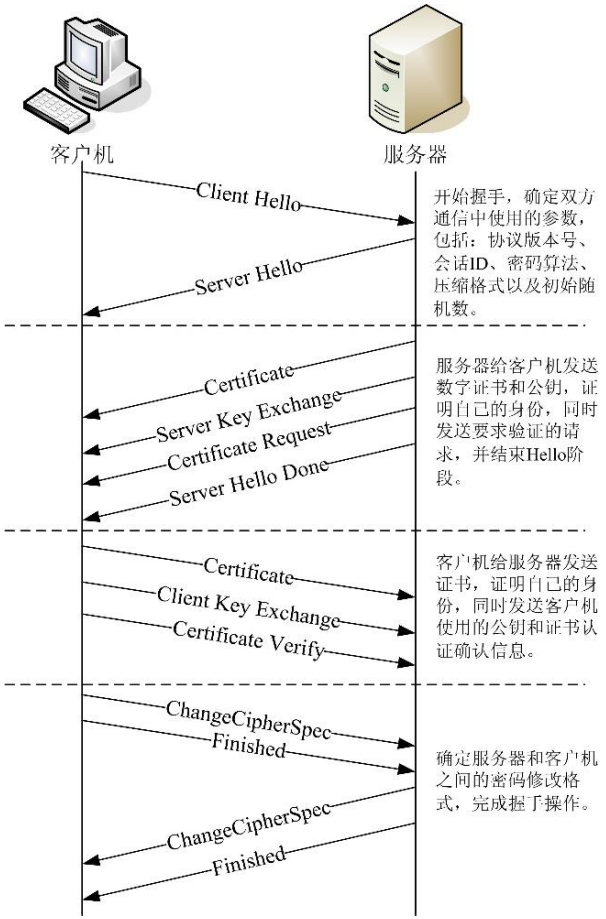


图4-11 SSL握手协议的操作过程

在SSL握手协议操作的任意步骤中，如果协商结果不符合某一方的要求，通信的任意一方都可以终止握手进程。在完成握手后，客户机和服务器即可以开始交换应用层数据。传输数据时，用对称密码进行加密，对称密钥用非对称算法加密，再把加密消息与被加密的密钥数据绑定后进行传输。接收的过程与发送过程正好相反，首先用接收者的私钥打开对称密钥的加密包，再用得到的对称密钥对消息进行解密，得到明文数据。

4.7.3 SSL记录协议

SSL记录协议建立在可靠的传输层协议（如TCP）之上，为高层协议（如HTTP、FTP等）提供数据封装、压缩、加密等基本功能的支持。如图4-12所示，SSL记录协议的操作过程如下：

（1）数据分块。将应用层的数据分解为大小为16×1024B（其中B表示字节）或更小的数据块。

（2）数据压缩（可选）。压缩必须是无损的，压缩后的数据长度未必比压缩前的数据短，但增加的内容长度不能超过1024B。在SSLv3中，没有说明采用哪一种压缩方式，所以系统默认为空，即不进行压缩。

（3）计算并添加MAC（消息认证码）。对压缩后的数据，采用单向Hash函数计算MAC，并添加到压缩后的数据后面。

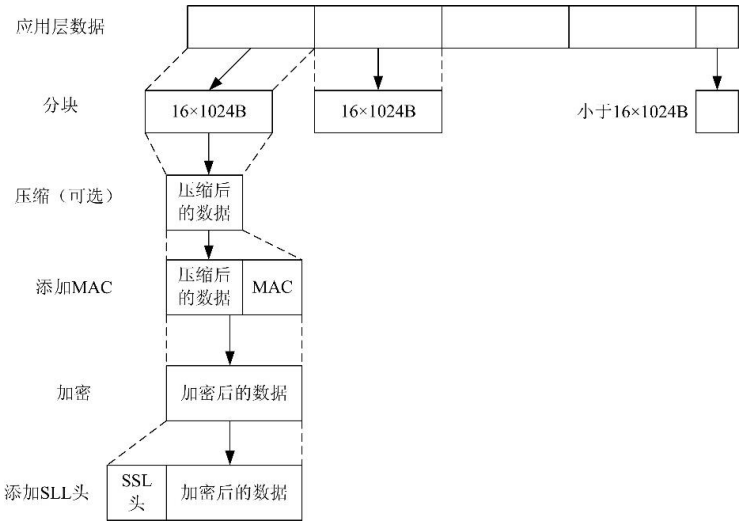


图4-12 SSL记录协议的操作过程

（4）加密。对压缩数据和MAC进行加密。加密对数据长度的增加不能超过1024B。允许采用的加密算法及相应的密钥长度如表4-1所示。

表4-1 SSL协议中使用的加密算法及其密钥长度

分组密钥		流密钥	
算法	密钥长度(bit)	算法	密钥长度(bit)
IDEA	128	RC4-40	40
RC2-40	40	RC4-128	128
DES-40	40		
3DES	168		
Fortezza	80		
DES	56		

（5）添加SSL记录头。在加密后的数据头部添加一个SSL记录协议头，使数据形式一个完整的SSL记录。该SSL记录头由以下字段组成（如图4-13所示）：



图4-13 SSL记录协议字段

①内容类型（8bit）。封装的高层协议类型。

②主版本号（8bit）。使用的SSL主版本号，如果采用SSL v3协议，该字段值为3。

③次版本号（8bit）。使用的SSL次版本号，如果采用SSL v3协议，该字段值为0。

④压缩长度（16bit）。以字节为单位的数据长度。有两种情况：如果采用了压缩，该字段值为压缩后的数据块长度；如果没有压缩，则该字段为明文数据块的长度。但两种长度都应该包括MAC。

4.7 SSL协议

SSL是一个通信协议。为了实现安全性，SSL的协议描述比较复杂，具有较完备的握手过程。这也决定了SSL不是一个轻量级的网络协议。另外，SSL还涉及大量的计算密集型算法：非对称加密算法，对称加密算法和数据摘要算法。

IETF将SSL进行了标准化，即RFC 2246，并将其称为TLS（Transport Layer Security）。从技术上讲，TLSv1.0与SSLv3.0的差别非常小。有关TLS的详细介绍，读者可参阅相关的技术文档。

5.1.1 TCP/IP体系的分层特点

ARPAnet是应用最早的计算机网络类型之一，现代计算机网络的许多概念源自ARPAnet。ARPAnet是由美国国防部资助的一个研究性网络，当初它通过租用的电话线将几百所大学和政府部门的计算机设备连接起来，要求通过一种灵活的网络体系结构实现不同设备、不同网络的互联和互通。后来卫星通信系统和无线电通信系统得到发展并应用到ARPAnet中，这时，ARPAnet最初开发的网络协议使用在通信可靠性较差的通信子网中时出现了问题，这就导致了TCP/IP协议的出现。

TCP/IP开始仅仅是两个协议：TCP（Transfer Control Protocol，传输控制协议）和IP（Internet Protocol，网际协议）。后来，TCP/IP演变为一种体系结构，即TCP/IP参考模型。现在的TCP/IP已成为一个工业标准的协议集，它最早应用于ARPAnet。因为当时的ARPAnet要求在任何条件下甚至是战争中都可以正常运行，这就决定了运行TCP/IP的网络具有很好的兼容性，并可以使用铜缆、光纤、微波以及通信卫星等多种链路。同时，在TCP/IP网络中所有的数据都以分组的形式传输。

5.1 TCP/IP体系概述

与OSI参考模型不同，TCP/IP模型由应用层（Application Layer）、传输层（Transport Layer）、网际层（Internet Layer，也称为Internet层）和网络接口层（Network Interface Layer）四部分组成，如图5-1所示。这四层大致对应OSI参考模型的七层。但与OSI模型不同的是：TCP/IP协议栈更加侧重于互联设备间的数据传送，而不是严格的功能层次的划分。

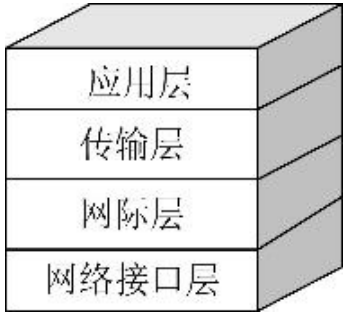


图5-1 TCP/IP体系

为了便于对TCP/IP体系的理解，可以将TCP/IP体系分为协议层和网络层两层，如图5-2所示。其中，协议层包括TCP/IP体系的上面两层（应用层和传输层），具体定义了有关网络通信协议的类型；而网络层包括TCP/IP模型的下面两层（网际层和网络接口层），具体定义了网络的类型（如局域网和广域网）和设备之间的路径选择。

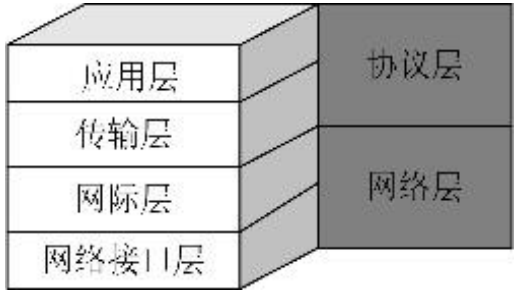


图5-2 将TCP/IP体系划分为协议层和网络层

5.1 TCP/IP体系概述

TCP/IP是一个协议簇或协议栈，它是由多个子协议组成的集合。图5-3列出了TCP/IP体系中包括的一些主要协议以及与TCP/IP体系的对应关系。理解这个图的结构（尤其是每一层对应的协议）对于后面的学习非常重要。

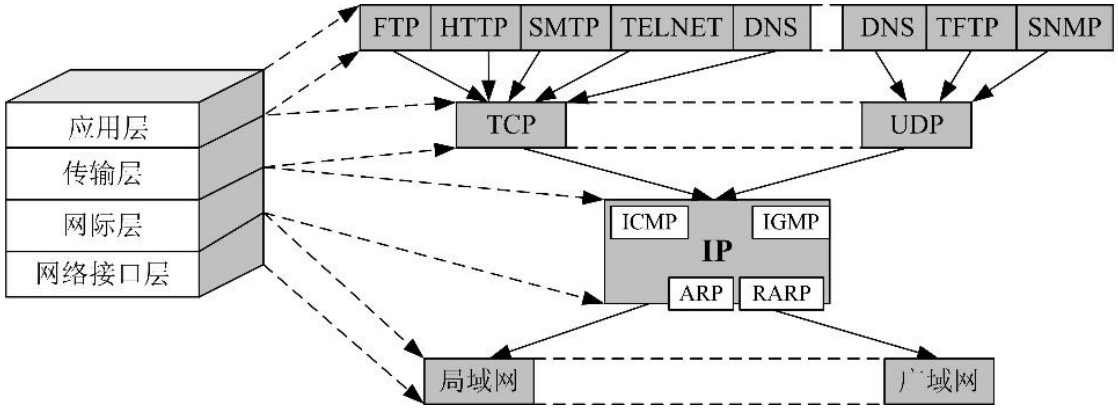


图5-3 TCP/IP体系中的主要协议及与各层的对应关系

5.1.2 TCP/IP各层的主要功能

TCP/IP体系也称为TCP/IP参考模型，该模型从下到上共分为网络接口层、网际层、传输层和应用层，共4个子层。各层的主要功能如下。

- 1. 网络接口层

在TCP/IP参考模型中，网络接口层属于最低的一层，它负责通过网络发送和接收分组。由于TCP/IP参考模型并没有明确规定在网络接口层应该使用哪些设备、网络和协议，这就带来了以下的好处：一是对于网际层及以上各层来说网络接口层透明的，网际层及以上各层在功能实现过程中不需要考虑网络接口层使用的是什么类型的网络、设备或协议；二是有利于TCP/IP网络的发展。由于在TCP/IP参考模型中，网络接口层的定义是空白的，所以已有的各种类型的物理网络都可以作为TCP/IP的网络接口层存在，如目前已经使用的电路交换机、分组交换网（如X.25、帧中继等）和局域网（如以太网、令牌网、FDDI等）。

- 2. 网际层

网际层也称为“互联网络层”，它相当于OSI参考模型网络层的无连接网络服务。网际层的任务是：允许位于同一网络或不同网络中的两台主机之间以分组的形式进行通信。更具体地讲，网际层提供了以下的服务功能：一是处理从传输层接收下来的报文段发送请求，然后将报文段封装到IP数据报中，并根据源主机和目的主机的IP地址来填充报头，然后根据目的主机的IP地址选择一条链路将封装后的IP数据报发送出去；二是处理从网络接口层接收到的由其他主机发送过来的数据报，根据数据报中的目的地址决定这个数据报是发送给本主机的还是要发送给其他主机的。如果是发送给本主机的，则在去掉报头信息后提交给传输层；如果是发送给其他主机的，则根据数据报的目的IP地址选择一条链路进行转发；三是当本主机连接两个不同的网络（称为“子网”）时，对接收到的数据报进行路由选择和转发，并进行流量控制和阻塞管理。

TCP/IP参考模型中网际层的协议是唯一的，即IP协议。IP协议是一个面向非连接的、不可靠的数据报传输服务协议，所以网际层的IP协议提供了一种“尽力而为”（best-effort）的服务。IP协议的协议数据单元（PDU）称为分组，所以将TCP/IP网络也称为分组交换网络。

- 3. 传输层

在TCP/IP参考模型中，传输层位于网际层与应用层之间，其设计目标是：允许在源和目的主机的对等体之间进行会话，负责会话对等体的应用进程之间的通信。TCP/IP参考模型的传输层功能类似于OSI参考模型传输层的功能。

在TCP/IP参考模型的传输层中定义了两个端到端的传输协议：传输控制协议（Transfer Control Protocol，TCP）和用户数据报协议（User Datagram Protocol，UDP）。

其中，TCP协议是一个可靠的、面向连接的协议，它实现了从一台主机发送出去的字节流（byte stream）无差错地传输到目的主机。在这一过程中，发送主机的传输层首先把从应用层接收到的数据流划分成为多个小的字节段（byte segment），并对每一个字节段进行编号。然后，每一个字节段可以通过不同的路径到达目的主机，如果某一个字节段在传输过程中出错或丢失，则要求发送端进行重传。当目的主机接收到字节段后，根据其编号重组为原来的字节流，并提交给应用层进行处理。TCP协议还负责处理流量控制，当发送端的发送速率与接收端的接收速度不匹配时（一般是发送速率大于接收速率），协调收、发双方的速率，以确保字节段的可靠传输。

UDP是一个不可靠的、面向非连接的传输层协议，主要用于不要求分组顺序到达的传输中，分组的先后顺序检查与排列由应用层的应用程序完成。同时，UDP主要应用于“快速交付比精确交付更加重要”的应用，如语音传输、视频传输等。

- 4. 应用层

应用层属于TCP/IP参考模型的最高层。应用层主要包括根据应用需要开发的一些高层协议，如telnet、FTP、SMTP、DNS、SNMP、HTTP等。而且，随着网络应用的不断发展，新的应用层协议还会不断出现。

需要说明的是：在OSI参考模型中，在传输层之上还定义了会话层和表示层，而在TCP/IP参考模型中却没有这两层。这是因为在当初设计时，研究人员认为OSI参考模型的高层划分过于复杂，而且每一层的功能设计并不明确或过于单一，这样在设计TCP/IP参考模型时就去掉了这两层。从目前的应用来看，TCP/IP参考模型当初的这种设计是正确的。

5.5 TCP安全

- 1. 连接建立

TCP是面向连接的。在面向连接的环境中，开始传输数据之前，在两个终端之间必须先建立一个连接。建立连接的过程可以确保通信双方在发送用户数据之前已经准备好了传送和接收数据。对于一个要建立的连接，通信双方必须用彼此的初始化序列号SEQ和来自对方成功传输确认的确认序号ACK来同步。（ACK号指明希望收到的下一个字节的编号）习惯上将同步信号写为SYN，应答信号写为ACK。整个同步的过程称为三次握手，图5-22说明了这个过程，具体如下：

第1步，主机A发送SYN给主机B：我的初始化序列号seq是X。主机A通过向主机B发送SYS报文段，实现从主机A到主机B的序列号的同步，即确定seq中的X；

第2步，主机B发送SYN、ACK给主机A：我的初始化序列号seq是Y（如果主机B同意与主机A建立连接时），确认序号ack是X＋1（等待接收第X＋1号字节的数据流）。主机B向主机A发送SYN报文段的目的是实现从主机B到主机A的序列号的同步，即确定seq中的Y。主机B向主机A发送确认信息ack=X+1，这是因为在TCP连接过程中，把正确接收到的最后一个序列号再加1的和，作为现在的确认号；

第3步，主机A发送ACK给主机B：我的确认序号ack是Y＋1。

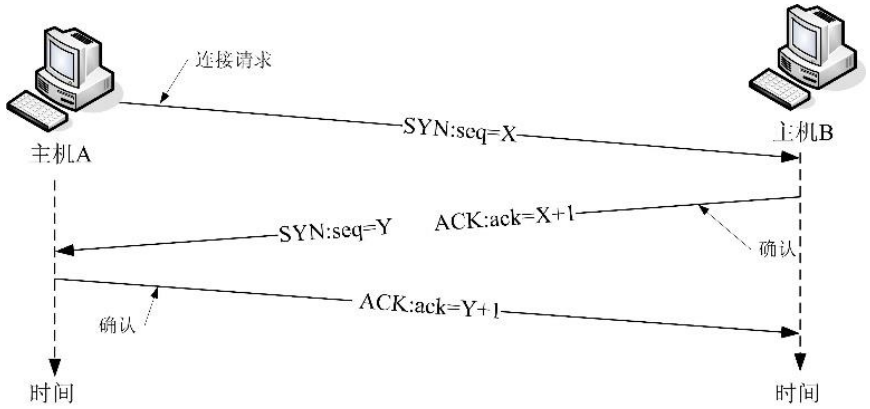


图5-22 TCP连接建立时的三次握手

通过以上三个步骤（**三次握手**），TCP连接建立，开始传输数据。

- 2. 数据传输

在连接建立后，TCP将以全双工方式传送数据，在同一时间主机A与主机B之间可以同时进行TCP报文段的传输，并对接收到的TCP报文段进行确认。如图5-23所示，当通过三次握手建立了主机A与主机B之间的TCP连接后，现在假设主机A要向主机B发送1800字节的数据，主机B要向主机A发送1500字节的数据。

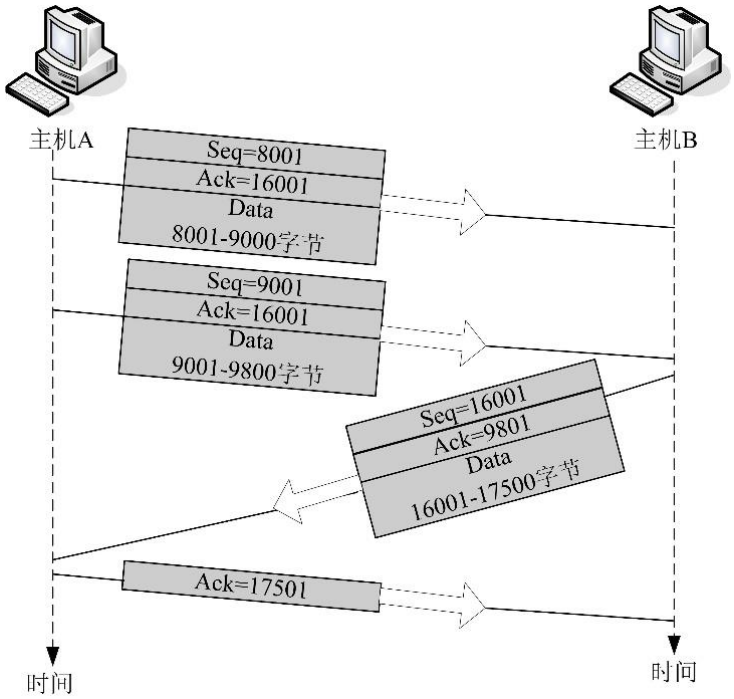


图5-23 TCP报文段的传输过程

5.5 TCP安全

在TCP报文段的首部信息中有一个序号字段和一个确认序号字段，在数据传输过程中要用到这两个字段的功能特性。TCP把一个连接中发送的所有数据都要按字节进行编号，而且在两个方向上的编号是互不影响的。当主机要发送数据时，TCP从应用进程中接收数据，并将其存储在发送缓存中，然后按字节进行编号，这也是为什么将TCP报文称为字节流的原因。编号并不一定从0开始，而是在0~（2^{32}-1）之间取一个随机数作为第一个字节的编号。例如，在本例中主机A正好取了8001作为第一个字节的编号，由于数据总长度为1800，所以字节的编号从8001~9801。同理，主机B的字节编号假设为16001~17500。

当对字节进行了编号后，TCP就给每一个报文段分配一个序号，该序号即这个报文段中的第一个字节的编号。在本例中，主机A发送的数据被分成两个报文段（每1000字节为一段），由于第一个字节的编号为8001，所以第一个报文段的序号seq=8001。第二个报文段只有800字节，第二个报文段中的第一个字节的编号为9001，所以第二个报文段的序号seq=9001。主机B正好以1500字节为一个报文段，所以主机B发送给主机A的数据正好存放在一个报文段中，该报文段的序号seq=16001。

每一个报文段可以选择不同的路径在网络中进行传输，在接收端需要对接收到的报文段时行确认。前文已经提到，在TCP中确认序号被定义为下一个希望接收到的字节的编号，所以在本例中当主机B成功接收到主机A发送过来的第二个报文段时，由于该报文段中的字节编号为9001~9800，所以主机B发送给主机A的确认序号ack=9801。

另外，在本例中还有三个问题需要进行说明：一是确认信息由发送信息同时捎带。每一个报文段中的ack序号就是对已成功接收到的报文段的确认；二是为了提高TCP的传输效率，主机并不会对接收到的每一个报文段报送确认信息，而是当同时接收到多个报文段后再发送确认信息，所以在本例中主机B只对主机A发送了一个确认信息；三是主机A在最后一次只发送了一个Ack=17501的确认信息，表示已成功接收到了主机B发送过来的报文段。这是因为主机A在本次TCP连接中已经再没有数据进行发送。

- 3. 连接终止

对于一个已经建立的连接，TCP使用改进的三次握手来释放连接（使用一个带有FIN附加标记的报文段，即在TCP报文段首部中将FIN字段的值置为1）。TCP关闭连

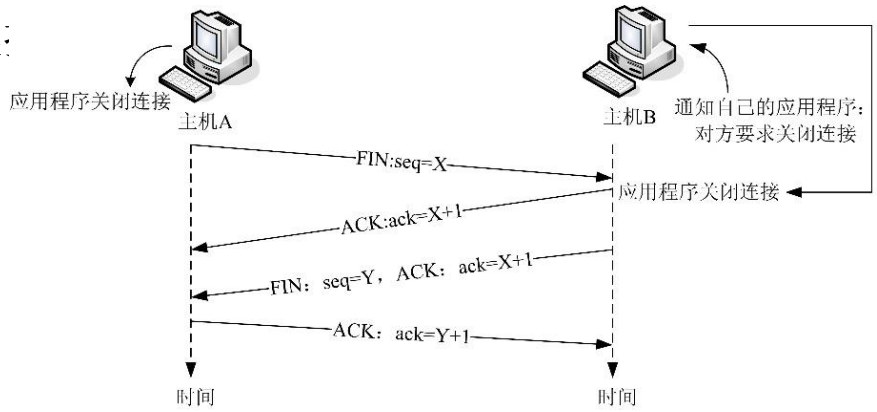


图5-24 TCP使用改进的三次握手来释放连接

第1步，当主机A的应用程序通知TCP数据已经发送完毕时，TCP向主机B发送一个带有FIN附加标记的报文段（FIN表示英文finish）；

第2步，主机B收到这个FIN报文段之后，并不立即用FIN报文段回复主机A，而是先向主机A发送一个确认序号ACK，同时通知自己相应的应用程序：对方要求关闭连接（先发送ACK的目的是为了防止在这段时间内，对方重传FIN报文段）；

第3步，主机B的应用程序告诉TCP：我要彻底的关闭连接，TCP向主机A送一个FIN报文段；

第4步，主机A收到这个FIN报文段后，向主机B发送一个ACK报文段，表示连接彻底释放。

5.5.2 TCP的安全问题

在TCP/IP网络中，如果两台主机之间要实现可靠的数据传输，首先要通过三次握手方式建立主机之间的TCP连接，但在TCP连接过程中很容易出现一个严重的安全问题：TCP SYN泛洪攻击。

按照TCP连接建立时三次握手的协议约定，当源主机A要建立与目的主机B之间的TCP连接时，源主机A首先发送一个用于同步的SYN报文段（第一次握手）。当目的主机B接收到这个报文段时，在正常情况下目的主机会打开连接端口，并给源主机A返回一个SYN+ACK的报文段（第二次握手）。同时，目的主机B将这个处于“半开放状态”的连接放在等待队列中，等待源主机A的ACK确认报文段（即等待第三次握手的实现）。这段等待时间一般为75s到25min。

5.5 TCP安全

TCP SYN泛洪攻击的工作过程如图5-25所示。如果在第一次握手过程中，源主机A发送给目的主机B的SYN报文段中的IP地址是伪造的，同时源主机A同时向目的主机B发送大量的SYN报文段。这时，对于目的主机B来说会正常接收这些SYN报文段，并发送SYN+ACK确认报文段。由于目的主机B接收到的SYN报文段中的IP地址都是伪造的，所以发送出去的SYN+ACK确认报文段全部得不到回复。在目的主机B的队列中存在大量的“半开放状态”的连接，最终将队列的存储空间填满，并因资源耗尽而瘫痪。

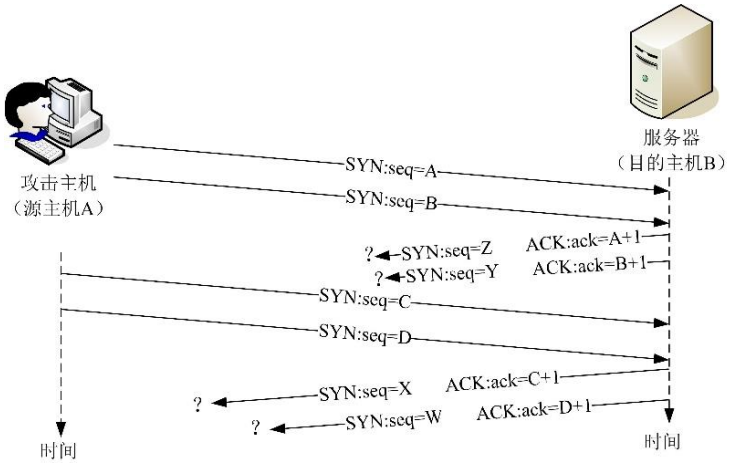


图5-25 TCP SYN泛洪攻击的工作过程

这种TCP SYN泛洪攻击属于一种典型的拒绝服务攻击（DOS攻击），即攻击者使用大量的服务请求耗尽了服务器的资源，使服务器无法处理正常的服务请求，最终造成系统的瘫痪。

5.5.3 操作系统中TCP SYN泛洪的防范

可以在Windows注册表内配置TCP/IP参数，以便保护服务器免遭网络级别的TCP SYN泛洪攻击。下面以Windows Server 2012为例进行介绍。

- 1. 启用TCP SYN攻击保护

启用TCP SYN泛洪攻击保护的命名值，位于注册表项的下面：HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services。

值名称： SynAttackProtect

建议值：2

有效值：0~2

说明：使TCP调整SYN+ACK的重传。配置此值后，在遇到TCP SYN攻击时，对连接超时的响应将更快速。在超过TcpMaxHalfOpen或TcpMaxHalfOpenRetried的值后，将触发SYN攻击保护。

- 2. 设置TCP SYN保护阈值

下列值确定触发SYN保护的阈值。这一部分中的所有注册表项和值都位于注册表项HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services 下。这些注册表项和值是：

值名称：TcpMaxPortsExhausted

建议值：5

有效值：0~65535

说明：指定触发TCP SYN泛洪攻击保护所必须超过的TCP连接请求数的阈值。

值名称：TcpMaxHalfOpen

建议的数值数据：500

有效值：100~65535

说明：在启用SynAttackProtect后，该值指定处于SYN_RCVD状态的TCP连接数的阈值。在超过SynAttackProtect后，将触发TCP SYN泛洪攻击保护。

值名称：TcpMaxHalfOpenRetried

建议的数值数据：400

有效值： 80~65535

说明：在启用SynAttackProtect后，该值指定处于至少已发送一次重传的SYN_RCVD状态中的TCP连接数的阈值。在超过SynAttackProtect后，将触发TCP SYN泛洪攻击保护。

- 3. 设置其他保护

这一部分中的所有注册表项和值都位于注册表项HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services 下。这些注册表项和值是：

值名称：TcpMaxConnectResponseRetransmissions

建议的数值数据：2

有效值：0~255

说明：控制在响应一次SYN请求之后、在取消重传尝试之前SYN+ACK的重传次数。

值名称：TcpMaxDataRetransmissions

建议的数值数据：2

有效值：0~65535

说明：指定在终止连接之前 TCP 重传一个数据段（不是连接请求段）的次数。

值名称：EnablePMTUDiscovery

建议的数值数据：0

有效值：0，1

说明：将该值设置为1（默认值）可强制TCP查找在通向远程主机的路径上的最大传输单元或最大数据包大小。攻击者可能将数据包强制分段，这会使堆栈不堪重负。对于不是来自本地子网的主机的连接，将该值指定为0可将最大传输单元强制设为576字节。

5.5 TCP安全

值名称：KeepAliveTime

建议的数值数据：300000

有效值： 80~4294967295

说明：指定TCP尝试通过发送持续存活的数据包来验证空闲连接是否仍然未被触动的频率。

值名称：NoNameReleaseOnDemand

建议的数值数据：1

有效值：0，1

说明：指定计算机在收到名称发布请求时是否发布其NetBIOS名称。

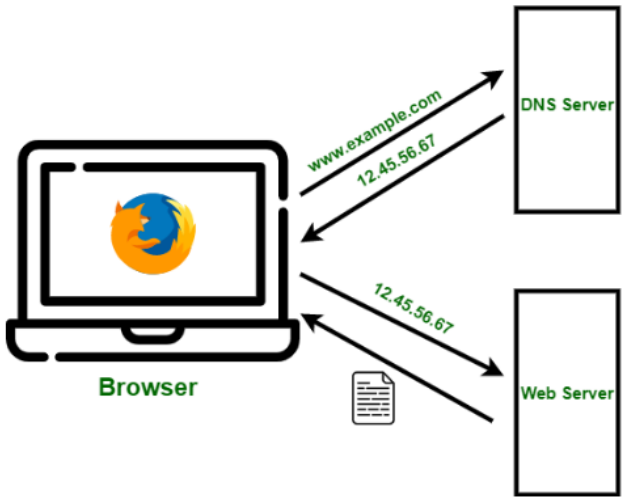
使用表5-1中汇总的值可获得最大限度的保护。

表5-1 建议值

值名称	值（REG_DWORD）
SynAttackProtect	2
TcpMaxPortsExhausted	1
TcpMaxHalfOpen	500
TcpMaxHalfOpenRetried	400
TcpMaxConnectResponseRetransmissions	2
TcpMaxDataRetransmissions	2
EnablePMTUDiscovery	0
KeepAliveTime	300000（5分钟）
NoNameReleaseOnDemand	1

5.6 DNS安全

5.6 DNS安全



为了解决主机IP地址与主机名之间的对应关系，InterNIC（Internet Network Information Center，Internet网络信息中心）制定了一套称为域名系统（Domain Name System，DNS）的分层名字解析方案，当DNS用户提出IP地址查询请求时，就可以由DNS服务器中的数据库提供所需的数据。DNS技术目前已广泛地应用于Internet和Intranet中。

5.6 DNS安全

5.6.1 DNS概述

DNS是一组协议和服务，它允许用户在查找网络资源时使用层次化的对用户友好的名字取代IP地址。当DNS客户端向DNS服务器发出IP地址的查询请求时，DNS服务器可以从其数据库内寻找所需要的IP地址给DNS客户端。这种由DNS服务器在其数据库中找出客户端IP地址的过程叫作“主机名称解析”。

5.6 DNS安全

- 1． DNS的功能及组成

简单地讲，DNS协议的最基本的功能是对主机名与对应的IP地址之间建立映射关系。例如，新浪网站的一个IP地址是202.106.184.200，几乎所有浏览该网站的用户都是使用www.sina.com.cn，而并非使用IP地址来访问。使用主机名（域名）比直接使用IP地址具有以下两点好处：

（1）主机名便于记忆，如sina.com.cn。

（2）数字形式的IP地址可能由于各种原因而改变，而主机名可以保持不变。

DNS的工作任务是在计算机主机名与IP地址之间进行映射。DNS位于TCP参考模型的最高层，使用TCP和UDP作为传输协议（一般多使用UDP，因为UDP的系统开销较小）。DNS模型相当简单：客户端向DNS服务器提出访问请求（如：www.sina.com.cn），DNS服务器在收到客户端的请求后在数据库中查找相对的IP地址（202.106.184.200），并作出反应。如果该DNS服务器无法提供对应的IP地址（如数据库中没有该客户端主机名对应的IP地址）时，它就转给下一个它认为更好的DNS服务器去处理。

5.6 DNS安全

当需要给某人打电话时，你可能知道这个人的姓名，而不知道他的电话号码。这时，可以通过查看电话号码簿查得他的电话号码，从而与他进行通话。由此可以看出，电话号码簿的功能便是建立姓名与电话号码之间的映射关系。而DNS的功能与这里的电话号码簿很类似。

DNS是为TCP/IP网络提供的一套协议和服务，是由名字分布数据库组成的。它建立了叫作域名空间的逻辑树结构，是负责分配、改写、查询域名的综合性服务系统。该空间中的每个节点或域都有一个唯一的名字。

组成DNS系统的核心是DNS服务器，它是回答域名服务查询的计算机，它允许为私人TCP/IP网络和连接公共Internet的用户提供并管理DNS服务，维护DNS名字数据并处理DNS客户端主机名的查询。DNS服务器保存了包含主机名和相应IP地址的数据库。例如，如果提供了名字www.sina.com，DNS服务器将返回新浪网站的IP地址202.106.184.200。

5.6 DNS安全

DNS是一种看起来与磁盘文件系统的目录结构类似的命名方案，域名也通过使用句点“.”分隔每个分支来标识一个域在逻辑DNS层次中相对于其父域的位置。但是，当定位一个文件位置时，是从根目录到子目录再到文件名，如C:\winnt\win.exe；而当定位一个主机名时，是从最终位置到父域再到根域，如sina.com。

图5-26显示了顶级域的名字空间及下一级子域之间的树型结构关系，图中的每一个节点以及其下的所有节点叫作一个域。域可以有主机（计算机）和其他域（子域）。例如，在图5-26中，pc1.sd.cninfo.net就是一个主机，而sd.cninfo.net则是一个子域。一般在子域中含有多个主机，例如，ah.cninfo.net子域下就含有pc1.ah.cninfo.net和pc30.ah.cninfo.net两台主机。

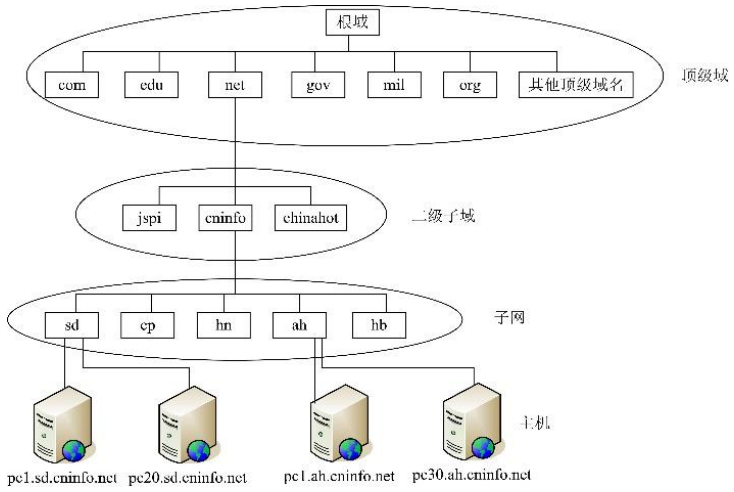


图5-26 Internet的域名结构

（1）根域。代表域名命名空间的根，这里为空。

（2）顶级域。直接处于根域下面的域，代表一种类型的组织和一些国家。在Internet中，由InterNIC进行管理和维护。如在顶级域名中com代表商业组织、edu代表教育和学术机构等，在域名的国家代码中cn代表中国、us代表美国等。

（3）二级域。在顶级域下面，用来标明顶级域以内的一个特定的组织。在Internet中，也是由InterNIC负责对二级域名进行管理和维护，以保证二级域名的唯一性。

（4）子域。在二级域的下面所创建的域，它一般由各个组织根据自己的要求自行创建和维护。

（5）主机。是域名命名空间中的最下面一层，它被称之为完全合格的域名（Fully Qualified Domain Name，FQDN）。

- 2． DNS的解析过程

现在假设客户端Web浏览器要访问网站www.sina.com，整个访问过程如图5-27所示。具体描述如下：

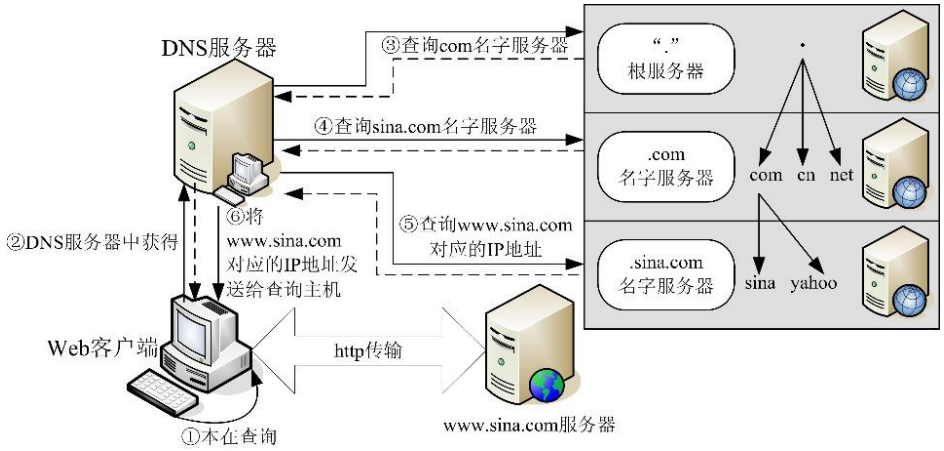


图5-27 Internet上对www.sina.com的访问过程

5.6 DNS安全

（1）Web浏览器调用DNS客户端程序（该程序称为“解析器”），先在本地的DNS缓存中查询是否有www.sina.com的记录。如果有该记录（例如，Web浏览器刚刚访问过www.sina.com，缓存中的记录系统还没有删除），则直接访问。

（2）如果在本地的缓存中没有找到相关的记录，客户端就会根据已设置的DNS服务器记录，向DNS服务器发出查询请求。如果该DNS服务器正好是创建www.sina.com记录的服务器，或在特定的时间段内处理过相同的查询，那么它就会从自己的区域记录或缓存中检索到该域名相应的资源记录（Resource Record，RR），并返回给客户端。

（4）DNS服务器向com名字服务器继续发出查询www.sina.com地址的请求，com名字服务器在找到sina.com的地址后，将结果发送给DNS服务器。

（5）DNS服务器向sina.com名字服务器发出查询www.sina.com的请求，sina.com名字服务器检索到www.sina.com对应的IP地址，并将结果发送给DNS服务器。

（6）DNS服务器将www.sina.com对应的资源记录发送给Web客户端，Web客户端利用IP地址访问相应的主机。

同时，在以上的递归查询过程中，Web客户端、DNS服务器以及各级的名字服务器都会记录这一次查询结果，以便下一次查询时直接调用。

5.6.2 DNS的安全问题

DNS服务是一种最基础的网络服务，但是DNS在设计之初并没有考虑安全问题，只是为了方便人们使用，简单地在域名与IP地址之间进行了映射，并将映射记录提供给人们查询，DNS内部没有为数据提供任何安全认证和数据完整性检查，留下了极大的安全隐患。如果DNS服务器被入侵者控制，则有可能篡改DNS服务器数据中IP地址与主机名之间的映射关系，从而会使主机遭受各类攻击（如DOS攻击、Web欺骗攻击等），严重时有可能造成单位内部网络（Intranet）或Internet中名称解析的混乱。下面，介绍几种常见的DNS安全威胁。

5.6 DNS安全

- 1．缓存中毒

DNS为了提高查询效率，采用了缓存机制，把用户查询过的最新记录存放在缓存中，并设置生存周期（Time To Live，TTL）。在记录没有超过TTL之前，DNS缓存中的记录一旦被客户端查询，DNS服务器（包括各级名字服务器）将把缓存区中的记录直接返回给客户端，而不需要进行逐级查询，提高了查询速率。

DNS缓存中毒利用了DNS缓存机制，在DNS服务器的缓存中存入大量错误的数据记录主动供用户查询。由于缓存中大量错误的记录是攻击者伪造的，而伪造者可能根据不同的意图伪造不同的记录，例如将查询指向某一个特定的服务器，使所有通过该DNS查询的用户都访问某一个网站的主页；或将所有的邮件指向某一台邮件服务器，拦截利用该DNS进行解析的邮件，等等。

5.6 DNS安全

由于DNS服务器之间会进行记录的同步复制，所以在TTL内，缓存中毒的DNS服务器有可能将错误的记录发送给其他的DNS服务器，导致更多的DNS服务器中毒。正如DNS的发明者Paul Mockapetris所说：中毒的缓存就像是“使人们走错方向的假冒路牌”。

2005年8月，数十万台互联网上的DNS服务器遭受到DNS缓存中毒的攻击，攻击者将存储在DNS服务器上的流行网站的IP地址更换为恶意网站的IP地址，将毫不知情的互联网用户由合法的网站引导到恶意网站，并要求用户透露机密信息或安装恶意软件。

DNS数据库对互联网上的用户是完全开放的，它既没有在DNS内部对数据提供认证机制和完整性检查，也没有对DNS服务器提供的服务进行访问控制和限制。所以攻击者可以将一些未经验证的数据存入到DNS服务器的缓存中，同时当用户在DNS服务器上进行地址查询时，DNS服务器也不对用户进行任何身份认证。DNS的这种工作机制造成了大量的安全漏洞，使DNS遭受到了各种各样的安全攻击。

- 2. 拒绝服务攻击

DNS服务器在互联网中的关键作用使它很容易成为攻击者进行攻击的目标，加上DNS服务器对大量的攻击没有相应的防御能力，所以攻击过程很容易实现，且造成的后果非常严重。现在使用的DNS采用了树型结构，一旦DNS服务器不能提供服务，其所辖的子域都将无法解析客户端的域名查询请求。

对DNS服务器进行拒绝服务攻击比较容易。目前针对DNS服务器的拒绝服务攻击主要有两种方式：一种是直接攻击DNS服务器，将DNS服务器作为被攻击对象，由多台攻击主机向被攻击的DNS服务器频繁发送大量的DNS查询请求，最终使DNS服务器崩溃；另一种是利用DNS服务器作为“中间人”，去攻击网络中的其他主机。攻击者可以向多个DNS服务器发送大量的查询请求，这些查询请求数据包中的源IP地址为被攻击者的IP地址。DNS服务器将大量的查询结果发送给被攻击主机，使被攻击主机无法提供正常的服务，例如使DNS服务器无法为用户提供正常的查询等。

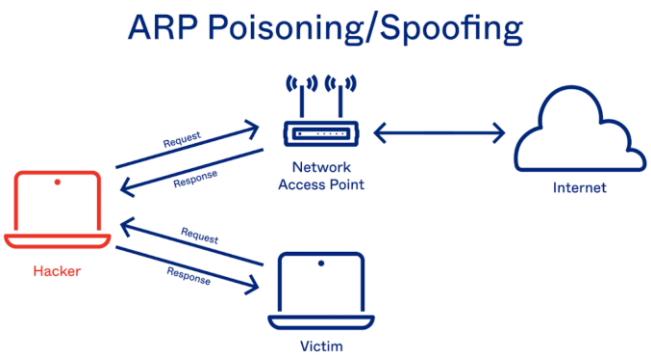
- 3. 域名劫持

域名劫持通常是指通过采用非法手段获得某一个域名管理员的账户和密码，或者域名管理邮箱，然后将该域名的IP地址指向其他的主机（该主机的IP地址有可能不存在）。域名被劫持后，不仅有关该域名的记录会被改变，甚至该域名的所有权可能落到其他人的手里。

2001年3月25日，“我要”（51.com）电子商务网站遭到攻击，其域名删除达1天之久。这是我国第一例涉嫌域名劫持的第一例事件。就其事件的整个过程，就是攻击者首先通过电子邮件获得到了51.com网站的域名管理员账户和密码，然后删除正常的域名解析记录。

5.3 ARP安全

5.3 ARP安全



ARP（Address Resolution Protocol，地址解析协议）用来将IP地址映射到MAC地址，以便设备能够在共享介质的网络（如以太网）中通信。

5.3 ARP安全

5.3.1 ARP概述

可以举一个例子很好地说明ARP是如何工作的：老师要将一封信交给教室里的某个学生，但是她并不认识这个学生，她只知道这个学生的姓名（IP地址），于是她对教室里所有的人说：“谁是王××，有你的信！”（ARP请求），当王××听到这个消息时（地址匹配），他站起来回答，然后老师就知道了他坐在几排几座（MAC地址），最后把信送到他座位上。

在ARP协议的实现中还有一些应该注意的事项：

（1） 每台计算机上都有一个ARP缓冲，它保存了一定数量的从IP地址到MAC地址的映射，同时当一个ARP广播到来时，虽然这个ARP广播可能与它无关，但ARP协议软件也会把其中的物理地址与IP地址的映射记录下来，这样做的好处是能够减少ARP报文在局域网上发送的次数。

（2） 按照缺省设置，ARP高速缓存中的项目是动态的，ARP缓冲中IP地址与物理地址之间的映射并不是一旦生成就永久有效的，每一个ARP映射表项都有自己的寿命，如果在一段时间内没有使用，那么这个ARP映射就会从缓冲中被删除，这一点和交换机MAC地址表的原理一样。这种老化机制，大大减少了ARP缓存表的长度，加快了查询速度。

在以太网中，当主机要确定某个IP地址的MAC地址时，它会先检查自己的ARP缓冲表，如果目标地址不包含在该缓冲表中，主机就会发送一个ARP请求（广播形式），网段上的任何主机都可以接收到该广播，但是只有目标主机才会响应此ARP请求。由于目标主机在收到ARP请求时可以学习到发送方的IP地址到MAC地址的映射，因此它采用一个单播消息来回应请求。这个过程如图5-10所示。

5.3 ARP安全

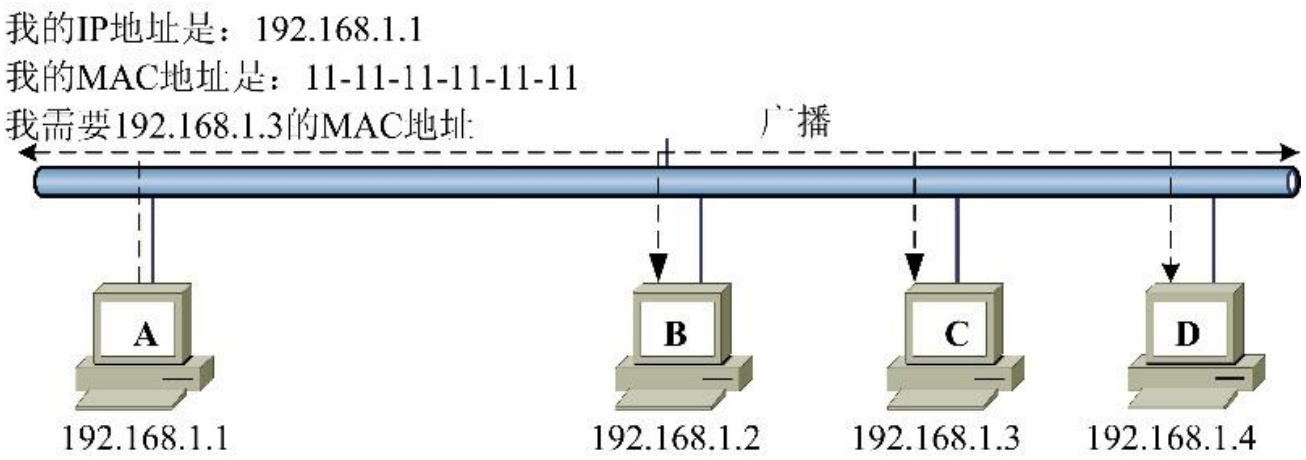
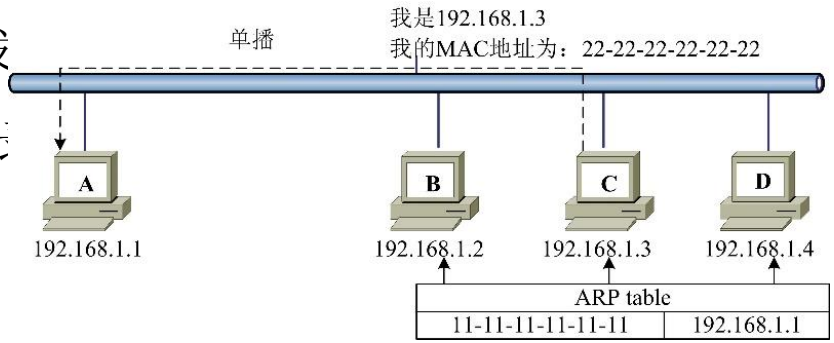


图5-10 ARP请求的过程

在图5-10中，主机A以广播形式发送ARP请求查询IP地址为192.168.1.3的主机的MAC地址，网段上所有的主机都会收到该ARP请求。

5.3 ARP安全

如图5-11所示，主机B、主机D收到主机A发来的ARP请求时，它们发现这个请求不是发给自己的，因此它们忽略这个请求，但是它们还是将主机A的IP地址到MAC地址的映射记录到自己的ARP表中。当主机C收到主机A发来的ARP请求时，它发



它用单播消息回应ARP请求，同时记

图5-11 ARP回应的过程

反向ARP（Reverse Address Resolution Protocol，RARP）是ARP的逆过程，即通过MAC地址找到对应的IP地址。

5.3.2 ARP欺骗

通过对上一节内容的学习，读者会发现ARP本来是局域网中计算机之间通信时所采用的一种非常有效的协议。但是，由于一台ARP主机在给另一台主机发送ARP响应时，并不一定首先要得到另一台主机的ARP请求，局域网中的任何一台主机都可以给其他主机发送公告：我的IP地址是××，我的MAC地址是××。这种协议设计上的漏洞便为网络攻击提供了可乘之机。

5.3 ARP安全

- 1. ARP欺骗的概念和现状

由于ARP协议在设计中存在的主动发送ARP报文的漏洞，使得主机可以发送虚假的ARP请求报文或响应报文，报文中的源IP地址和源MAC地址均可以进行伪造。在局域网中，即可以伪造成某一台主机（如服务器）的IP地址和MAC地址的组合，也可以伪造成网关的IP地址和MAC地址的组合，等等。这种组合可以根据攻击者的意图进行任意搭配，而现有的局域网中却没有相应的机制和协议来防止这种伪造行为。近几年来，局域网中的ARP欺骗已经泛滥成灾，几乎没有一个局域网未遭遇过ARP欺骗的侵害。

由于ARP协议工作在TCP/IP参考模型的网际层与网络接口层之间（OSI参考模型的网络层与数据链路层之间），所以现有的网管软件和防病毒软件几乎对ARP欺骗无能为力，网络管理员只能通过地址绑定等最简单和原始的方法来防御ARP欺骗，而缺乏一种行之有效的全网解决方案。

5.3 ARP安全

从大量的ARP欺骗行为来看，虽然有部分是为了窃取他人计算机上发送的报文信息，但占的比例并不大。目前，绝大部分ARP欺骗是为了扰乱局域网中合法主机中保存的ARP表，使得网络中的合法主机无法正常通信或通信不正常，如表示为计算机无法上网或上网时断时续等。ARP欺骗中的主机是指主要以MAC地址作为通信地址的设备，如局域网中的计算机、交换机等。所以，下面将分别针对计算机和交换机来介绍ARP欺骗的现象。

- 2． 针对计算机的ARP欺骗

要全面理解ARP欺骗，首先要掌握如图5-3所示的TCP/IP体系结构的工作特点，即明确ARP协议在TCP/IP参考模型中的位置：网际层与网络接口层之间。目前，局域网中的ARP欺骗形式多种多样，下面仅以最常见的一种ARP欺骗现象为例进行介绍。

如图5-12所示，假设主机A向主机B发送数据。在主机A中，当应用程序要发送的数据到了TCP/IP参考模型的网际层与网络接口层之间时，主机A在ARP缓存表中查找是否有主机B的MAC地址（其实是主机B的IP地址与MAC地址的对应关系），如果有，则直接将该MAC地址（22-22-22-22-22-22）作为目的MAC地址添加到数据单元的网络首部（位于网络接口层），成为数据帧。在局域网（同一IP网段，如本例的192.168.1.x）中，主机利用MAC地址作为寻址的依据，所以主机A根据主机B的MAC地址，将数据帧发送给主机B。

5.3 ARP安全

主机	IP地址	MAC地址
主机A	192.168.1.1	11-11-11-11-11-11
主机B	192.168.1.2	22-22-22-22-22-22
主机C	192.168.1.3	33-33-33-33-33-33
主机D	192.168.1.4	44-44-44-44-44-44
主机E	192.168.1.5	55-55-55-55-55-55

图5-12 主机中IP地址与MAC地址的对应关系示意图

5.3 ARP安全

如果主机A在ARP缓存表中没有找到目标主机B的IP地址对应的MAC地址，主机A就会在网络上发送一个广播帧，该广播帧的目的MAC地址是“FF.FF.FF.FF.FF.FF”，表示向局域网内的所有主机发出这样的询问：IP地址为192.168.1.2的MAC地址是什么？在局域网中所有的主机都会接收到该广播帧，但在正常情况下因为只有主机B的IP地址是192.168.1.2，所以主机B会对该广播帧进行ARP响应，即向主机A发送一个ARP响应帧：我（IP地址是192.168.1.2）的MAC地址是22-22-22-22-22-22。

这样，主机A就知道了主机B的MAC地址，它就可以向主机B发送数据了。同时主机A还会更新自己的ARP缓存表，将主机B的IP地址与MAC地址的对应关系保存在自己的ARP缓存表中，以供下次通信时直接使用，避免进行广播查询。

5.3 ARP安全

但是，主机的ARP缓存中并不会保存所有参与过通信的主机的IP地址和MAC地址的对应关系，而是采用了老化机制防止ARP缓存表过于庞大，因为ARP过于庞大的ARP缓存表会影响主机的通信效率。在一段时间内，如果ARP缓存表中的某一条记录没有使用，就会被删除。

从上面的例子可以看出，ARP协议的基础就是信任局域网内所有的主机，这样就很容易实现在局域网内的ARP欺骗。如果现在主机D要对主机A进行ARP欺骗，冒充自己是主机C。具体实施中，当主机A要与主机C进行通信时，主机D主动告诉主机A自己的IP地址和MAC地址的组合是“192.168.1.3+44-44-44-44-44-44”，这样当主机A要发送给主机C数据时，会将主机D的MAC地址44-44-44-44-44-44添加到数据帧的目的MAC地址中，从而将本来要发给主机C的数据发给了主机D，实现了ARP欺骗。在整个ARP欺骗过程中，主机D称为“中间人”（man in the middle），对这一中间人的存在主机A根本没有意识到。

5.3 ARP安全

通过以上的ARP欺骗，使主机A与主机C之间断开了联系。如图5-13所示，现在假设主机C是局域网中的网关，而主机D为ARP欺骗者。这样，当局域网中的计算机要与其他网络进行通信（如访问Internet）时，所有发往其他网络的数据全部发 样整个网络将无法与其他网络进行

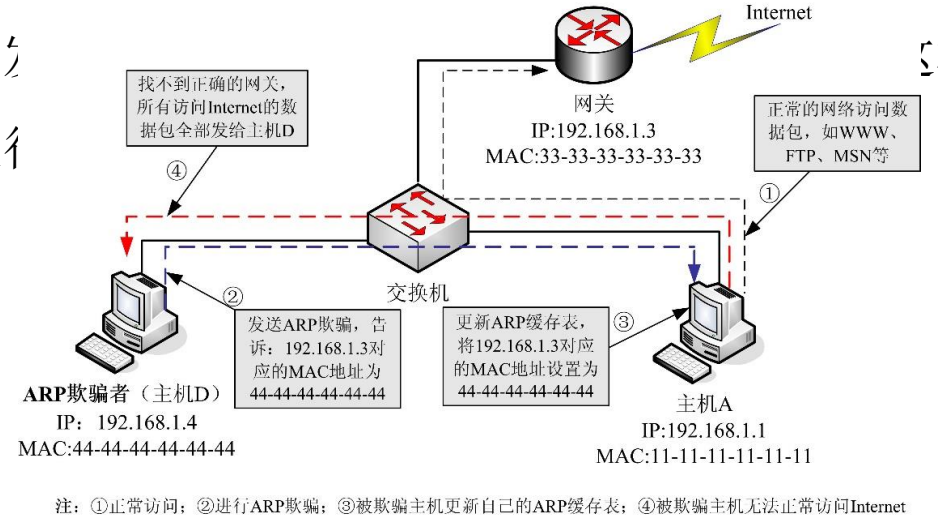


图5-13 ARP欺骗的实现过程

- 3. 针对交换机的ARP欺骗

交换机的工作原理是通过主动学习下连设备的MAC地址，并建立和维护端口和MAC地址的对应表，即交换机中的MAC地址表。通过MAC地址表，实现下连设备之间的[illegible]称为CAM（Content Addressable Memory[illegible]4所示。

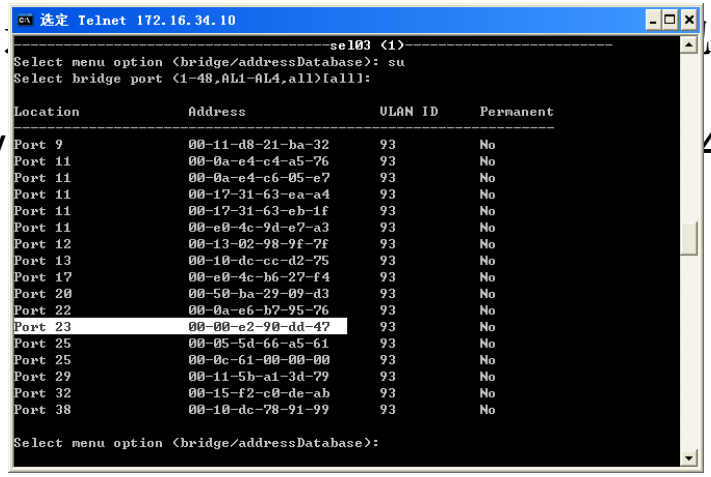


图5-14 交换机中的MAC地址表

5.3 ARP安全

交换机中的CAM表详细地记录了参与通信的下连设备的MAC与交换机端口的一一对应关系。CAM表在交换机加电启动时是空的，当下连的某一台主机要通信时，交换机会自动将该主机的MAC地址与下连端口的对应关系记录下来，在CAM表中形成一条记录，将这一过程称为交换机的学习。CAM表的大小是固定的，不同交换机的CAM表大小可能不同。

在进行ARP欺骗时，ARP欺骗者利用工具产生欺骗MAC，并快速填满CAM表。交换机的CAM表被填满后，交换机便以广播方式处理通过交换机的数据帧，这时ARP欺骗者可以利用各种嗅探攻击获取网络信息。CAM表被填满后，流量便以洪泛（Flood）方式发送到所端口，其中交换机上连端口（Trunk端口）上的流量也会发送给所有端口和邻接交换机。这时的交换机其实已成为一台集线器。与集线器不同，由于交换机上有CPU和内存，大量的ARP欺骗流量会给交换机产生流量过载，其结果是下连主机的网络速度变慢，并造成数据包丢失，甚至产生网络瘫痪。

在计算机网络中曾经出现的SQL蠕虫病毒就是利用组播功能，构造虚假的目的MAC地址将交换机的CAM表填满，对网络安全运行造成了非常大的威胁。

8.2 防火墙的应用

8.2 防火墙的应用

在计算机网络管理中防火墙是一种非常有效的安全解决方案，它可以为用户提供一个相对安全的网络环境。但是，并不是说防火墙在安全管理中是万能的，采用了防火墙的网络同样存在一些安全漏洞和隐患。



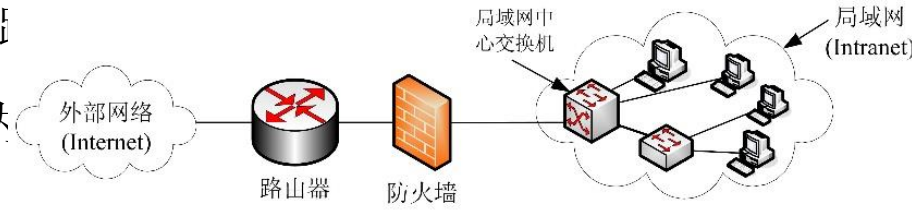
8.2.1 防火墙在网络中的应用

作为最基本的网络安全防护措施，防火墙将网络不但在物理上进行了分割，而且在安全逻辑上进行了严格的划分。

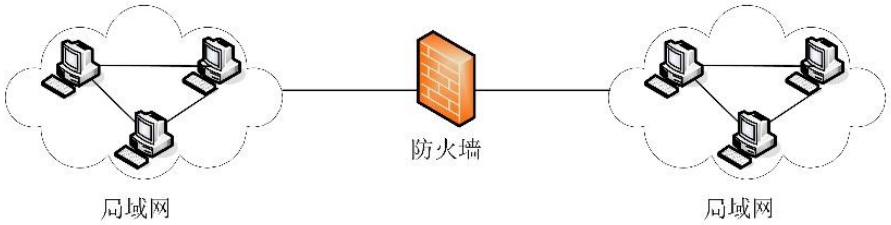
8.2 防火墙的应用

- 1. 防火墙在网络中的位置

防火墙多应用于一个局域网的出口处（如图8-1（a）所示）或置于两个网络中间（如图8-1（b）所示）。对于绝大多数局域网来说，在将局域网接入Internet时，在[illegible]置一台防火墙，以实现对局域网内



(a) 位于局域网出口处的防火墙



(b) 置于两个局域网中间的防火墙

图8-1 防火墙在网络中的位置

8.2 防火墙的应用

根据应用的不同，防火墙一般可以分为路由模式防火墙和透明模式防火墙两类。其中，路由模式防火墙可以让处于不同网段的计算机通过路由转发的方式互相通信（如图8-1（b）所示），路由模式防火墙存在以下两个局限：

（1）防火墙各端口所连接的网络必须位于不同的网段，否则两个网络之间将无法进行通信；

（2）与防火墙直接连接的设备（计算机、路由器或交换机）的网关都要指向防火墙。

简单讲，路由模式防火墙是让防火墙同时承担路由器的功能，而路由器主要用于连接不同的网络。

将路由模式防火墙也称为“不透明”的防火墙。而透明模式防火墙克服了路由模式防火墙的不足，可以连接两个位于同一逻辑网段的物理子网，将其加入一个已有的网络时可以不用修改边缘网络设备的设置。透明模式防火墙的应用如图8-1（a）所示。

为了适应不同网络的应用需要，目前市面上的主流防火墙一般都同时支持路由模式和透明模式两种工作模式，使用者可以根据实际的网络需要在两种模式之间进行选择。

8.3 防火墙的基本类型

8.3 防火墙的基本类型

作为内部网络与外部公共网络之间的一道屏障，防火墙是最先受到人们重视的网络安全产品之一。对于防火墙的工作类型，可以根据不同的方式进行分类。例如，按照防火墙对数据包处理方式的不同，可以分为包过滤防火墙和代理防火墙（也称“应用层网关防火墙”）两大体系，前者主要有以色列的Chechpoint防火墙和Cisco PIX防火墙，后者主要有AI公司的Cauntlet防火墙。考虑到读者的需要，本章则从防火墙的体系结构（或架构）入手，介绍防火墙的基本类型。

防火墙的基本准则

防火墙在网络安全管理中通常遵循以下两种策略：

1. 默认拒绝原则（所有未被允许的即禁止）

- 仅允许经过管理员授权的通信通过，默认封锁所有未明确开放的服务。
- **优点**：安全性高，可有效防止未经授权的访问。
- **缺点**：用户访问受限，需要逐项开放服务，管理成本较高。
- Cisco PIX防火墙默认采用此策略。

2.默认允许原则（所有未被禁止的即允许）

- 默认允许所有通信，仅屏蔽特定的未授权用户或站点。
- **优点**：灵活性强，用户可自由访问大部分资源。
- **缺点**：管理复杂，随着服务增多，安全风险提高，防护难度加大。
- 许多国产防火墙采用此策略。

- 2. 包过滤防火墙的工作原理

包过滤（Packet Filter）是在网络层中根据事先设置的安全访问策略（过滤规则），检查每一个数据包的源IP地址、目的IP地址以及IP分组头部的其他各种标志信息（如协议、服务类型等），确定是否允许该数据包通过防火墙。其实，从早期的包过滤防火墙开始，防火墙除能够根据IP分组的头部信息进行数据包的检查外，还能够检查TCP和UDP协议及使用的端口，并将其作为数据包的过滤规则。为此，包过滤防火墙同时工作在OSI参考模型的网络层和传输层。

包过滤防火墙中的安全访问策略（过滤规则）是网络管理员事先设置好的，主要通过对进入防火墙的数据包的源IP地址、目的IP地址、协议及端口进行设置，决定是否允许数据包通过防火墙。

防火墙的基本类型（按层次）

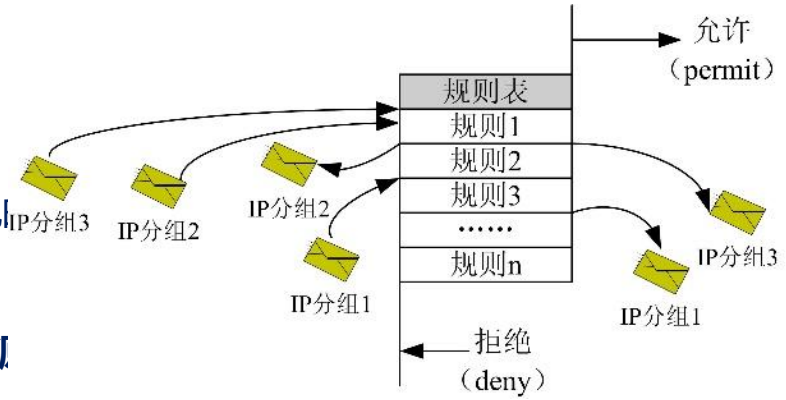
1 包过滤防火墙

利用包过滤（Packet Filtering）技术在网络层实现

1. IP分组的组成

数据包由**IP头部**和**数据部分**组成，**IP头部包含**

2. 包过滤防火墙的工作原理



包过滤防火墙工作示意图

- **过滤机制**：包过滤防火墙在网络层和传输层工作，检查每个数据包的源/目的IP地址、协议、端口号等信息，并与预设规则表匹配，决定是否放行或阻止数据包。
- **匹配过程**：
  - 防火墙从**规则表**的第一条规则开始，逐条匹配数据包的头部信息。
  - 一旦匹配成功，即执行对应规则，不再继续匹配。
  - 如果所有规则都不匹配，则默认丢弃数据包（如 deny ip any any 规则）。

防火墙的过滤规则表其实是一个访问控制列表（Access Control List，ACL），当数据包进入防火墙时，防火墙首先提取IP分组的头部信息，然后再与ACL中的条目从上到下进行一一比对。如果第一条规则不匹配，就开始检查第二条规则，依此类推。当ACL中的某一条规则匹配时，防火墙开始执行该规则，不再进行以下条目的检查。

8.3 防火墙的基本类型

例如，如果拒绝从IP地址为172.16.1.100的主机发出的数据包通过防火墙，则可以通过类似于下行的一条命令来实现：

deny ip host 172.16.1.100 any

如果允许使用80端口的TCP协议和使用20端口UDP协议的数据包通过，则可以通过类似于下面的2条命令来实现：

permit tcp any any eq 80

permit udp any any eq 20

网络管理员可以根据网络安全的实际需要，通过相应的命令行允许（permit）或拒绝（deny）数据包通过。

如图8-5所示，当网络管理员在防火墙上设置了过滤规则后，在防火墙中会形成一个过滤规则表。当数据包进入防火墙时，防火墙会将IP分组的头部信息与过滤规则表进行逐条比对，根据比对结果决定是否允许数据包通过。假设某一防火墙的过滤规则表中只有以下的4条规则（实际应用中要远远超过4条）：

deny ip host 172.16.1.100 any

permit tcp any any eq 80

permit udp any any eq 20

deny ip any any

防火墙的基本类型（按层次）

1 包过滤防火墙

利用包过滤（Packet Filtering）技术在网络层实现的防火墙称为包过滤防火墙。

3. 包过滤防火墙的特点

包过滤防火墙的优点是**成本低、速度快、对用户透明，并且实现方式灵活**（既可以与现有路由器集成，也可以使用独立软件实现）。

同时，它也存在以下缺点：

（1）**配置**起来比较**困难**，尤其是当规则比较多时，非常容易出错。

（2）工作在OSI参考模型的网络层，**无法检测针对应用层的攻击。**

（3）基于IP头部信息进行过滤，而这些**信息都可以伪造**，使得**防火墙容易被绕过。**

防火墙的基本类型（按层次）

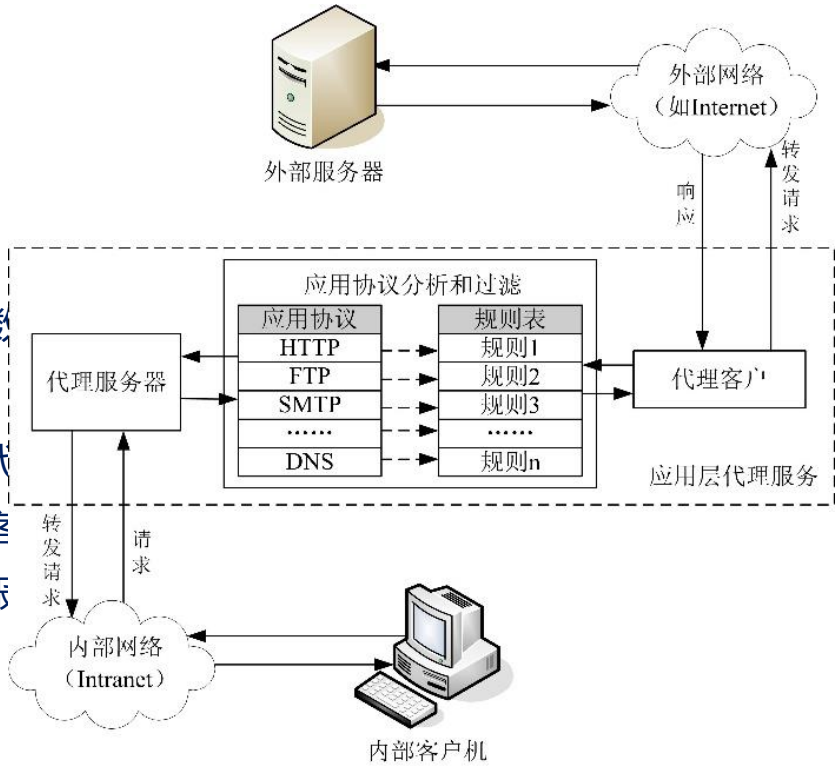
2 代理防火墙

代理防火墙（应用层网关防火墙）充当中介，转发，从而阻挡直接连接，提高安全性。

1. 代理防火墙的工作原理

代理服务器位于客户端和服务器之间，截获所有数

- **工作流程：**
  - **拦截请求**：内部客户端请求外部服务器，代
  - **代发请求**：若符合策略，代理服务器代替客
  - **检查响应**：外部服务器返回数据后，代理服
- **支持协议：**代理防火墙支持 HTTP、HTTPS、并不断扩展新协议。



代理防火墙的工作示意图

防火墙的基本类型（按层次）

2 代理防火墙

代理防火墙（应用层网关防火墙）充当中介，内外部网络的数据通信必须通过代理服务器进行转发，从而阻挡直接连接，提高安全性。

2. 代理防火墙的特点

代理服务器位于客户端和服务器之间，截获所有数据请求。

- **优点：**
  - **高安全性**：所有通信必须通过代理服务器，能够检测和拦截应用层的恶意攻击和病毒。
  - **缓存加速**：代理服务器存储常用访问数据，减少重复请求，提高访问效率。
  - **细粒度控制**：可针对特定应用层协议（如HTTP、FTP）进行访问限制，提高安全管理能力。
- **缺点：**
  - **性能较低**：代理防火墙需要解析和处理每个数据包，相比包过滤防火墙，吞吐量较低，对系统性能影响较大。

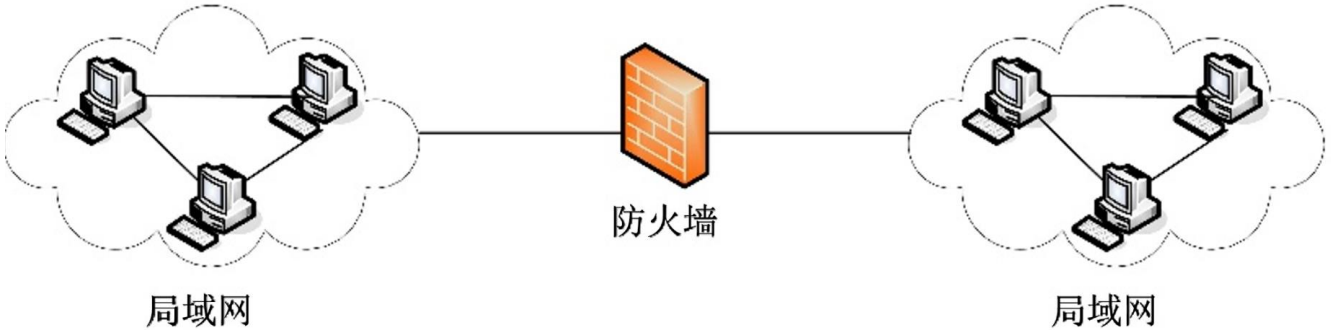
防火墙的基本类型（按工作模式）

1．防火墙的网络位置

防火墙不仅物理上分隔网络，还在安全逻辑上进行划分。通常，防火墙部署在局域网（LAN）接入Internet的出口，或两个网络之间，如：

1.路由模式防火墙（如下图）

- 连接不同网段的设备，并通过路由转发数据。
- **局限性**：必须连接不同网段，所有设备的网关需指向防火墙。
- 也称为“不透明”防火墙。



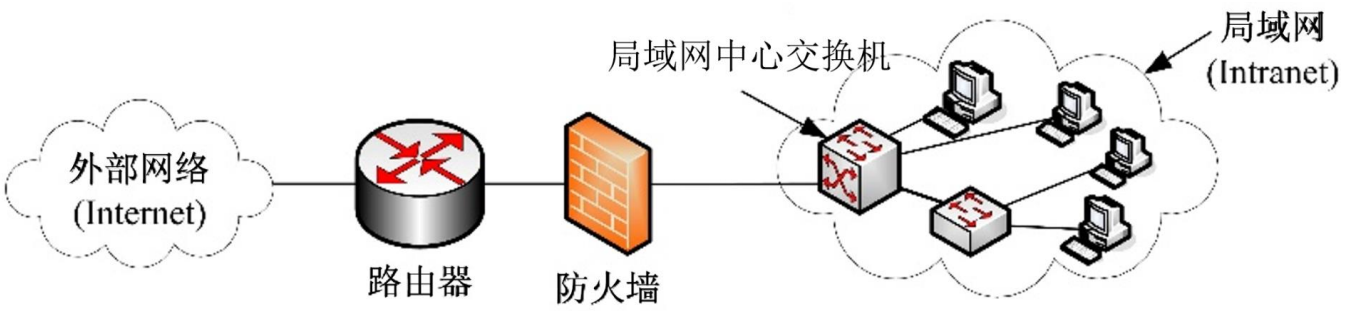
置于两个局域网中间的防火墙

防火墙的基本类型（按工作模式）

2.透明模式防火墙（如下图）

- 可连接同一网段的设备，不需修改网络设置。
- 适用于无需变更网络架构的环境。

主流防火墙一般支持**两种模式**，用户可根据需求选择。



位于局域网出口处的防火墙

7.1 网络攻击概述

7.1 网络攻击概述



随着网络应用的日渐普及，安全威胁日显突出，其中网络攻击成为目前网络安全中危害最严重的现象之一，所以研究和解决各种攻击方法将显得很有必要。

7.1.1 网络入侵与攻击的概念

网络入侵是一个广义上的概念，它是指任何威胁和破坏计算机或网络系统资源的行为，例如非授权访问或越权访问系统资源、搭线窃听网络信息等。具有入侵行为的人或主机称为入侵者。一个完整的入侵包括入侵准备、攻击、侵入实施等过程。而攻击是入侵者进行入侵所采取的技术手段和方法，入侵的整个过程都伴随着攻击，有时也把入侵者称为攻击者。

其实，在整个网络行为中，入侵和攻击仅仅是在形式和概念描述上有所不同，其实质基本上是相同的。对计算机和网络系统而言，入侵与攻击没有本质的区别，入侵伴随着攻击，攻击的结果就是入侵。例如，在入侵者没有侵入目标网络之前，会采取一些方法或手段对目标网络进行攻击。当攻击者侵入目标网络之后，入侵者利用各种手段窃取和破坏别人的资源。

从网络安全角度看，入侵和攻击的结果都是一样的。一般情况下，入侵者或攻击者可能是黑客、破坏者、间谍、内部人员、被雇用者、计算机犯罪者。攻击时，所使用的工具（或方法）可能是电磁泄漏、搭线窃听、程序或脚本、软件工具包、自治主体（能独立工作的小软件）、分布式工具、用户命令或特殊操作等。在本章的描述中，将集中使用攻击这一概念。

7.1 网络攻击概述

入侵者（或攻击者）所采用的攻击手段主要有以下八种特定类型。

将自己伪装成为合法用户（如系统管理员），并以合法的形式攻击系统。

攻击者首先复制合法用户所发出的数据（或部分数据），然后进行重发，以欺骗接收者，进而达到非授权入侵的目的。

通过采取秘密方式篡改合法用户所传送数据的内容，实现非授权入侵的目的。

中止或干扰服务器为合法用户提供服务或抑制所有流向某一特定目标的数据。

利用其所拥有的权限对系统进行破坏活动。这是最危险的类型，据有关资料统计，80%以上的网络攻击及破坏与内部攻击有关。

通过搭线窃听、截获辐射信号、冒充系统管理人员或授权用户、设置旁路躲避鉴别和访问控制机制等各种手段入侵系统。

首先通过某种方式侵入系统，然后安装陷阱门（如植入木马程序）。并通过更改系统功能属性和相关参数，使入侵者在非授权情况下能对系统进行各种非法操作。

这是一种具有双重功能的客户/服务体系结构。特洛伊木马系统不但拥有授权功能，而且还拥有非授权功能，一旦建立这样的体系，整个系统便被占领。

②漏报。IDS对已知的入侵活动未产生报警的现象称为漏报。漏报说明IDS虽然在进行攻击的检测，但它却没有命中真正的攻击。大多数IDS都通过相关技术尽量使系统避免漏报，但完全清除漏报是很困难的，基本是不可能的。由于漏报会导致攻击者能够实现攻击过程，但IDS却没有检测到，这对网络系统会产生严重的安全威胁。一般情况下，漏报是因为IDS的软件缺陷所导致的。

（2）Attacks（攻击）。Attacks（攻击）指试图渗透系统或绕过系统的安全策略以获取信息、修改信息以及破坏目标网络或系统功能的行为。IDS的攻击主要包括DoS/DDoS、Smurf、木马、勒索软件、蠕虫等。

7.3.2 IDS的分类

根据不同的标准，可以对IDS进行不同的分类。下面主要从IDS的工作原理对其进行类别划分。根据实现技术的不同，IDS可以分为异常检测模型、误用检测模型和混合检测模型三种类型。

- 1. 异常检测模型

异常检测（Anomaly Detection）模型主要检测与可接受行为之间的偏差，把当前主体的活动与网络行为比较，网络行为一般是指网络中正常的访问行为特征参数及其阈值的集合，当网络活动行为与系统正常行为有较大偏离时判定为入侵。异常检测常用的是统计方法，最大的特点是能够让入侵检测系统自动学习主体的行为习惯。常见的异常检测模型如图7-10所示。

如果可以预先定义每项可接受的行为（如对HTTP的正常访问、正常的TCP连接、正常的SMTP协议使用等），那么每项不可接受的行为（如TCP半连接状态、大量连续的SMTP连接等）就应该是入侵。首先总结正常操作应该具有的特征（用户轮廓），当用户活动与正常行为有重大偏离时即被认为是入侵。这种检测模型的漏报率低，但误报率高。因为不需要对每种入侵行为进行定义，所以能有效检测未知的入侵。

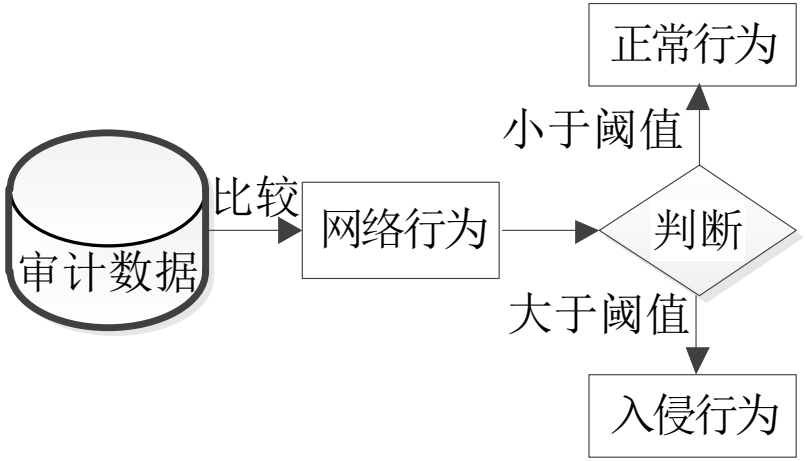


图7-10 异常检测模型

- 2. 误用检测模型

如图7-11所示，误用检测（Misuse Detection）模型主要检测与已知到不可接受行为之间的匹配程度。如果可以定义所有的不可接受行为，那么每种能够与之匹配的行为都会引起报警。收集非正常操作的行为特征，建立相关的特征库，当监测的用户或系统行为与库中的记录相匹配时，系统就认为这种行为是入侵。误用检测型检测基于已知的系统缺陷和入侵模式，所以又称“特征检测模型”。它能够准确地检测到某些特征的攻击，但却过度依赖事先定义好的安全策略，所以无法检测系统未知的攻击行为，从而产生入侵或攻击的漏报。

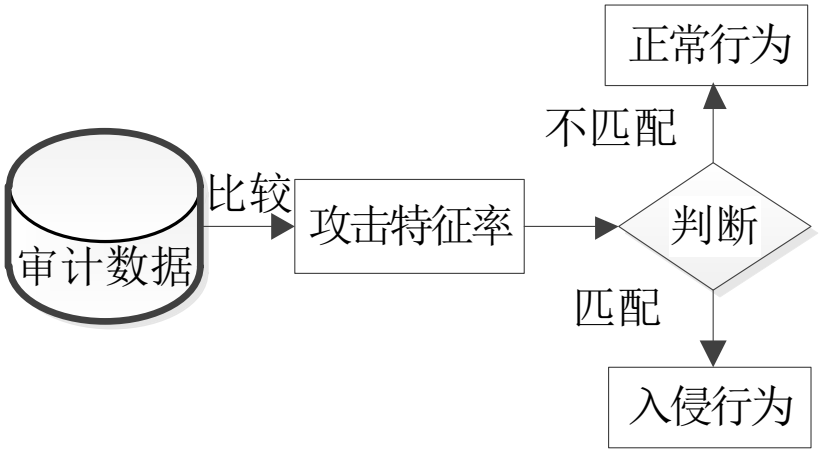


图7-11 误用检测模型

- 3. 混合检测模型

混合检测模型是对异常检测模型和误用检测模型的综合。近几年来，混合检测模型日益受到人们的重视。这类检测在做出决策之前，既分析系统的正常行为，同时还观察可疑的入侵行为，所以判断结果更全面、准确、可靠。

混合检测并不为不同的入侵行为分别建立模型，而是首先通过大量的事例学习什么是入侵行为以及什么是系统的正常行为，发现描述系统特征的一般使用模式，然后再形成对异常和误用都适用的检测模型。

7.3.3 IDS的信息收集

入侵检测的第一步是信息收集，收集内容包括系统、网络、数据及用户活动的状态和行为。此工作由放置在不同网段的传感器或不同主机上的代理来进行，包括系统和网络日志文件、网络流量、非正常的目录和文件改变、非正常的程序执行等。

- 1. 信息收集的方法

就准确性、可靠性和效率而言，IDS收集到的信息是它进行检测和决策的基础。如果收集信息的时延太大，很可能在检测到攻击的时候，入侵者已经完成了入侵过程；如果信息不完整，系统的检测能力就会下降；如果信息本身不正确，系统就无法检测到某些攻击，从而给用户形成一种不真实的安全感。所以研究信息收集机制是非常重要的。根据对象的不同，信息收集的方法包括基于主机的信息收集、基于网络的信息收集和混合型信息收集三种类型。

（1）基于主机的信息收集

系统分析的数据是计算机操作系统的事件日志、应用程序的事件日志、系统调用、端口调用和安全审计记录。主机型入侵检测系统保护的一般是所在的主机系统。是由代理（agent）来实现的，代理是运行在目标主机上的可执行程序，它们与命令控制台（console）通信。 基于主机的IDS部署如图7-12所示。

（2）基于网络的信息收集

系统分析的数据是网络上的数据包。网络型入侵检测系统担负着保护整个网段的任务，基于网络的入侵检测系统由遍及网络中每个网段的传感器（sensor）组成。传感器是一台将以太网卡置于混杂模式的计算机，用于嗅探网络上的数据包。基于网络的IDS部署如图7-13所示（当单位内部网络存在多个网段时，建议在每一个网段分别安装一个传感器）。

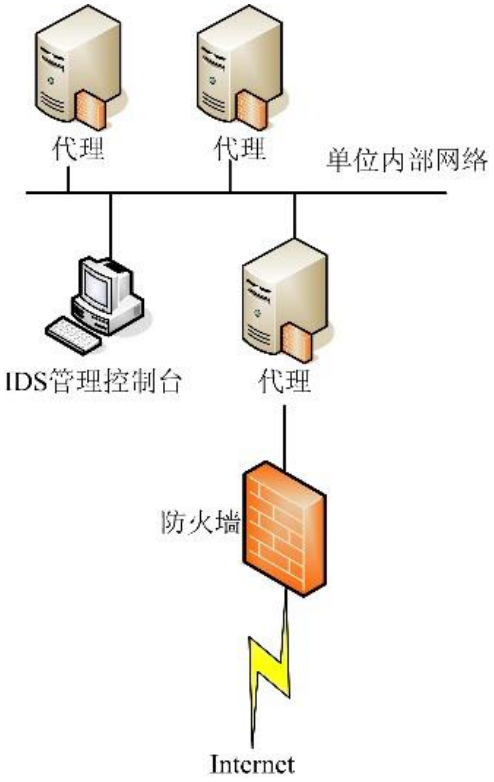


图7-12 基于主机的IDS部署

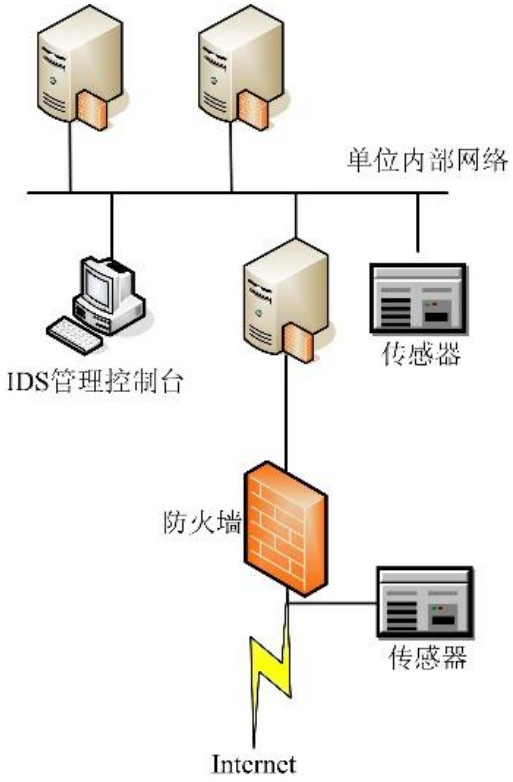


图7-13 基于网络的IDS部署

（3）混合型信息收集

混合型信息收集是基于网络的信息收集和基于主机的信息收集的有机结合。基于网络的信息收集和基于主机的信息收集都存在不足之处，会造成防御体系的不全面，而混合型入侵检测系统既可以发现网络中的攻击信息，也可以从系统日志中发现异常情况。

基于网络的数据收集有时会比基于主机的数据收集效果更好，尤其是主机对攻击行为没有反应的时候（例如，攻击数据包指向的端口是关闭的），也可以通过终端主机网络协议的底层检测到这些攻击。总体而言，基于主机的数据收集占有一定的优势：

①基于主机的信息收集所收集到的数据能准确反映主机上发生的情况，而不是根据从网络上收集到的数据包去猜测发生了什么事情。

②在数据流量很大的网络中，由于受线路的影响，网络监视器经常会产生丢包，但主机监视器则可以报告每台主机上发生的所有事件。

③基于网络的信息收集机制对插入攻击和规避攻击无能为力，但基于主机的信息收集就不存在这样的问题，它能够处理主机收到的所有数据。

- 2． 直接监控与间接监控

我们将信息收集的途径分成直接监控和间接监控两种方法。

（1）直接监控。从信息生成地或属地直接获取数据。例如，如果要直接监控某台主机的CPU负载情况，就需要从主机相应的内核结构中获取数据。

（2）间接监控。从能反映监控目标行为的数据源处获取数据。例如，如果要直接监控某台主机的CPU负载情况，间接监控可以通过读取记录CPU负载的日志文件，完成对主机CPU 负载的监控。

就检测入侵行为而言，直接监控要优于间接监控，原因如下：

（1）从非直接数据源获取的数据（例如审计踪迹）在被IDS使用之前，有被入侵者修改的潜在可能。尤其是通过未加密的以明文方式传输和存储的数据被篡改的可能性更大。

（2）非直接数据源可能无法记录某些事件。

（3）在间接监控中，数据一般都是通过某种机制生成的（如编写审计踪迹的代码），但那些机制并不了解IDS使用数据的具体需求。因此，从间接数据源获取的数据量总是非常大，一个C2级生成的审计踪迹可能包含每个用户每天50kB~500kB的记录，对于一个中等规模的用户组来说，每天审计踪迹数据可能有好几百兆。由于这个原因，IDS在使用间接数据源时，通常必须消耗大量的资源对数据进行过滤和精简。直接监控方法只获取它需要的数据，所以生成的数据量相对较小。此外，监控组件自身也会对数据进行分析，只有在检测到相关事件时才产生结果，这样就减少了数据的存储量。

（4）间接监控机制的伸缩性差。因为当主机及其内部被监控要素的数目增加时，过滤数据的开销会降低被监控主机的性能。

（5）间接数据源常常在数据产生和IDS访问这些数据之间有一个时延，而直接监控的时延就小得多，这样IDS才能据此做出更及时的响应。

- 3. 信息收集的渠道

IDS目前所能检测到的大部分入侵都是由主机上的活动引起的，如执行某一命令、访问某项服务并提供不正确的数据等，这些攻击活动发生在终端机上，有时通过网络检测也可以发现。针对网络本身的攻击通常都是数据流，即发送的数据量超过网络的承受能力，以至于合法数据包通信受阻。但在终端机上也照样可以检测到这些攻击，例如通过查看主机ICMP报文是否有大量的Echo-Request分组，也可以检测到是否有Ping的泛洪数据流攻击发生。入侵检测利用的信息一般来自以下四个方面。

（1） 系统和网络日志文件

攻击者经常在系统日志文件中留下他们的踪迹，因此充分利用系统和网络日志文件信息是检测入侵的必要条件。日志中包含发生在系统和网络上的不寻常和不期望活动的证据，这些证据可以指出有人正在入侵或已成功入侵了系统。通过查看日志文件，能够发现成功的入侵或入侵企图，并很快地启动相应的应急响应程序。日志文件中记录了各种行为类型，每种类型又包含不同的信息。例如记录“用户活动”类型的日志，就包含登录、用户ID改变、用户对文件的访问、授权和认证信息等内容。很显然，不正常的或不期望的用户行为就是重复登录失败、登录到不期望的位置以及非授权的企图访问重要文件等等。如图7-14所示的是通过Windows系统“事件查看器”记录的相关日志，网络管理员要养成经常查看日志记录的习惯。

7.3 IDS技术及应用

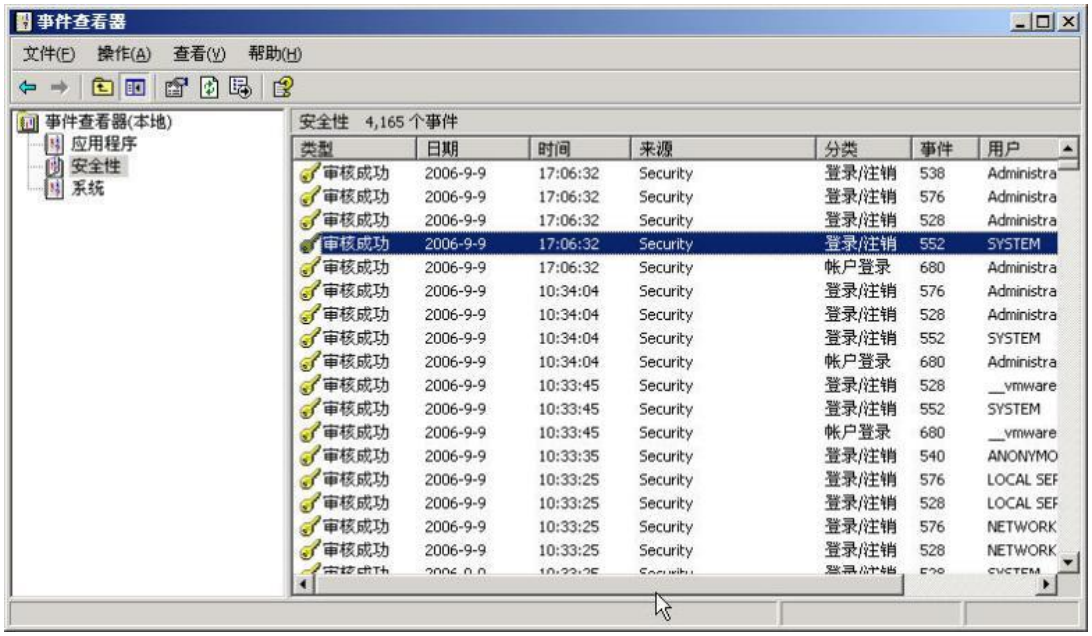


图7-14 Windows系统的日志记录

（2） 目录和文件中的不期望的改变

网络环境中的文件系统包含很多软件和数据文件，保存有重要信息的文件经常是入侵者获取、修改或破坏的目标。目录和文件中的不期望的改变（包括修改、创建和删除），很可能就是一种入侵产生的指示和信号。对于FTP服务器来说，我们会根据不同的用户来对指定的目标分配相应的权限，如果我们给某些用户仅指定了“读取”（read）权限（如图7-15所示），但却发现该用户对应的目录下产生了大量的文件或文件夹，这很可能就是有入侵者行为发生。

另外，出于安全考虑，当我们在网络中共享某些资源时，会在共享名后加“$”符号以对共享资源进行隐藏，这样只有知道完整的共享名称的用户才能访问，如图7-16所示。但是，如果我们发现这些已设置了隐藏的文件夹中突然出现了一些不明的文件，或某些文件被修改，也可能是入侵者所为。

7.3 IDS技术及应用

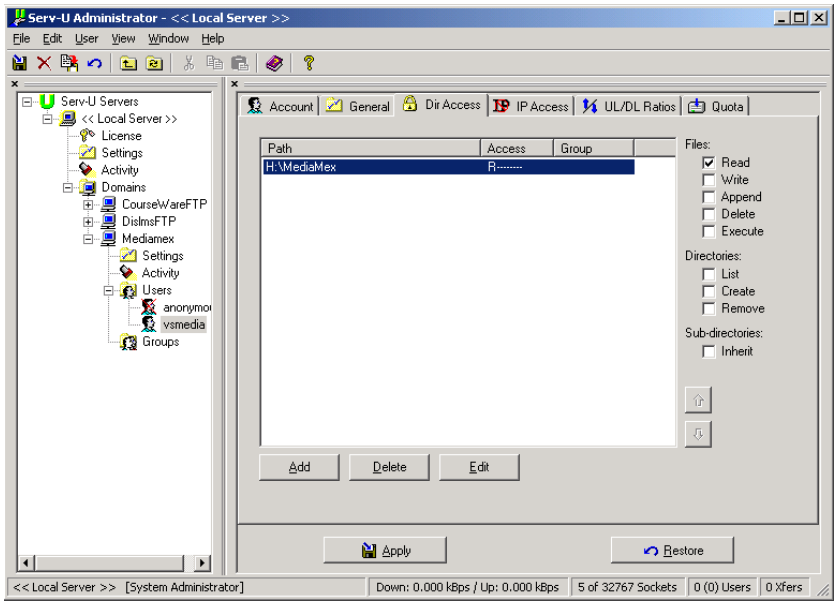


图7-15 对用户的指定目录权设置了“Read”权限



图7-16 对共享文件夹设置隐藏属性

（3） 程序执行中的不期望行为

网络系统上的程序执行一般包括操作系统、网络服务和特定的应用程序。每个在系统上执行的程序对应一到多个进程。每个进程的执行都拥有不同的环境，特殊的环境决定了进程可访问的系统资源（如硬盘空间、外设等）、程序和数据文件等。一个进程的运行由它对应的操作来体现，操作执行的方式不同，利用的系统资源也就不同。操作包括计算、文件传输，以及与网络中其他进程的通信等。一个进程出现了不期望的行为可能表明攻击者正在入侵或用户的系统已被入侵。一般情况下，入侵者在进入用户的系统后，为了安全地运行后门程序，会将该程序运行时进程修改为系统中已有的进程。所以，对于我们熟悉的一些进程的运行状态也要引起网络管理员的关注，当某一进程出现异常（如CPU占用率突然持续保持在较高的水平）时，就要查看该进程提供的服务。

（4） 物理形式的入侵信息

物理形式的入侵包括：一是未授权的对网络硬件连接；二是对物理资源的未授权访问。入侵者会利用各种方法进入用户的网络（一般为内部网络），然后进行各种非法操作，如安装应用软件，修改系统参数，删除用户数据等。例如，现在不少单位和家庭都安装了无线路由器来提供无线上网服务，但大部分用户对无线路由器的用户接入即没有进行用户认证，也没有进行加密，而且大部分还打开了DHCP服务，只要入侵者的无线网卡设置为“自动获取IP”地址，就可以通过无线路由器来访问Internet或公司的内部网络。

7.3.4 IDS的信息分析

IDS对于收集到的各类信息（如系统、网络、数据及用户活动状态和行为等），一般通过三种技术手段进行分析：模式匹配、统计分析和完整性分析。其中前两种方法用于实时的入侵检测，而完整性分析则用于事后分析。

- 1. 模式匹配

模式匹配就是将收集到的信息与IDS数据库中已知的记录进行比较，从而发现违背安全策略的行为，并将此行为确定为入侵或攻击行为。该过程的实现方法多种多样，例如可以通过简单的字符串的匹配来完成，也可以利用复杂的数学算法来进行。一般来说，一种进攻模式可以用一个过程（如执行一条指令）或一个输出（如获得权限）来表示。

模式匹配的最大优点是只需收集相关的数据集合，系统的负担较小，且技术已相当成熟。IDS的模式匹配有些类似于病毒防火墙，只要不断升级各类攻击的数据库，就能够实现较高的检测准确率和效率。但是，模式匹配不能检测到从未出现过的攻击或入侵手段。

- 2. 统计分析

统计分析方法首先给系统对象（如用户、文件、目录和设备等）创建一个统计描述，统计正常使用时的一些测量属性（如访问次数、操作失败次数和延时等）。测量属性的平均值将被用来与网络、系统的行为进行比较，任何观察值在正常值范围之外时，就认为有入侵或攻击发生。例如，对于使用Windows服务器操作系统的企业域用户，可以根据企业内部管理的规定，允许员工在周1到周5的早上8:00至下午6:00登录域控制器来访问企业的内部资源，如图7-17和图7-18所示。如果在如图7-14所示的“事件查看器”中发现有用户在非规定时间频繁地试图登录该域控制器，则可以确定为入侵行为。



图7-17 用户账号的属性设置对话框

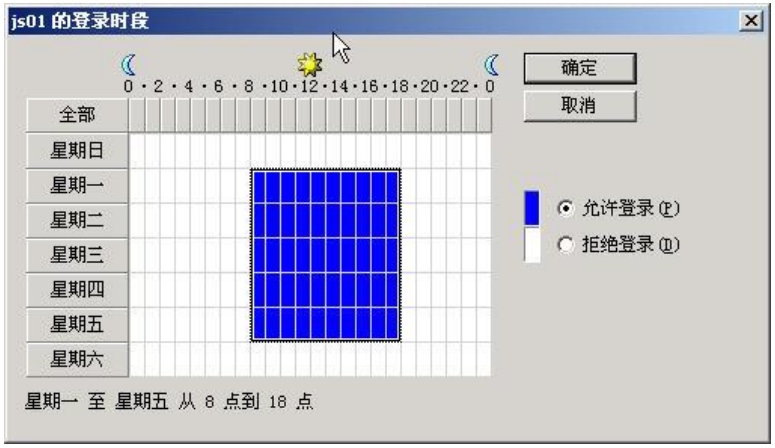


图7-18 设置用户账号的登录时间

统计分析的优点是可检测到未知的或更为复杂的入侵，缺点是误报、漏报率较高，且不适应用户正常行为的突然改变。

- 3. 完整性分析

完整性分析主要关注某个文件或对象是否被更改，可以通过该文件或该文件所在目录的属性来发现。完整性分析利用强有力的加密机制，可以识别微小的变化。完整性分析的优点是不管模式匹配方法和统计分析方法能否发现入侵，只要是成功的攻击导致了文件或其他对象的任何改变，它都能够发现。其缺点是一般以批处理方式实现，不用于实时响应。尽管如此，完整性检测方法还应该是网络安全产品的必要手段之一。例如，可以在每一天的某个特定时间内开启完整性分析模块，对网络系统进行全面的扫描检查。

7.3.5 IDS的主要实现技术

入侵检测技术主要的研究方向是把各个领域的研究成果（如目前的大数据技术、人工智能技术等）应用于入侵检测系统中，更好地与其他各种安全技术逐渐融合。目前，IDS所使用的技术比较多，本节仅介绍几类常见的技术和方法。

- 1. 生物免疫技术

生物体自身的免疫系统主要是保护生物体自身，使其不受外界的病毒或细菌的侵害，其作用与IDS的作用十分接近，他们都属于防御系统。生物体的免疫过程与计算机的入侵检测过程相对照如图7-19所示。

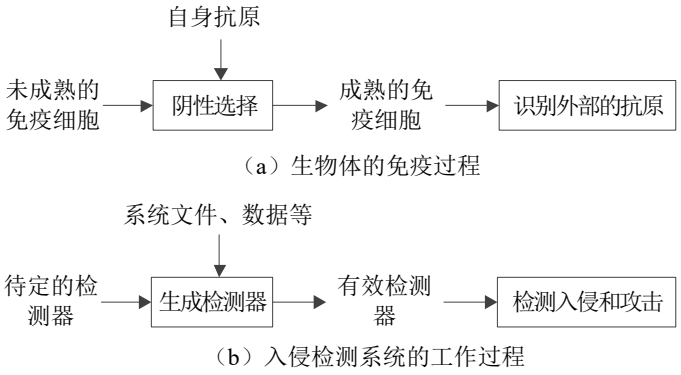


图7-19 生物免疫与IDS对照

基于生物免疫技术的入侵检测系统使用阴性选择算法。该算法的核心是根据对象的特征来进行编码，并产生一系列的检测器，根据阴性选择算法，用该检测器能检测出异常，进而发现入侵和攻击行为。这种入侵检测系统有着较强的学习能力和非常好的自适应能力，利用该系统能检测出许多未知类型的入侵和攻击。

- 2. 分布式协作技术

分布式入侵检测包括两层含义：一是针对分布式的网络入侵行为的检测技术，二是利用分布式的方法检测分布式的攻击。关键的技术是协同处理检测信息，安全地信息共享，有效地提取入侵攻击的有效信息。

一般情况下，分布式的入侵检测系统由5个单元组成：数据采集、通信传输、入侵检测分析、应急处理和管理单元。根据不同的情形，可对这些单元组合。如将数据采集单元和通信传输单元组合，可产生新的单元，新单元能完成数据的采集和传输的任务。按不同的网络配置情况和入侵检测需要，可以将这些单元安装在一台主机上或者分布在网络中的不同位置。基于协议分析技术的分布式检测方法更好地解决了传统入侵检测技术中计算量大、检测效率低等问题。其中，数据采集单元和管理单元功能的实现需要借助安全信息库，三者之间的关系如图7-20所示。

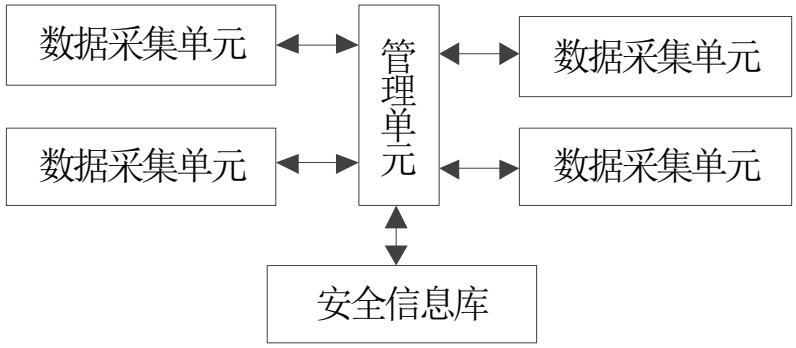


图7-20 分布式入侵检测系统中数据采集单元、管理单元与安全信息库之间的关系

- 3. 数据挖掘技术

数据挖掘是指从数据库中提取出相关的有用的知识，知识一般可表示为概念、规则、规律、模式等形式。用数据挖掘技术处理所搜集到的审计数据，提取相关的知识并形成相应的规则，为正常的操作和各种入侵行为建立精准的行为模式，IDS利用这些行为模式对整个网络进行入侵检测。

基于数据挖掘的实时入侵检测系统由检测引擎、检测器、检测数据库和检测模型组成。其中，检测引擎用来观察原始的数据，并计算用来进行模型评估的特征；检测器用来获取检测引擎的数据，利用检测模型进行判定是否属于攻击；数据库用来存储数据和各种检测的模型。

- 4. 移动代理技术

移动代理技术指的是在网络中的一台主机上运行安全监测和入侵检测的软件，使该主机具备自治、自适应等特性。移动代理技术应用于入侵检测中具有以下的一些特性：多代理合作、网络数据流量低、应对主机间的动态迁移、分布的灵活。

移动代理技术最显著的特点是，主机上自动地运行这些代理，可以从一台主机移动到另外一台主机上工作，并且还能和其他类似的代理进行交流和相互协作。基于代理的入侵检测方法是非常有利的，它允许入侵检测系统提供异常检测和误用检测的混合能力。

7.3.6 IDS部署实例分析

根据IDS信息收集方式的不同，目前的IDS产品也基本上分为基于主机、基于网络和混合型3种类型，其中有些是软件形式（以基于主机的信息收集方式为主），而有些是软件和专用硬件相结合（以基于网络的信息收集方式为主）。下面分别以ISS RealSecure和Cisco IDS为例进行介绍。

- 1. ISS RealSecure的部署

IDS的典型代表是ISS（Internet Security Systems，国际互联网安全系统）的RealSecure，它是一个自动实时的入侵检测和响应系统，它通过监控网络传输并自动检测和响应可疑的行为，在系统受到危害之前截取和响应安全漏洞和内部误用，从而最大限度地为企业网络提供安全保障。RealSecure在网络中的部署如图7-21所示，根据企业网络的特点，可以在每一个网络主干（三层交换机）上安装一个网络传感器（Network Sensor），然后将通过该主干的流量全部镜像到该网络传感器上，再通过RealSecure控制台进行分析。对于小型网络来说，可以仅在中心交换机上安装一个网络传感器即可，如图7-22所示。

7.3 IDS技术及应用

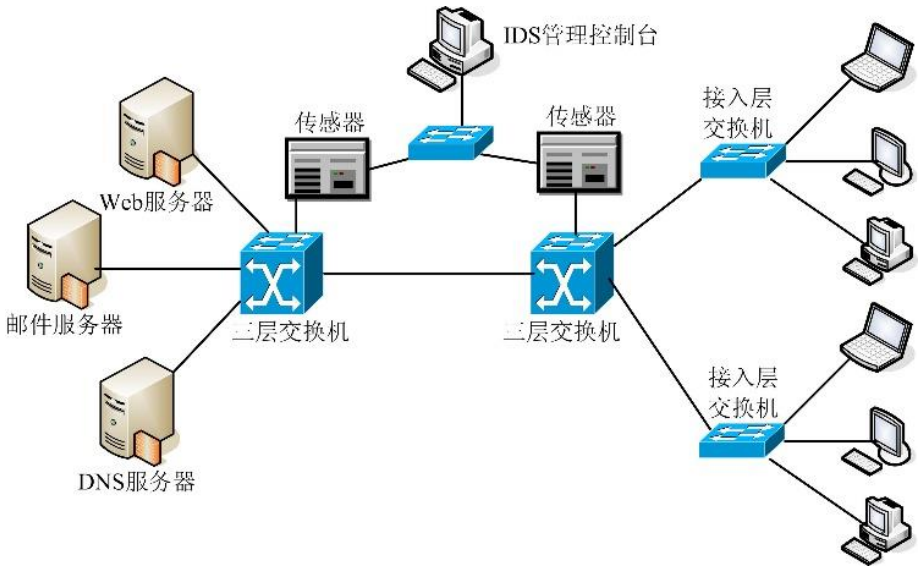


图7-21 IDS在大中型网络中的部署

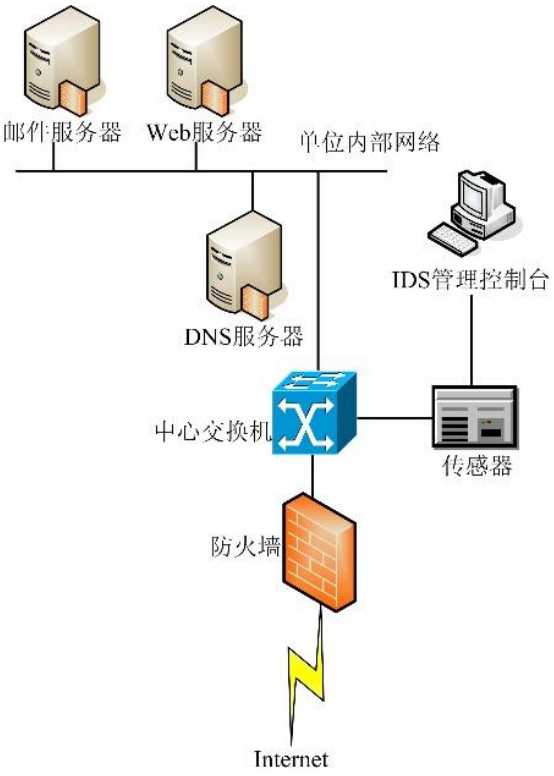


图7-22 IDS在小型网络中的部署

7.3 IDS技术及应用

RealSecure是一种混合型的入侵检测系统，同时提供基于网络和基于主机的实时入侵检测。其控制台可以运行在Windows 2000/2003等操作系统上。RealSecure的传感器是自治的，能被许多控制台控制。其中：

（1）RealSecure控制台。可同时对多台网络传感器和服务器代理进行管理；对被管理传感器进行远程的配置和控制；各个监控器发现的安全事件实时地报告到控制台。

（2）Network Sensor。网络传感器，对网络进行监听并自动对可疑行为进行响应，最大限度保护网络安全；运行在特定的主机上（目前广泛使用的RealSecure 6.x/7.x可运行在UNIX、Linux和Windows 服务器操作系统上），监听并解析所有的网络信息，及时发现具有攻击特征的信息包；检测本地网段，查找每一数据包内隐藏的恶意入侵，对发现的入侵做出及时的响应。当检测到攻击时，网络传感器能即刻做出响应，进行报警/通知（向管理控制台报警、向安全管理员发送E-mail、SNMP trap、查看实时会话和通报其他控制台），记录现场（记录事件日志及整个会话），采取安全响应行动（终止入侵连接、调整网络设备配置，如防火墙、执行特定的用户响应程序）。

（3）Server Sensor。服务器传感器，它属于一种服务器代理，安装在各个服务器（如图7-21和图7-22所示的E-Mail、Web、DNS服务器等）上对主机的核心级事件、系统日志以及网络活动实现实时入侵检测；具有包拦截、智能报警以及阻塞通信的能力，能够在入侵到达操作系统或应用之前主动阻止入侵；自动重新配置网络引擎和选择防火墙阻止黑客的进一步攻击。

- 2． Cisco IDS部署

在网络安全领域中，防火墙就好像是坚固的门锁和窗闩，能够阻挡他人的非法入侵。事实上，好的安全战略也应该使用入侵检测。与安全大厦内的警报器和摄像机相似，IDS警报不但能为警卫提供很多详细信息（包括入侵者进入大厦的方法和目前所在的位置等），还能提供必要的数据，帮助安全管理人员确定快速缉拿入侵者的最佳方式，以及将来怎样预防类似入侵的发生。

Cisco公司的IDS产品多以硬件形式存在，同时Cisco公司不但推出专用的IDS产品（如Cisco-IDS-4200系列），而且还为Cisco交换机、路由器、防火墙开发了专门的硬件模块。只要在这些网络设备上安装相应的模块就可以作为一台网络传感器来使用。同时，Cisco基于主机的代理（Cisco安全代理）可以运行在服务器主机上，为主机提供安全保障。

更值得一提的是，为了同时管理网络中的大量传感器，Cisco公司使用了IDS管理员中心（IDS MC），它能够在一个管理控制台上同时管理几百个传感器。IDS MC是Cisco Works 2000 VPN/安全管理解决方案（VMS）产品的一个组件，可以部署在Windows 2000（Service Pack3及以上版本）及以上版本的操作系统上。

还值得一提的是，在中小型网络中，为了同时监控多个网段，Cisco公司还推出了多监控接口的传感器，在该传感器上提供了多个网络接口，每一个网络接口可以分别连接一个网段，如图7-23所示。需要说明的是，多监控接口从Cisco IDS 4.1版本开始支持。

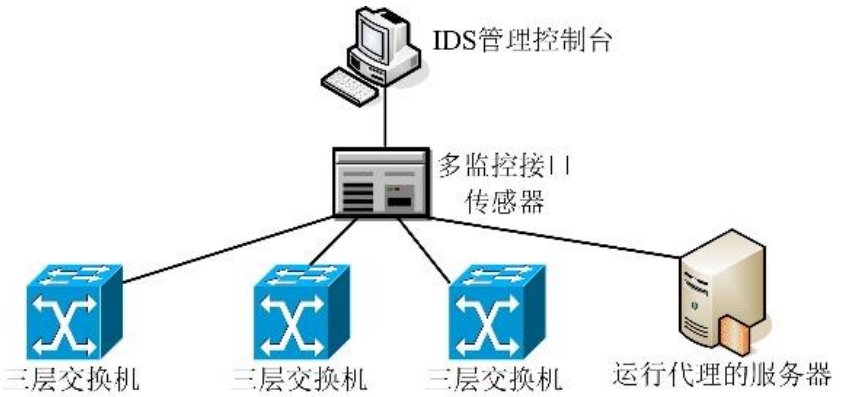


图7-23 使用多监控接口传感器的IDS

7.3.7 IDS的特点

入侵检测被认为是继防火墙之后的第二道安全闸门，它在尽量不影响网络性能的情况下对网络进行监测，从而提供对各类攻击和误操作的实时防范。

7.3 IDS技术及应用

- 1. IDS的特点

入侵检测是防火墙的有机补充，可帮助系统应对网络攻击和入侵，扩展了系统的安全管理手段（包括安全审计、监视、攻击识别和响应等），提高了信息安全基础结构的完整性。它从计算机网络系统中的多个关键点（如路由器、防火墙、服务器等）收集信息，并分析这些信息，再通过一定的措施查看网络中是否有违反安全策略的行为和遭到袭击的迹象。这些功能都是通过IDS执行以下的任务来实现的：

（1）收集、分析用户及系统的各项活动。

（2）对系统构造和弱点的审计。

（3）识别响应已知进攻和入侵的活动模式，并且采取一定的方式通知网络管理人员。

（4）异常行为模式的统计分析。

（5）评估重要系统和数据文件的完整性。

（6）操作系统的审计跟踪管理，并识别用户违反安全策略的行为。

对一个成熟的IDS来讲，它不但可使系统管理员时刻了解网络系统（包括程序、文件和硬件设备等）的任何变更，还能给网络安全策略的制订提供帮助和指南。更为重要的一点是：它的配置、使用和管理应用简单明了，适应大量的非专业人员使用。另外，入侵检测的规模还应根据网络所受到的威胁、系统构造和用户的安全需求的改变而适时地进行改变。同时，IDS在发现入侵后，能够及时作出响应，包括切断网络连接、记录事件和报警等。

- 2. IDS存在的不足

入侵检测系统（IDS）存在的不足为：

（1）在无人干预的情况下，无法执行对攻击的检查。

（2）无法感知单位内部网络安全策略的内容。

（3）不能弥补网络协议的漏洞。

（4）不能弥补系统提供的原始信息的质量缺陷或完整性问题。

（5）不能分析网络繁忙时所有的事务。

（6）不能总是对数据包级的攻击进行处理。

（7）不能应付现代网络的硬件及特性。

入侵检测作为一种积极主动的安全防护技术，提供了对内部攻击、外部攻击和误操作的实时保护，在网络系统受到危害之时拦截和响应入侵。

7.4 IPS技术及应用

7.4 IPS技术及应用

安全防护是一个多层次的保护机制，它一方面包括网络的安全策略（相关的安全管理制度、系统安全策略的运行等），又包括防火墙、防病毒、入侵检测系统等产品的部署和应用，同时还根据技术的发展，在继IDS后推出了IPS（Intrusion Protection System，入侵防御系统）。由此可见，为了保障网络安全，还必须建立一套完整的安全防护体系，进行多层次、多手段的检测和防护。IPS正是构建安全防护体系不可缺少的一个环节。

7.4.1 IPS的概念

IPS是继IDS之后发展起来的一项新型技术，它在继承了IDS优势的同时，避免了IDS存在的一些不足，适应了现代计算机网络对安全的要求。

IPS是一种主动的、智能的入侵检测和防御系统，其设计目的主要是预先对入侵活动和攻击行为的网络流量进行拦截，避免造成损失。IDS以关联方式部署在不同的服务器和网段上，先将服务器或网段上的流量镜像到网络传感器上，再通过IDS管理控制台进行分析，如果发现入侵或攻击，则会产生报警，IDS在网络中的部署方式如图7-24所示。与IDS对比，IPS最大的不同是IPS以串联的方式部署在网络的进出口处，像防火墙一样，它对进出网络的所有流量进行分析，当检测到有入侵或攻击企图后，会自动将相应的数据包丢弃，或采取相应的措施将攻击源阻断，IPS在网络中的部署方式如图7-25所示。

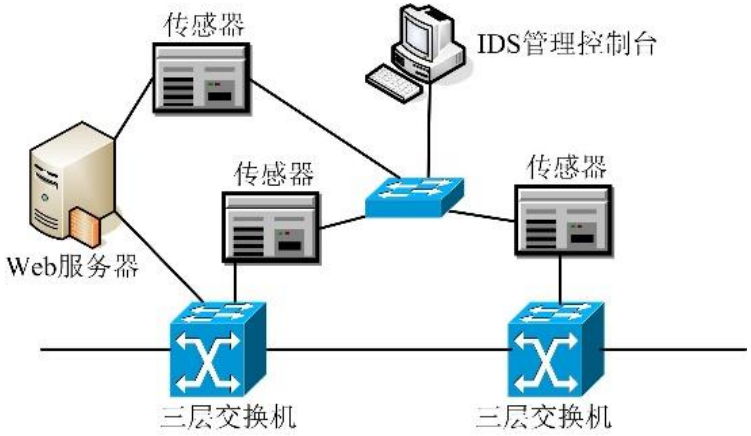


图7-24 IDS在网络中的部署方式

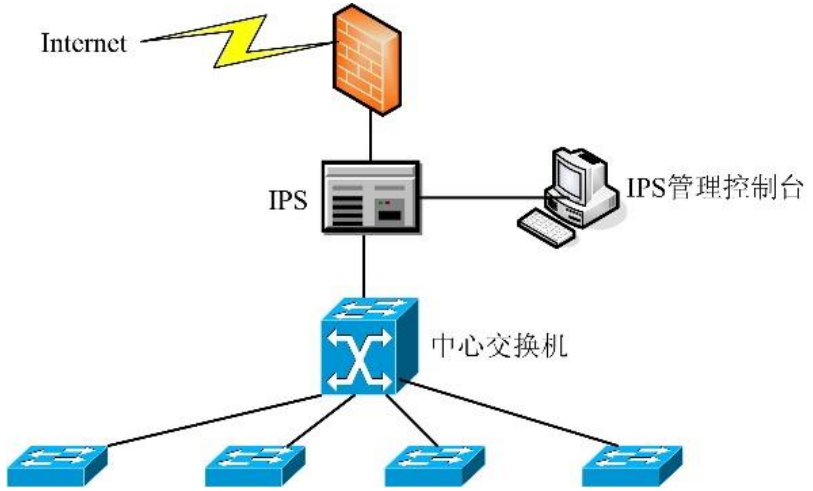


图7-25 IPS在网络中的部署方式

7.4 IPS技术及应用

在介绍IPS时，我们不得不提到防火墙和IDS。防火墙是实施访问控制策略的系统，对流经网络的流量进行检查，拦截不符合安全策略的数据包。同时，传统的防火墙只能对OSI参考型第三层（网络层）和第四层（传输层）的数据单元进行检查，不能检测应用层的内容，而且防火墙的包过滤技术不会针对每一个字节进行检查，因而也就无法发现攻击活动。所以，防火墙的主要功能是拒绝那些明显可疑的网络流量，但仍然允许某些流量通过，因此防火墙对于大部分入侵攻击仍然无能为力。

IDS通过监视网络或系统资源，寻找违反安全策略的行为或攻击迹象，并发出报警。IDS从工作方式来看基本上是被动的，在攻击或入侵实际发生之前，IDS往往无法预先发出报警。而IPS则倾向于提供主动防御，其设计目的是预先对入侵活动和攻击性网络流量进行拦截，避免其造成损失，而不像IDS那样简单地在恶意流量传送时或传送后才发出警报。IPS是通过直接嵌入到网络流量中实现这一功能，即通过一个网络端口接收来自外部系统的流量，经过检查确认其中不包含异常活动或可疑内容后，再通过另外一个端口传送到内部系统中。这样一来，有问题的数据包，以及所有来自同一数据流的后续数据包，都能在 IPS 设备中被清除掉。

7.4 IPS技术及应用

IPS实现实时检查和阻止入侵的原理在于IPS拥有数目众多的过滤器，能够防止各种攻击。当新的攻击手段被发现之后，IPS就会创建一个新的过滤器。所有流经IPS的数据包都被分类，分类的依据是数据包的头部信息，如源IP地址、目的IP地址、端口号和应用域等。每种过滤器负责分析相对应的数据包。通过检查的数据包可以继续往前发送，包含恶意内容的数据包就会被丢弃，被怀疑的数据包需要接受进一步的检查。

IPS应具有以下的技术特征：

（1）嵌入式运行。只有以嵌入模式运行的IPS设备才能够实现实时的安全防护，实时阻断所有可疑的数据包，并对该数据流的剩余部分进行拦截。

（2）深入分析和控制。IPS必须具有深入分析能力，以确定哪些流量已经被拦截，并能够根据攻击类型、策略等来确定哪些流量应该被拦截。

（3）入侵特征库。与防病毒系统的病毒库一样，较为完整的高质量的入侵特征库是IPS高效运行的必要条件。当我们在选择一款IPS产品时，除考虑其硬件性能和所采用的技术等指标外，还要重点考虑IPS入侵特征库的升级等问题。

（4）高效处理能力。IPS必须具有对数据包的高效处理能力，争取对整个网络性能的影响降至最低水平，避免IPS成为网络的瓶颈。

7.4.2 IPS的分类

IPS根据部署方式的不同，分为基于主机的入侵防御系统（Host IPS，HIPS）、基于网络的入侵防御系统（Network IPS，NIPS）和应用入侵保护（Application Intrusion Prevention，AIP）3种类型。

- 1. 基于主机的入侵防御

基于主机的入侵防御（HIPS）通过在服务器等主机上安装代理程序来防止对主机的入侵和攻击，保护服务器免受外部入侵或攻击。HIPS可以根据自定义的安全策略以及分析学习机制来阻断对服务器等主机发起的恶意入侵，HIPS可以阻断缓冲区溢出、更改登录口令、改写动态链接库以及其他试图获得操作系统入侵权的行为，加强了系统整体的安全性。

HIPS利用由包过滤、状态包检测和实时入侵检测组成的分层防护体系，不但能够阻止诸如缓冲区溢出这一类的已知攻击，还能够防范未知攻击，防止针对Web页面、应用系统和资源的未授权的任何非法访问，提供对主机整体的保护。它能够在满足网络实际吞吐率的前提下，最大限度地保护主机的敏感内容，既可以以将相关软件嵌入到应用程序对操作系统的调用中来拦截针对操作系统的可疑调用，提供对主机的安全防护，也可以更改操作系统内核程序的方式，提供比操作系统更加严谨的安全控制机制。HIPS与具体的主机或服务器上所运行的操作系统紧密相关，不同的操作系统需要不同的代理程序。

- 2. 基于网络的入侵防护

基于网络的入侵防护（NIPS）通过检测流经的网络流量，提供对网络系统的安全保护。与IDS的并联方式不同，由于IPS采用串联方式，所以一旦检测出入侵行为或攻击数据流，NIPS就可以去除整个网络会话。另外，由于IPS以串联方式接入整个网络的进出口处，所以NIPS的性能也影响着整体网络的性能，NIPS有可能成为整个网络的瓶颈。为此，对NIPS的硬件组成和处理能力就提出更高的要求。

除在硬件上为NIPS提供保障外，还需要从实现技术上寻找突破。NIPS吸取了目前几乎IDS所有的成熟技术，包括特征匹配、协议分析和异常检测等。其中，特征匹配具有准确率高、速度快等特点，是应用最为广泛的一项技术。基于状态的特征匹配不但检测攻击行为的特征，还要检查当前网络的会话状态，避免受到欺骗攻击。协议分析是一种较新的入侵检测技术，它充分利用网络协议的特征，并结合高速数据包捕捉和协议分析技术，来快速检测某种攻击特征。协议分析能够理解不同协议的工作原理，以此分析这些协议的数据包，来寻找可疑或不正常的访问行为。

- 3. 应用入侵防护

应用入侵防护（AIP）是NIPS产品的一个特例，它把NIPS扩展成为位于应用服务器之前的网络设备，为应用服务器提供更安全的保护。AIP被设计成一种高性能的设备，配置在特定的网络链路上，以确保用户遵守已设定好的安全策略，保护服务器的安全。而NIPS工作在网络上，直接对数据包进行检测和阻断，与具体的服务器或主机的操作系统平台无关。

7.4.3 IPS的发展

IDS入侵检测系统一直以来充当了安全防护系统的重要角色。IDS技术是通过从网络上获取数据包后进行分析，从而检测和识别出系统中的未授权或异常现象。IDS注重的是网络监控、审核跟踪，告知网络是否安全，发现异常行为时，自身不作为，而是通过与防火墙等安全设备联动的方式进行防护。目前，IDS是一种受到企业欢迎的解决方案，但其存在以下几个显著缺陷：一是部署过程复杂；二是误报率高；三是自身防攻击能力较差，等等。

以上现象的存在，是因为绝大多数IDS系统都是被动的，而不是主动性的。在攻击实际发生之前，IDS往往无法预先发出报警。IPS则倾向于提供主动性的防护，其设计目的为预先对入侵活动和攻击性网络流量进行拦截，避免其造成损失，而不是简单地在恶意流量传送时或传送后才发出报警。目前，集病毒、木马、入侵、攻击等为一体的混合威胁不断发展，所以单一的防御措施已经无能为力，企业需要对网络进行多层、深层的防护来有效保证其网络安全。真正的深层防护体系不仅能够发现恶意代码，而且还能够主动地阻止恶意代码的攻击。在当前混合威胁泛滥的情况下，只有深层防御才可以确保网络的安全。IPS在深层防御保护方面具有一定的技术优势。

但是有专家认为，入侵防护应该是由多种安全设备组成的安全体系共同来实现，而不是由IPS单独来完成，IPS只是主动防御的一部分，而不是主动防御的全部。主动防御系统还需要加入应用级防火墙与应用级IDS，应用级的IDS产品能够重组信息流，跟踪应用会话过程，并准确描述和识别攻击，而应用级的防火墙能够阻断向应用层发起的攻击，保护Web应用。

所以，从较长的一段时间来看，IPS还不可能完全取代IDS和防火墙产品，IPS还有许多不够完善的地方主要有：单点故障、性能瓶颈、误报和漏报等。这是由于IPS必须串联到网络中，这就可能造成网络瓶颈或单点故障。如果IDS出现故障，最坏的情况也就是造成某些攻击无法被检测到，而串联式的IPS设备出现问题，就会严重影响网络的正常运转，甚至造成所有用户都将无法访问企业网络提供的服务。即使正常使用的IPS设备也仍然是一个潜在的网络瓶颈，串联到网络中的IPS不仅会增加正常的响应时间，而且会降低网络的效率，IPS必须与数千兆或者更大容量的网络流量保持同步，尤其是当加载了数量庞大的检测特征库时，设计不够完善的IPS设备将很难支持这种响应速度，这就为IPS设备的制造技术和成本提出了更高的要求。

针对以上问题，IPS厂商纷纷采用各种方式加以解决。例如，综合应用多种检测技术，采用专用硬件加速系统来提高IPS的运行效率，等等。不过，需要说明的是：因为网络威胁的多样性和综合性已越来越突出，所以IPS的不足并不会成为阻止人们使用IPS的理由。在众多的安全产品中，入侵防御系统的重要性会不断被用户所认可。

由于IPS技术还处于快速的发展阶段，相应的网络应用目前还较少。为此，本章仅介绍了IPS的相关概念和技术优势，对IPS感兴趣的读者可关注其发展。

7.6 Web应用防火墙

7.6 Web应用防火墙



基于HTTP/HTTPS协议的Web技术推动了互联网的发展，目前Web应用已成为互联网应用的主流，与此同时Web应用安全也成为大家普遍关注的问题。

7.6.1 Web应用安全概述

随着互联网技术的飞速发展，基于Web和数据库结合的B/S架构已经广泛应用于企业内部和外部的业务系统中，Web系统发挥着越来越重要的作用。与此同时，越来越多的Web系统也因为存在安全隐患而频繁遭受到各种攻击，导致Web系统敏感数据、页面被篡改、甚至成为传播木马的傀儡，给更多访问者造成伤害，带来严重的安全威胁。

7.6 Web应用防火墙

- 1. Web应用攻击

虽然通过运行各类安全措施有效加强了对网络的安全管理，但是传统的安全防护方式无法完全应对针对Web应用的网络攻击。尤其是近年来随着Web应用的深入普及，Web应用程序漏洞发掘和攻击速度越来越快，基于Web漏洞的攻击更容易被利用，已经成为互联网安全的最大隐患。据统计，目前对网站的成功攻击中，超过70%是基于Web应用层，而非传统的网络层。例如，在最近OWASP（Open Web Application Security Project，开放式Web应用程序安全项目）机构发布的全球网络安全威胁中，排名最前面的是SQL注入和XSS攻击（Cross Site Scripting，跨站脚本攻击），成为目前存在最为普遍、利用最为广泛、造成危害最为严重的两类Web威胁。

7.6 Web应用防火墙

一般情况下，攻击者采用以下两种方式实施对Web系统的攻击。

（1）篡改Web系统数据。攻击者通过SQL注入等方式，利用Web应用程序漏洞获得Web系统权限后，可以进行网页挂马、网页篡改、修改数据等操作。例如，攻击者可以通过网页挂马，利用被攻击的Web系统作为后续攻击的跳板，致使更多用户受害；也可以通过网页篡改，丑化Web系统所有者的声誉甚至造成政治影响；还可以通过修改Web系统敏感数据，直接达到获取利益的目的。

7.6 Web应用防火墙

SQL注入：

1. SQL注入概念及产生原因：

当web应用向后台数据库传递SQL语句进行数据库操作时，如果对用户输入的参数没有经过严格的过滤处理，那么攻击者就可以构造特殊的SQL语句，直接输入数据库引擎执行，获取或修改数据库中的数据。关键点：（a）用户能控制输入的内容； (b) web应用把用户输入的内容带入到数据库执行。

2. SQL注入的本质：

把用户输入的数据当作代码来执行，违背了“数据与代码分离”的原则

3. 例子

SELECT * FROM admin WHERE Username='user' and Password='pass'

万能pass：'or '1' = '1' #

4. 工具 sqlmap，https://github.com/sqlmapproject/sqlmap

7.6 Web应用防火墙

文件上传漏洞：

文件上传漏洞是指由于程序员在对用户文件上传部分的控制不足或者处理缺陷，而导致的用户可以越过其本身权限向服务器上上传可执行的动态脚本文件。这里上传的文件可以是木马，病毒，恶意脚本或者WebShell等。“文件上传”本身没有问题，有问题的是文件上传后，服务器怎么处理、解释文件。如果服务器的处理逻辑做的不够安全，则会导致严重的后果。

文件上传漏洞需满足的条件：首先，上传的文件能够被web容器解释执行。所以文件上传后所在的目录要是web容器所覆盖到的路径其次，用户能够从web访问这个文件。如果文件上传了，但用户无法通过web访问，或者无法得到web容器解释这个脚本，那么也不能称之为漏洞。最后，用户上传的文件若被安全检查、格式化、图片压缩只等功能改变了内容，则也可能导致攻击不成功。

文件上传漏洞利用方式：

文件上传漏洞产生的原因：一些web应用程序中允许上传图片，文本或者其他资源到指定的位置，文件上传漏洞就是利用这些可以上传的地方将恶意代码植入到服器中，再通过 url 去 访问以执行代码。

1.服务器配置不当（例如.htaccess配置可执行）

2.开源编辑器上传漏洞（ckeditor,fckeditor）

3.本地文件上传限制被绕过（js,%00,文件头等）

4.过滤不严格被绕过（黑名单，白名单）

5.文件解析漏洞导致文件执行（IIS6:xxx.asp/1.jpg, Fast-CGI 1.jpg/1.php,1.php.xx.yy）

其他各类绕过方法，大小写，%00截断，分号单引号等等……

工具：BurpSuite

其他攻击手段：

非法命令执行：Web程序未对命令执行接口数据有效规范，造成恶意命令执行

逻辑漏洞：购买 -1 个商品

……

一般情况下，攻击者采用以下两种方式实施对Web系统的攻击。

（2）窃取用户信息。利用Web应用程序漏洞，构造特殊网页或链接引诱Web系统管理员、普通用户点击，以达到窃取用户数据的目的。例如游戏、网银、论坛等账号的窃取，大多是利用了Web系统的XSS漏洞实现的。

7.6 Web应用防火墙

1. XSS 漏洞的定义
跨站脚本（Cross Site Script）通常发生在客户端，攻击者在 Web 页面中插入恶意 JavaScript 代码（也包括 VBScript 和 ActionScript 代码等），用户浏览此页面时，会执行这些恶意代码，从而使用户受到攻击。

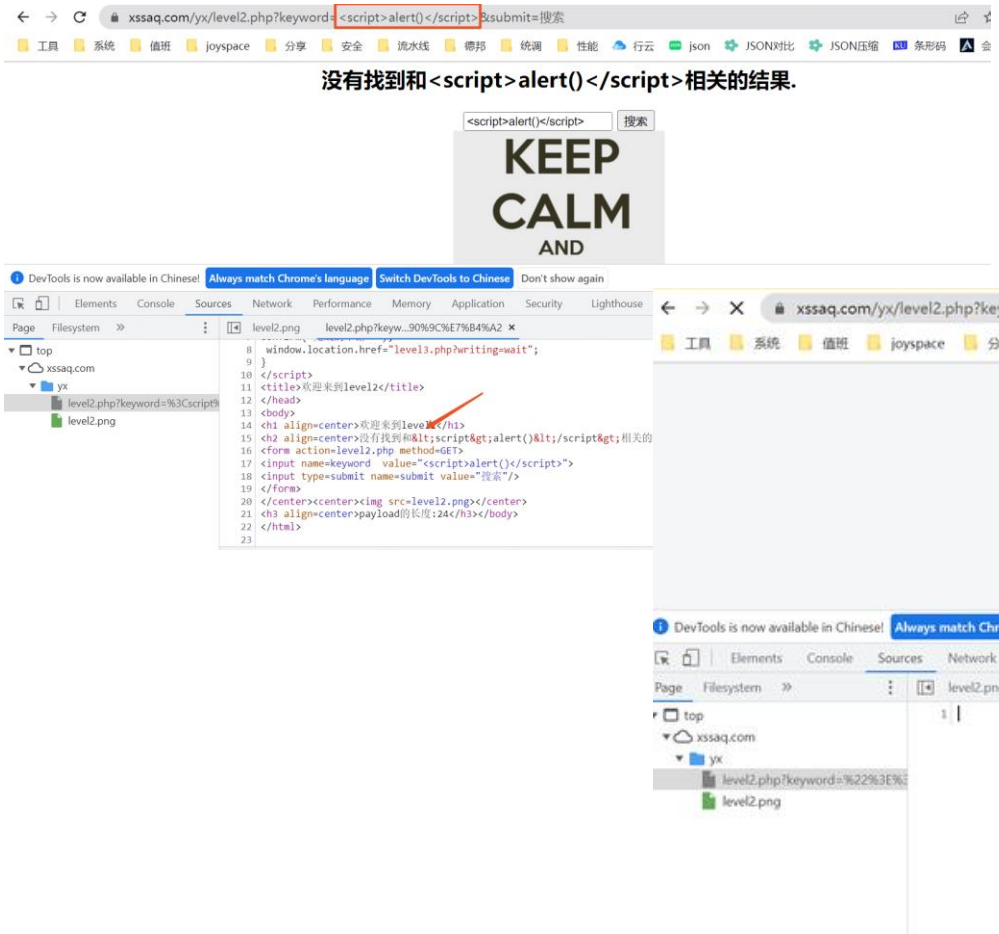
2.XSS 主要攻击形式
存储型跨站脚本攻击：攻击者利用应用程序提供的添加、修改数据功能，将恶意数据存储到服务器中，当其他用户浏览展示该数据的页面时，浏览器会执行页面嵌入的恶意脚本，从而达到恶意攻击的目的，这种攻击是持久化的。

反射型跨站脚本攻击：攻击者发送一个 URL 给用户并诱导其访问，浏览器会执行页面嵌入的恶意脚本，从而达到恶意攻击的目的，这种攻击只执行一次，是非持久化的。

DOM 跨站脚本攻击：在 Html 页面中，未通过规范 JavaScript 直接操作用户输入的数据，当攻击者插入一段恶意代码，在页面最终展示会执行恶意脚本，从而达到恶意攻击的目的。

3.XSS 漏洞危害
信息窃取（如盗取用户 cookie，伪造用户身份登录）
钓鱼欺诈
蠕虫攻击

7.6 Web应用防火墙



预防：HTML转义，内容安全策略（CSP）

其他攻击手段：

文件包含漏洞：和SQL注入只等攻击方式一样，文件包含漏洞也是一种注入型漏洞，其本质就是输入一段用户能够控制的脚本或者代码，并让服务端执行。以PHP为例，我们常常把可重复使用的函数写入到单个文件中，在使用该函数时，直接调用此文件，而无需再次编写函数，这一过程叫做包含。

有时候由于网站功

```php
<?php
    include $_GET['test'];
?>
```

来让后台执行任意

含函数有以下四种





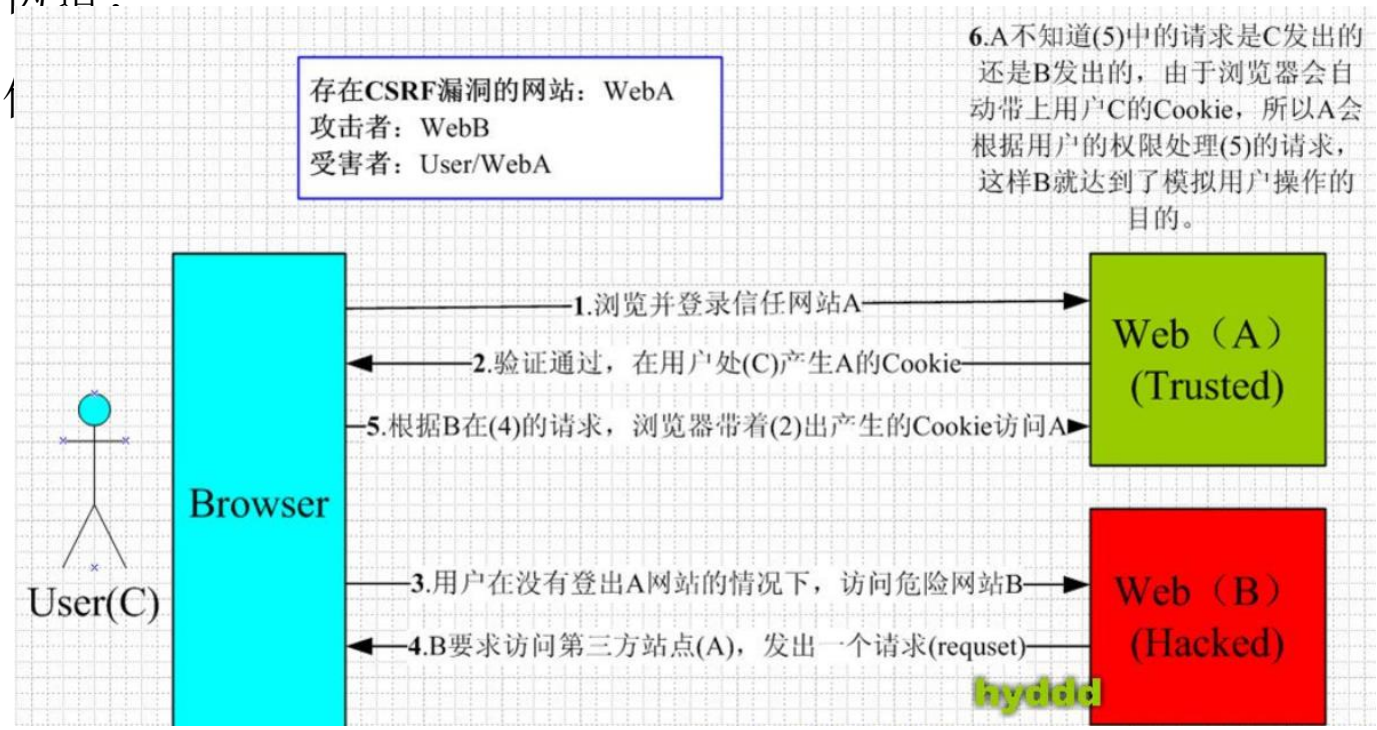
equire_once()。

其他攻击手段：

CSRF跨站请求伪造：

根据攻击者的指令

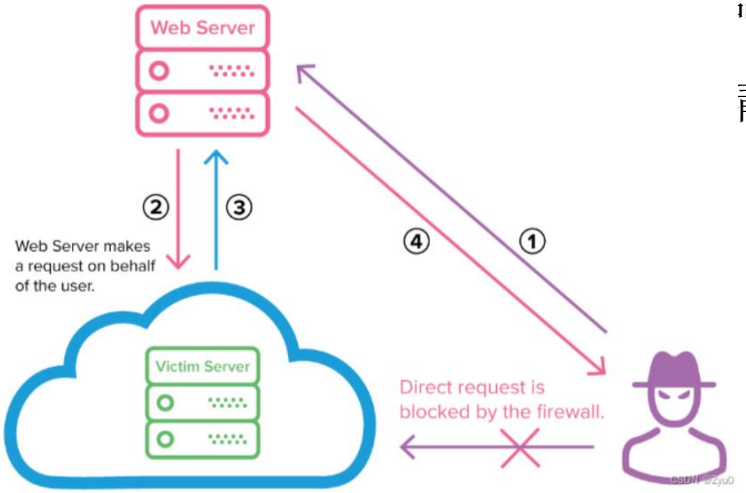
问请求



其他攻击手段：

SSRF服务器端请求伪造：在典型的 SSRF 场景中，想要访问内部服务器的外部攻击者无法使用直接请求，因为它们会被防火墙阻止。相反，恶意行为者可以利用 SSRF 漏洞通过易受攻击的 Web 服务器进行攻击:1.攻击者向易受 SSRF 攻击且与目标服务器位于同一内部网络的 We 服务器发送伪造请求2.易受攻击的 Web 服务器将攻击者控制的请求发送到受害者的服务器，青求的数据响应网络服务器4.如果特定的 SSRF

在大多数情况下，攻击者需要通过其他方式(带



7.6.3 Web应用防火墙技术

事实表明，针对复杂网络环境下Web应用系统存在的安全问题，需要变被动应对为主动关注，实施积极防御，这就需要以一个全新的视角看待Web应用系统的安全，并依托相关技术之间的关联互动，加强对Web应用系统的安全管理。

7.6 Web应用防火墙

- 1. Web应用防火墙的工作原理

面对Web应用的攻击，最关键的就是有效的检测防护机制。针对此现象，可以通过Web应用安全网关等设备加强对Web系统的安全防护，对SQL注入、XSS攻击等针对应用层的攻击进行防护。并针对Web应用访问进行各方面优化，以提高Web或网络协议应用的可用性，确保业务应用能够快速、安全、可靠地交付。实现这些安全管理功能的技术和产品便是Web应用防火墙（Web Application Firewall，WAF），WAF的主要工作流程如图8-10所示，其主要功能介绍如下。

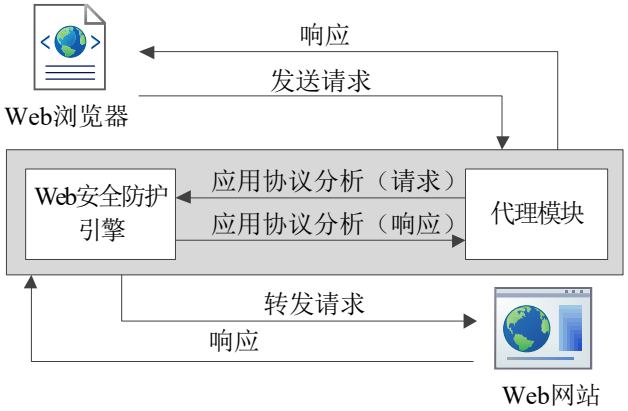


图8-10 WAF的主要工作流程

7.6 Web应用防火墙

（1）WAF旨在保护Web应用程序免受常见攻击的威胁，通过分析应用层的流量以发现任何违背安全策略的安全问题。

（2）WAF在网络中一般位于Web应用服务器前端，用于保护防火墙之后的应用服务器。它提供的功能可能包括服务器之间的流量负载均衡、压缩、加密，HTTP/HTTPS流量的反向代理，检查应用程序的一致性和汇聚TCP会话等。

如图8-10所示，可将WAF的工作原理描述为：Web应用客户端（Web浏览器）向Web网站发起访问请求，该请求报文没有直接发送到Web网站，而是先提交给一个代理模块，由该代理模块将该请求报文转发给Web安全防护引擎进行协议分析，之后再将该请求报文转发给Web网站；Web网站接受Web请求，并进行响应回复，该响应报文首先在Web安全防护引擎上进行安全性分析，之后再由代理模块转发给Web应用客户端。在以上操作过程中，主要体现WAF功能的代理模块和Web安全防护引擎中断了Web应用客户端与Web网站之间的直接连接，其目的是对往来的数据包进行安全性分析。在整个工作过程中，对于Web应用客户端和Web网站来说，WAF的存在是透明的。

（3）WAF是保护Web应用程序的常用手段，但WAF防火墙失效或被未知攻击手段绕过时，其无法特别有效的保障Web应用程序所在运行环境的安全性。因为当WAF失效导致攻击者利用Web应用程序攻击时，可能会获取其所在运行环境的访问权限，严重时可能使得管理者失去对运行环境（如操作系统）的控制权。

此时，可以考虑使用**隔离机制的安全沙箱如Docker或虚拟机**作为Web应用程序的容器。即使WAF失效导致运行环境受到攻击，攻击者所攻击的也仅仅是沙箱虚拟环境，不会对物理运行环境造成影响。虽然隔离沙箱也有可能被攻击者攻破，但相较于WAF而言其实施难度极大，所以隔离沙箱可以和WAF组成Web应用程序的双重保护。

9.3 实现VPN的第二层隧道协议

9.3 实现VPN的第二层隧道协议

第二层隧道协议是在OSI参考模型的第二层（数据链路层）实现的隧道协议。由于数据链路层的数据单位为帧，所以第二层隧道协议是以帧为数据交换单位来实现的。用于实现VPN的第二层隧道协议主要有PPTP、L2TP和L2F。

在具体介绍相关协议之前，需要对第二层协议的功能进行说明。第二层协议的实现依靠的是设备的物理地址（如网卡的MAC地址），负责在两个直连的设备之间进行数据交换。所以，下面所介绍的第二层隧道协议都是一种以物理寻址为基础的点对点的数据传输方法。



9.3.1 PPTP

PPTP（Point-to-Point Tunneling Protocol，点对点隧道协议）是建立在PPP（Point-to-Point）协议和TCP/IP协议之上的第二层隧道协议。PPTP实际上是对PPP协议的一种扩展，它在PPP的基础上增强了认证、压缩、加密等功能，提高了PPP协议的安全性。PPTP协议是一个第二层的隧道协议，它提供了PPTP客户端与PPTP服务器之间的加密通信，允许在公共IP网络（如Internet）上建立隧道。PPTP支持TCP/IP、IPX/SPX、Appletalk、NetBEUI等多种网络协议。

- 1. PPP

由于PPTP是在PPP基础上发展起来的，所以在介绍PPTP之前对PPP进行简要的介绍。PPP是Internet中使用的一个点对点的数据链路层协议，其目的是在TCP/IP网络中的一个物理节点实现对上层数据（IP数据报）的封装，然后通过已确定的物理链路将封装后的数据发送到下一个物理节点。在下一个物理节点进行解封装操作后，将封装前的数据（IP数据报）提供给该节点的上一层（网络层）进行处理。为此，PPP的主要功能是在TCP/IP网络中实现两个相邻物理节点（路由器或计算机）之间的通信，它只负责在两个物理节点之间“搬运”上层数据，并不关心上层数据的具体内容。

- 2． PPTP的工作过程

微软公司是PPTP协议的主要发起者，所以Windows系统操作系统都支持PPTP协议。PPTP中创建的隧道属于主动式隧道，一般由PPTP客户机发起隧道建立连接请求，在得到PPTP服务器认证后才能建立隧道。

PPTP提供了在IP网络中建立多协议的安全VPN的通信方式，远端用户能够通过任何支持PPTP的ISP访问企业内部网络。PPTP提供了PPTP客户机与PPTP服务器之间的安全通信。其中，PPTP客户机是指运行PPTP协议的计算机，而PPTP服务器是指运行PPTP协议的服务器。通过PPTP，客户机可以采用PSTN、ISDN、xDSL、以太网、无线等连接，以拨号方式接入公共IP网络。拨号客户机首先按正常的网络接入方式拨号到ISP的网络接入服务器（NAS），建立PPP连接；在此基础上，客户机进行第二次拨号建立到PPTP服务器的连接，该连接称为PPTP隧道。PPTP隧道实质上是基于IP协议的另一个PPP连接，其中IP数据报可以封装成TCP /IP、IPX/SPX、NetBEUI等多种协议数据。如果客户机是直接接入到本地局域网，而且本地局域网已连接到IP网络，这时客户机则不需要第一次的PPP拨号连接，可以直接与PPTP服务器建立隧道。

9.3 实现VPN的第二层隧道协议

对于基于PPTP的VPN而言，由于客户机是通过拨号方式接入到VPN服务器，所以该VPN服务器也称为VPDN（Virtual Private Dial-up Network，虚拟专用拨号网）服务器。下面以Windows操作系统为例，介绍基于PPTP协议的VPN的实现过程。如图9-7所示，基于PPTP协议的VPN是一种客户机/服务器（Client/Server）的结构，包括PPTP服务器（VPDN服务器）和PPTP客户机两部分。具体工作过程如下：

（1）发送建立连接请求。在此之前，需要在VPDN服务器端为PPTP客户机建立好用户账户（包括登录账号和对应的密码）。PPTP客户机向VPDN服务器发起连接请求，具体可利用客户端VPN连接软件来实现（Windows操作系统自带）。在输入VPDN服务器的IP地址后，首先要将登录账号和密码发送到VPDN服务器端进行用户认证，以防止非法用户侵入受保护的内部网络。

其中，PPTP用户的认证可以使用多种方法，如PAP、SPAP、CHAP、MS-CHAP、EAP等。

（2）返回连接完成信息。当VPDN服务器验证了用户的合法性后，返回连接完成信息，表示已经正式建立了VPN连接。

（3）进行数据传输（至VPDN服务器端）。在接收到连接完成信息后，表示VPN安全隧道已经建立，这时就可以进行正常的数据通信。在VPN客户机与VPDN服务器之间进行数据通信时，为了保证数据传输的安全性，可以选用MPPE、RSA 、DES等算法对IP数据报进行加密。其中，在Windows操作系统中多使用微软公司自己的MPPE（Microsoft Point-to-Point Encryption，微软点对点加密）算法进行数据的加密处理。

（4）进行数据传输（至目的主机）。当VPDN服务器接收到远程用户机发送过来的PPTP数据报后开始对其进行处理。首先进行解封装操作，从PPTP数据报中取出本地内部网络中的计算机的IP地址（私有IP地址）或计算机名称信息，然后根据此信息将其中的PPP数据报转发到目的主机。

9.3 实现VPN的第二层隧道协议

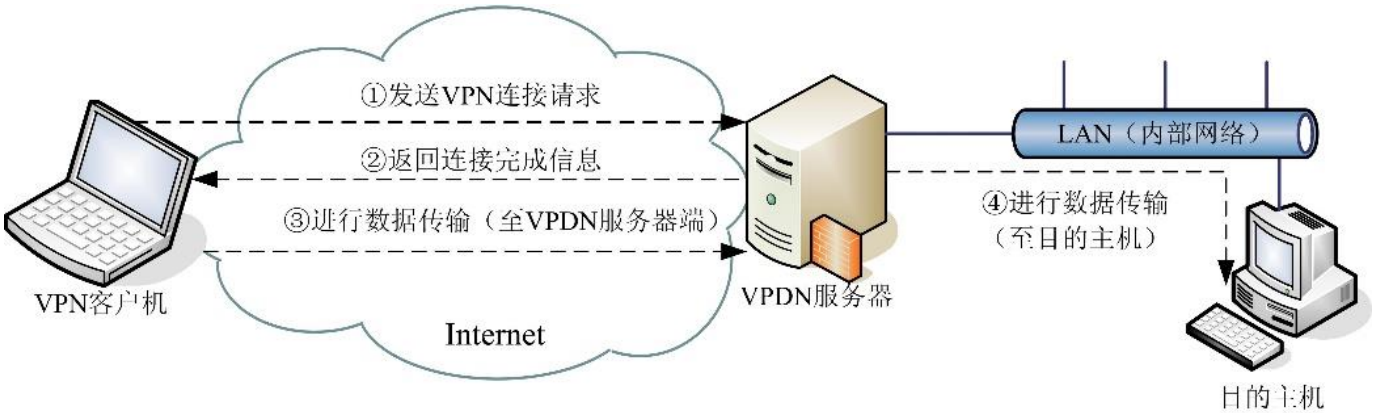


图9-7 基于PPTP隧道的VPN的工作示意图

- 3． PPTP的报文格式

在PPTP客户机与PPTP服务器之间传输的报文分为两种类型：控制报文和数据报文。

（1）PPTP控制报文。PPTP控制报文负责PPTP隧道的建立、维护和断开。当PPTP客户机通过第一次拨号建立了与IP网络的连接后，再通过第二次拨号建立与PPTP服务器的隧道连接。其中，第二次拨号通过PPTP客户机上的PPTP拨号软件（使用TCP动态端口）与PPTP服务器的TCP 1723端口建立控制连接。PPTP控制报文的结构如图9-8（a）所示，其中各字段的定义如下。

①IP头部。标明参与隧道建立的PPTP客户机和PPTP服务器的IP地址及其他相关信息。

②TCP头部。标明建立隧道时使用的TCP端口等信息，其中PPTP服务器的端口为TCP 1723。

③PPTP控制信息。携带了PPTP呼叫控制和管理，用于建立和维护PPTP隧道。

④数据链路头部和数据链路尾部。用数据链路层协议对连接数据包（IP头部、TCP头部和PPTP控制信息）进行封装，从而实现相邻物理节点之间的数据包传输。

PPTP控制连接的建立过程如下：

① 在PPTP客户机上动态分配的TCP端口（1024以上）与PPTP服务器上的TCP 1723端口之间建立一个TCP连接；

② PPTP客户机发送一个用以建立PPTP控制连接的PPTP消息；

③ PPTP服务器向PPTP客户机返回一条PPTP消息，对连接请求进行响应；

④ PPTP客户机在接收到PPTP服务器的响应后，再向PPTP服务器发送另一条PPTP消息，并且选择一个用以对从PPTP客户机向PPTP服务器发送数据的对PPTP隧道进行标识的调用ID；

⑤ 当PPTP服务器接收到该消息后，通过另一条PPTP消息进行应答。并且为自己选择一个用以对从PPTP服务器向PPTP客户机发送数据的对PPTP隧道进行标识的调用ID；

⑥ PPTP客户机发送一条PPTP Set-Link-Info消息，以便指定PPP协商选项。

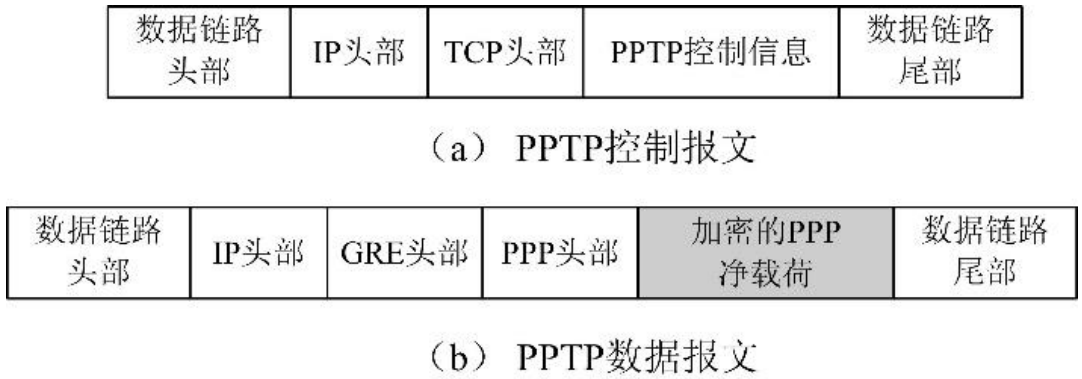


图9-8 PPTP报文格式

（2）PPTP数据报文。PPTP数据报文负责传输用户的数据，其报文结构如图9-8（b）所示。在利用PPTP控制报文完成隧道的建立后，初始的用户数据（如TCP/IP数据报、IPX/SPX数据报或NetBEUI数据帧等）经过加密后，形成加密的PPP净载荷。然后，添加PPP头部信息，封装形成PPP帧；PPP帧再进一步添加GRE头部信息，经过第二次封装便形成GRE报文；第三次封装将添加IP头部信息，其中IP头部信息包含数据包的源IP地址和目的IP地址；数据链路层封装是对IP数据报根据网络连接的情况，添加相应的数据链路头部和数据链路尾部信息。

在进行第二次封装时使用了GRE（Generic Routing Encapsulation，通用路由封装）协议。当通过PPTP连接发送数据时，PPP帧将利用GRE协议进行封装，其中GRE头部信息中包含了用以对数据包所使用的特定PPTP隧道进行标识的信息。有关GRE的详细内容将在本章随后的内容中进行介绍。

当PPTP服务器接收到PPTP数据包时，通过以下过程进行解封装过程操作：

① 处理并去掉数据链路层头部和尾部信息；

② 处理并去掉IP头部信息；

③ 处理并去掉GRE和PPP头部信息；

④ 如果需要的话，对PPP有效净载荷（即用户数据）进行解密或解压缩处理，具体根据PPTP客户机对用户数据的处理情况而定；

⑤ 对用户数据进行接收或转发处理。



9.4.2 IPSec

IPSec（IP Security）是IETF的IPSec工作组于1998 年制订的一组基于密码学的开放网络安全协议。**IPSec工作在网络层，为网络层及以上层提供访问控制、无连接的完整性、数据来源认证、防重放保护、保密性、自动密钥管理等安全服务。**IPSec是一套由多个子协议组成的安全体系。

- 1. IPSec体系结构

IPSec主要由AH（Authentication Header，认证头部）协议、ESP（Encapsulating Security Payload，封装安全载荷）协议和负责密钥管理的IKE（Internet Key Exchange，Internet密钥交换）协议组成。IPSec通过AH协议和ESP协议来对网络层或上层协议进行保护，通过IKE 协议进行密钥交换。各协议之间的关系如图9-15所示。其中：

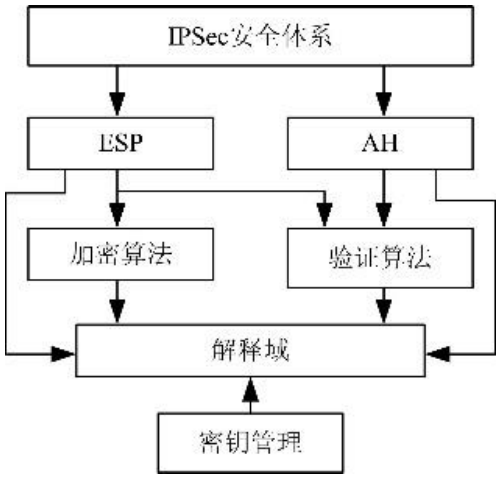


图9-15 IPSec安全体系结构示意图

（1） AH。AH为IP数据报提供无连接的数据完整性和数据源身份认证，同时具有防重放（replay）攻击的能力。可通过消息认证（如MD5）产生的校验值来保证数据完整性；通过在待认证的数据中加入一个共享密钥来实现数据源的身份信证；通过AH头部的序列号来防止重放攻击。AH的详细内容可参看RFC 2402文档。

（2）ESP。ESP为IP数据报提供数据的保密性（通过“加密算法”来实现）、无连接的数据完整性和数据源身份认证以及防重放攻击保护。与AH相比，数据保密性是ESP的新增功能。ESP中的数据源身份认证、数据完整性校验和防重放攻击保护的实现与AH相同。ESP的详细内容可参看RFC 2406文档。

需要说明的是，AH和ESP既可以单独使用，也可以配合使用。由于ESP提供了对数据的保密性，所以在目前的实际应用中多使用ESP，而很少使用AH。

（3）解释域（DOI）。解释域将所有的IPSec协议捆绑在一起，为IPSec的安全性提供综合服务。例如，当系统中同时使用了ESP和AH时，解释域将两者的安全性进行集成。

（4）IKE。IKE协议是密钥管理的一个重要组成部分，它在通信系统之间建立安全关联，提供密钥确定、密钥管理的机制，是一个产生和交换密钥并协调IPSec参数的框架。IKE将密钥协商的结果保留在SA（安全关联）中，供AH和ESP通信时使用。IKE的详细内容可参看RFC 2409文档。

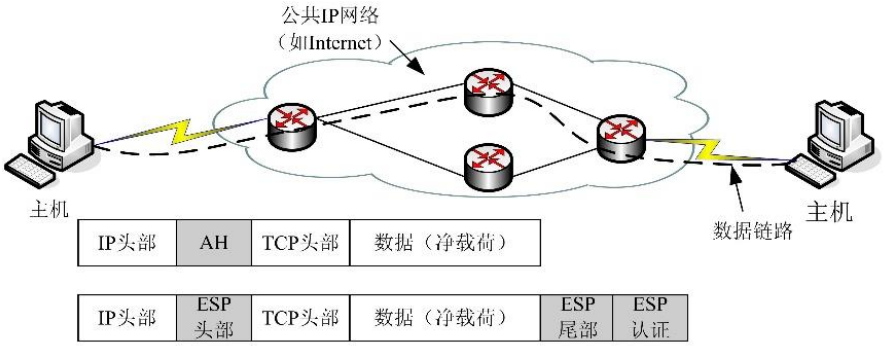
- 2．IPSec的工作模式

IPSec协议可以在两种模式下运行：传输模式和隧道模式。其中，传输模式使用原来的IP头部，把AH或ESP头部插入到IP头部与TCP端口之间，为上层协议提供安全保护。传输模式保护的是IP数据报中的有效载荷（上层的TCP报文段或UDP数据报）。传输模式的IPSec组成结构如图9-16（a）所示。

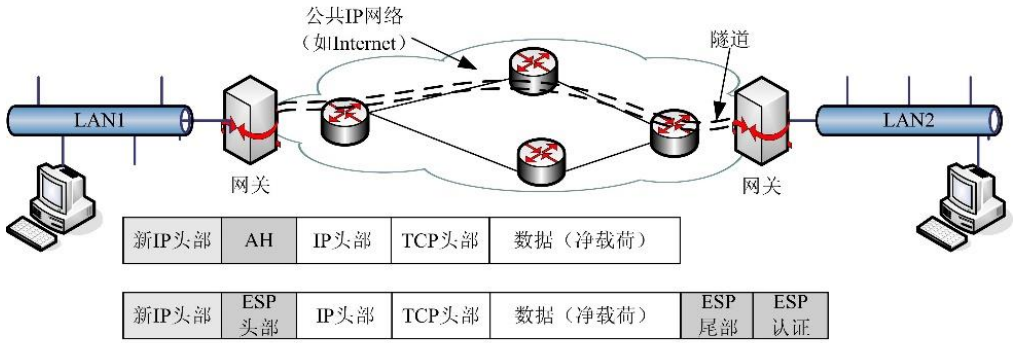
隧道模式首先为原始IP数据报增加AH或ESP头部，然后再在外部添加一个新IP头部。原来的IP数据报通过这个隧道从IP网络的一端传递到另一端，途中所经过的路由器只检查最外面的IP头部（新IP头部），而不检查原来的IP数据。由于增加了一个新IP头部，因此新IP数据报的目的地址可能与原来的不一致。隧道模式的IPSec组成结构如图9-16（b）所示。

IPSec的传输模式实现了主机之间的端到端的安全保障，AH和ESP保护的是用户数据（净载荷）。在通常情况下，传输模式只用于两台主机之间的安全通信。隧道模式为整个IP数据报提供了安全保护。隧道模式通常用在隧道的其中一端或两端是安全网关（防火墙、路由器等）的网络环境中。使用隧道模式后，安全网关后面的主机可以使用内部私有IP地址进行通信，而且在内部通信中不需要使用IPSec。

9.4 实现VPN的第三层隧道协议



（a） IPSec的传输模式



（b） IPSec的隧道模式

图9-16 IPSec的工作模式

传输模式下的IPSec数据包未对原始IP头部提供加密和认证，因而存在利用IP头部信息进行网络攻击的隐患。传输模式的优点是对原始数据包的长度增加很少，因此占用系统的开销也较小。在隧道模式下，由于原始数据包成了新数据包的净载荷，所以安全性较高，但对系统的开销较大。

- 3. AH

如图9-15所示，在IPSec安全体系中，AH通过验证算法为IP数据报提供了数据完整性和数据源身份认证功能，同时还提供了防重放攻击能力（可选），但AH协议不提供数据加密功能。其中：

（1）数据完整性。是指保证数据在存储或传输过程中，其内容未被有意或无意改变。

（2）数据源身份认证。是指对数据的来源进行真实性认证，认证依据主要有源主机标识、用户账户、网络特性（IP地址、接口的物理地址等）。

（3）重放攻击。是指攻击者通过重放消息或消息片段达到对目标主机进行欺骗的攻击行为，其主要用于破坏认证的正确性。

在传输模式中，AH头部位于IP头部和传输层协议（TCP）头部之间，而在隧道模式中，AH位于新IP头部与原IP数字报之间，如图9-17所示。AH可以单独使用，也可以与ESP协议结合使用。其中。

9.4 实现VPN的第三层隧道协议

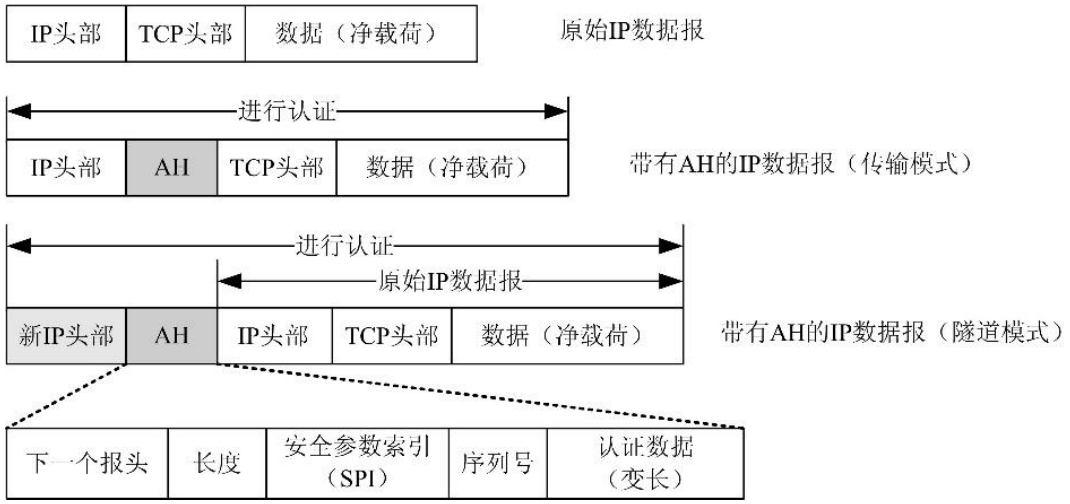


图9-17 AH的认证方式及协议组成

①下一个报头（Next Header）。用于识别在AH后面的一个IP数据报的类型。在传输模式下，将是原始IP数据报的类型，如TCP或UDP；在隧道模式下，如果采用IPv4封装时这一字段值设置为4，如果是IPv6封装时这一字段值设置为41。

②长度（Length）。AH头部信息的长度。由于在AH头部信息中还设置了“保留”字段（图9-17未标出），在不同应用中AH头部的长度是不确定的，所以对于某一个具体应用来说需要标明整个AH头部的长度值。

③安全参数索引（Security Parameters Index，SPI）。在AH头部中，SPI字段的长度为32位。SPI的值可以任意设置，它与IP头部（如果是隧道模式，则为“新IP头部”）中的目的IP地址一起用于识别数据报的安全关联。其中，当SPI为0被保留用来表明“没有安全关联存在”。

④ 序列号（Sequence Number）。序列号字段的长度为32位，它是一个单向递增的计数器，不允许重复，用于唯一地标识每一个发送数据包，为安全关联提供防重放攻击的保护。接收端通过校验序列号，确定使用某一序列号的数据包是否已经被接收过，如果已接收过，则拒收该数据包，避免了重放攻击的发生。

⑤认证数据（Authentication Data）。认证数据字段是一个可变长度的字段，但该字段中包含一个非常重要的项，即完整性检查和（ICV），它是一个Hash函数值。接收端在接收到数据包后，首先执行相同的hash运算，将运算值再与发送端所计算的ICV值进行比较，如果两者相同，表示数据完整。如果数据在传输过程中被篡改，则两个计算结果将不一致。

- 4． ESP

ESP为IP数据报提供数据的保密性（通过加密实现）、无连接的数据完整性、数据源身份认证以及防重放攻击的功能。其中，ESP安全协议的特点为：

（1）ESP服务依据建立的安全关联（SA）是可选的；

（2）数据完整性检查和数据源身份认证一起进行；

（3）仅当与数据完整性检查和数据源身份认证一起使用时，防重放攻击保护才是可选的；

（4）防重放攻击保护只能由接收方选择使用。

（5）ESP的加密服务是可选的，但当启用了加密功能后，也就选择了数据完整性检查和数据源身份认证。因为仅使用加密功能对IPSec系统来说是不安全的；

（6）ESP可以单独使用，也可以和AH结合使用。一般ESP不对整个IP数据报加密，而是只加密IP数据报的有效载荷部分，不包括IP头部。但在端对端的隧道通信中，ESP需要对整个原始数据报进行加密。

ESP的安全体系和协议组成如图9-18所示。其中ESP头部包括安全参数和序列号两个字段，其功能描述与AH相同。ESP尾部包括：

①扩展位（Padding）。其值在0~255B（字节）之间。主要是在进行数据加密处理的过程中，为了使加密数据的长度符合某一加密算法的要求（如是512的整数倍），或在加密时隐藏用户数据的真实长度，就使用扩展位来填充。

②扩展位长度（Padding Length）。它是ESP尾部的必选字段，表示扩展位的长度值。如果该字段值为0，表示没有扩展（没有使用填充）。

③下一个报头（Next Header）。用于识别在AH后面的一个IP数据报的类型，具体含义与AH协议中的下一个报头的定义相同。

ESP认证部分仅包含一个认证数据（Authentication Data）字段，只有在安全关联（SA）中启用了认证功能时，才会有此字段。其功能与AH中的数据认证字段的定义相同，但要认证的字段包括ESP头部、原始IP数据报和ESP尾部。

9.4 实现VPN的第三层隧道协议

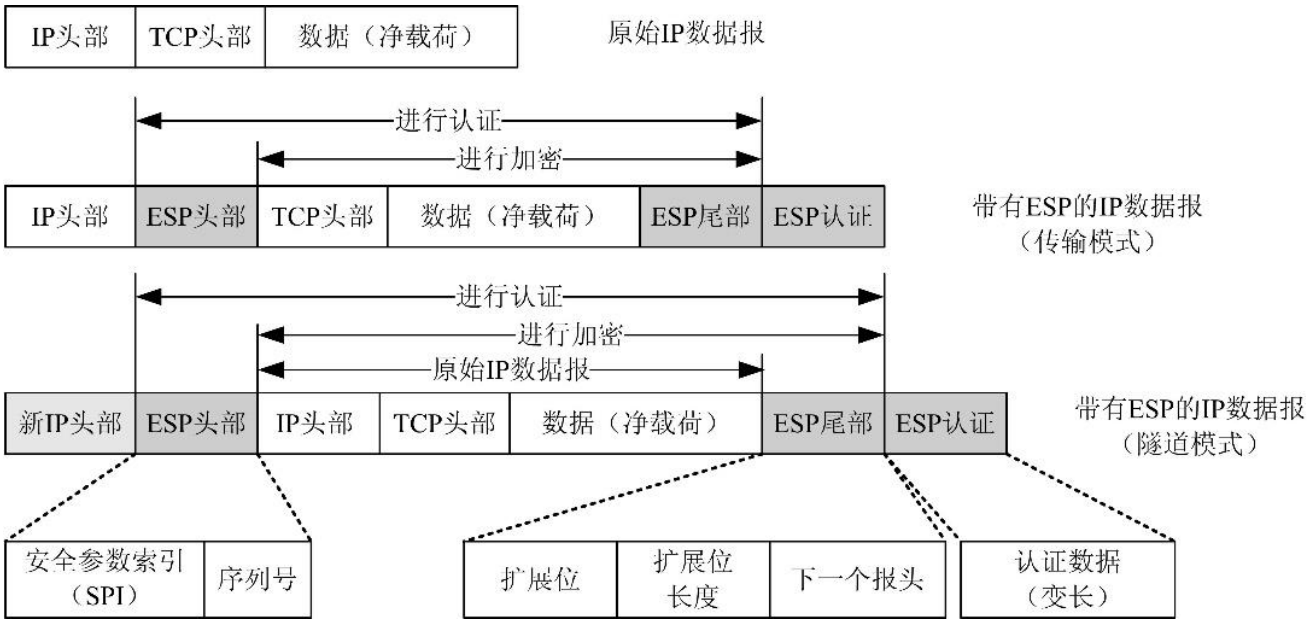


图9-18 ESP的安全体系和协议组成

- 5. IKE

IKE（Internet Key Exchange，Internet密钥交换协议）是IPSec规定的一种用来动态创建安全关联（SA）的密钥协商协议。在IPSec系统中，IKE对SA进行协商，并对安全关联数据库（SAD）进行维护。IKE是IETF提出的一种混合型协议，按照其框架设计，采用3个RFC文档来定义IKE协议：

（1）ISAKMP（Internet Security Association and Key Management Protocol）。定义了一个密钥交换的基本框架，包括报文格式、报文如何解析、密钥协商过程等。

（2）IPSec DOI（IPSec Domain of Interpretation）。它是对ISAKMP应用于IPSec解释域的描述，规定了ISAKMP和IKE究竟要协商什么。

（3）IKE。是符合ISAKMP的一个密钥交换协议。IKE是在ISAKMP的框架下定义的，它的某些细节又在IPSec DOI中进行描述。同时，IKE还采用了Oakley（Oakley密钥管理协议）的部分交换模式，以及SKEME协议的共享和密钥更新技术。

①IKE协商SA的两个阶段。IKE协商SA时分为两个阶段：第一阶段的主要目的在于验证对方的身份，从而得到ISAKMP SA，为第二阶段建立一个安全信道；第二阶段是在第一阶段协商的基础上利用找到的IPSec安全策略库中的相应策略进行协商，建立实际使用的IPSec SA。一个ISAKMP SA可用来建立多个IPSec SA。

②模式。IKE协议规定了4种模式：主模式、野蛮模式、快速模式和新群模式。其中第一阶段只能采用主模式或野蛮模式中的一种，两种模式的区别是：主模式包括6条消息，交换过程提供身份认证；野蛮模式只包括3条消息，如果不使用公钥验证方法，交换过程不提供身份认证功能。第二阶段只能采用快速模式。新群模式既不属于第一阶段，也不属于第二阶段，它跟在第一阶段之后，利用第一阶段的协商结果来协商新的群参数。

③验证方法。IKE协议指定第一阶段可以使用下列方式进行验证：

· 预共享密钥。通信双方通过某种安全途径获取交换双方唯一共享的密钥，通过Hash运算来完成认证。

· 数字签名。通信双方利用自己的私钥对特定的信息进行签名，对方利用获得的公钥进行解密处理，以确定对方的身份，完成认证过程。

· 公钥加密。通信双方利用对方的公钥来加密特定的信息，同时根据对方返回的结果以确定对方的身份。在IKE协议中可采用两种加密方法：一种是一次公钥加密，一次私钥解密；另一种是两次公钥加密，两次私钥解密。